

This is a self-archived version of an original article. This version may differ from the original in pagination and typographic details.

Author(s): Kosenkov, Oleksandr; Elahidoost, Parisa; Gorschek, Tony; Fischbach, Jannik; Mendez, Daniel; Unterkalmsteiner, Michael; Fucci, Davide; Mohanani, Rahul

Title: Systematic mapping study on requirements engineering for regulatory compliance of software systems

Year: 2025

Version: Published version

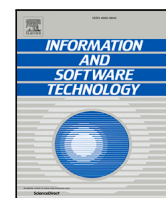
Copyright: © 2024 The Authors. Published by Elsevier B.V.

Rights: CC BY 4.0

Rights url: <https://creativecommons.org/licenses/by/4.0/>

Please cite the original version:

Kosenkov, O., Elahidoost, P., Gorschek, T., Fischbach, J., Mendez, D., Unterkalmsteiner, M., Fucci, D., & Mohanani, R. (2025). Systematic mapping study on requirements engineering for regulatory compliance of software systems. *Information and Software Technology*, 178, Article 107622. <https://doi.org/10.1016/j.infsof.2024.107622>



Systematic mapping study on requirements engineering for regulatory compliance of software systems

Oleksandr Kosenkov^{a,b,*}, Parisa Elahidoost^{a,b,1}, Tony Gorschek^{b,a}, Jannik Fischbach^{a,d}, Daniel Mendez^{b,a}, Michael Unterkalmsteiner^b, Davide Fucci^b, Rahul Mohanani^c

^a Fortiss GmbH, Guerickestraße 25, Munich, 80805, Germany

^b Software Engineering Research Lab SERL, Blekinge Institute of Technology, Valhallavägen 1, Karlskrona, 371 79, Sweden

^c University of Jyväskylä, Seminaarinkatu 15, Jyväskylä, 40014, Finland

^d Netlight Consulting GmbH, Prannerstraße 4, Munich, 80333, Germany

ARTICLE INFO

Dataset link: <https://zenodo.org/records/13999201>, <https://regulatory-re.com/sms>

Keywords:

Requirements engineering
Software engineering
Secondary research
Regulatory requirements engineering
Regulatory compliance
Compliance requirements
Software compliance

ABSTRACT

Context: As the diversity and complexity of regulations affecting Software-Intensive Products and Services (SIPS) is increasing, software engineers need to address the growing regulatory scrutiny. We argue that, as with any other non-negotiable requirements, SIPS compliance should be addressed early in SIPS engineering—i.e., during requirements engineering (RE).

Objectives: In the conditions of the expanding regulatory landscape, existing research offers scattered insights into regulatory compliance of SIPS. This study addresses the pressing need for a structured overview of the state of the art in software RE and its contribution to regulatory compliance of SIPS.

Method: We conducted a systematic mapping study to provide an overview of the current state of research regarding challenges, principles, and practices for regulatory compliance of SIPS related to RE. We focused on the role of RE and its contribution to other SIPS lifecycle process areas. We retrieved 6914 studies published from 2017 (January 1) until 2023 (December 31) from four academic databases, which we filtered down to 280 relevant primary studies.

Results: We identified and categorized the RE-related challenges in regulatory compliance of SIPS and their potential connection to six types of principles and practices addressing challenges. We found that about 13.6% of the primary studies considered the involvement of both software engineers and legal experts in developing principles and practices. About 20.7% of primary studies considered RE in connection to other process areas. Most primary studies focused on a few popular regulation fields (privacy, quality) and application domains (healthcare, software development, avionics). Our results suggest that there can be differences in terms of challenges and involvement of stakeholders across different fields of regulation.

Conclusion: Our findings highlight the need for an in-depth investigation of stakeholders' roles, relationships between process areas, and specific challenges for distinct regulatory fields to guide research and practice.

Contents

1.	Introduction	2
2.	Fundamentals and related work	3
2.1.	Background and terminology used in this manuscript.....	3
2.1.1.	Regulatory compliance: Terms and concepts.....	3
2.1.2.	Regulatory compliance of SIPS: Terms and concepts.....	3
2.2.	Related work	4
2.2.1.	SIPS users compliance	4
2.2.2.	SIPS developers compliance	4
2.2.3.	SIPS compliance.....	5

* Corresponding author.

E-mail address: oleksandr.kosenkov@bth.se (O. Kosenkov).

¹ These authors contributed equally to this work.

3.	Study design.....	5
3.1.	Research goal and research questions.....	5
3.2.	Research methodology.....	6
3.2.1.	Data preparation.....	6
3.2.2.	Data extraction.....	8
3.2.3.	Data analysis.....	10
4.	Results and discussions.....	10
4.1.	Trends throughout years, venues, and authors.....	10
4.2.	RQ1: What are the reported challenges in regulatory compliance of SIPS?.....	11
4.2.1.	Discussion Section 4.2.....	11
4.2.2.	Primary studies in other disciplines.....	15
4.3.	RQ2: What is needed to address the challenges to the regulatory compliance of SIPS and what are the PPs used for that?.....	16
4.3.1.	Discussion Section 4.3.....	16
4.4.	RQ3: Which stakeholders were involved in the development of PPs for regulatory compliance of sips?.....	18
4.4.1.	Discussion Section 4.4.....	18
4.5.	RQ4: What are the main software processes areas (PAs) involved in enabling the regulatory compliance of sips?.....	19
4.5.1.	Discussion Section 4.5.....	20
4.6.	RQ5: Which regulations and domains of application are the most considered in regulatory compliance of SIPS?.....	22
4.6.1.	Domain of application.....	22
4.6.2.	Fields of regulation.....	22
4.6.3.	Regulations.....	22
4.6.4.	Discussion Section 4.6.....	23
5.	Threats to validity.....	25
5.1.	Internal validity.....	25
5.2.	External validity.....	25
5.3.	Construct validity.....	25
6.	Conclusions and further research directions.....	25
	CRedit authorship contribution statement.....	26
	Declaration of competing interest.....	26
	Appendix A.....	26
	Appendix B. Supplementary data.....	26
	Appendix. Data availability.....	26
	References.....	26

1. Introduction

Motivation. Software engineers are facing an increasing amount of regulations that affect software-intensive products and services (SIPS) either directly by regulating technology (e.g., artificial intelligence) or indirectly by regulating processes along which SIPS are developed and/or in which they operate (e.g., personal data processing). Analysts predict that further regulatory scrutiny of the Information Technology (IT) sector will continue to intensify for various issues, ranging from privacy to new advanced technologies [1]. Software engineers must respond to multiple regulations that are often concurrently applicable. These regulations can also address different issues (e.g., privacy and security) and different aspects of software systems (e.g., properties of software systems and user behavior [2]) with structured principles and practices. A well-structured approach to implementing and adhering to regulations in software engineering is essential to achieve regulatory compliance and provide evidence of that compliance (i.e., the reproducible implementation of demands contained in the regulations). Failure to implement and demonstrate compliance can result in sanctions ranging from large fines to removing non-compliant SIPS from the market.

Existing scientific studies already provide a significant body of knowledge about the regulatory compliance of SIPS. Due to the steady growth of regulatory demands, SE research and practice would benefit from a more systematic understanding of regulatory compliance and its multiple facets. In particular, such a systematic understanding is essential, especially in (software) requirements engineering (RE), which largely contributes to the compliance of SIPS by translating regulations into manageable (and testable) requirements [3,4]. Hence, we argue that RE practices should be systematically guided to contribute to implementing regulatory compliance and raise awareness of specific engineering challenges it needs to address. The connection of RE to

other software development life cycle (SDLC) process areas is important [3] to seamlessly and consistently address the implementation of regulations throughout the entire SDLC [5,6]. Existing literature focuses on multiple RE principles and practices; however, there is no clear and commonly accepted understanding of the challenges they address, their contribution to subsequent SDLC process areas, and the various stakeholders' involvement and roles. A synthesis of the data available in primary studies on these matters would contribute significantly to systematizing RE for regulatory compliance.

Objective. Our objective is to structure and synthesize the publication via a secondary study focusing on challenges, principles, and practices in regulatory compliance of SIPS. Our research aims to identify **the state of reported evidence in RE for regulatory compliance**. We are mainly focused on the RE-related aspects of regulatory compliance of SIPS related to (1) challenges to the regulatory compliance of software systems, (2) principles and practices, and (3) affected SDLC process areas. Furthermore, we analyze the involvement of stakeholders in the development of principles and practices. We also extract and analyze data about different regulatory fields and application domains to account for the differences in implementing compliance with different regulations in different application domains.

Contribution. Our study makes the following core contributions:

- categorization of RE-related challenges to regulatory compliance of SIPS into 14 categories;
- identification of six main types of principles and practices and their mapping to challenges to the implementation of regulatory compliance;
- identification of five stakeholder types that are reported to be involved in the development, application, and validation of principles and practices and their mapping with challenges and fields of regulation;

- identification of SDLC process areas and RE processes that are considered in the primary studies we identified;
- identification of domains of application, fields of regulation, and regulations reported in primary studies.

The contribution of our research is complementary to multiple previous secondary studies that have considered regulatory compliance from different, more isolated perspectives. Some of the secondary studies were mainly focused on the compliance of SE processes [7,8], the application of a single principle or practice such as goal-oriented modeling [9,10], particular compliance tasks such as compliance management [11], or compliance to one specific regulation (e.g., GDPR [12]). Other studies have considered regulatory compliance challenges [11] in general without having the entire software development life-cycle in scope, and those studies considering the regulatory compliance implementation throughout the SDLC did not, in turn, analyze challenges, principles, and practices along the main process areas [3]. Our study aims to close those gaps and provide a synthesized view of the broad publication landscape to the community of researchers and practitioners.

Outline. The rest of the paper is structured as follows—in Section 2.1, we synthesize the theoretical background based on computer science and legal literature. In Section 2.2, we provide an overview of related secondary studies and describe how our study complements existing work. In Section 3, we present the design and the main stages of the systematic mapping study. Section 4 introduces and discusses the results, structured along our research questions. We analyze the potential threats to the validity of our study in Section 5 before concluding, in Section 6, our work and suggesting potential directions for future work.

Data availability. We publish our dataset of the data extracted from the 280 primary studies we have identified for this study (available on [Zenodo](https://zenodo.org/doi/10.5281/zenodo.13999201) (DOI: 10.5281/zenodo.13999201) or on the website²). The dataset includes the following data: study metadata (title, venue, publication year, authors, authors' affiliation, abstract), challenges to regulatory compliance (direct excerpts from studies), categories of challenges to compliance, principles and practices (direct excerpts from text), categories of principles and practices, types of automation of principles and practices, involved stakeholders (direct excerpts from studies), categories of involved stakeholders, phase of principle and practice life cycle for which involvement of stakeholders was considered, SDLC process areas covered by the study, regulations considered in the study, fields of regulations that were considered, domains of application that were considered and assessment of rigor and relevance.

2. Fundamentals and related work

Regulatory RE is an interdisciplinary research area requiring the synthesis of legal and SE perspectives. Therefore, we first introduce the basic terms used throughout our study (from the perspective of SE) before reviewing work directly related to our own.

2.1. Background and terminology used in this manuscript

This section provides an overview of the terms and concepts used in this study.

2.1.1. Regulatory compliance: Terms and concepts

Nowadays, organizations operate in a complex business landscape with multiple obligatory norms of different origins. This makes *compliance* — a state of verifiable adherence to all obligatory pre-defined legally binding norms [13–16] — one of the priorities for organizations. Organizations pay special attention to *regulatory compliance*—the state

of verifiable adherence to public, general, obligatory norms specified in regulations [10,17]. In this research, we define *regulation* as any official document that is a source of public, general, obligatory norms issued by regulators [18,19]. We also consider standards to be a type of regulation. While standards are not legally binding, many regulators can use them as a reference point to amend regulations or enforce standards as a source of legally binding requirements for regulatory compliance [20] (e.g., GDPR makes references to approved certification mechanisms as an element to demonstrate compliance to GDPR norms). Moreover, standards are recognized as one of the compliance concerns in SE research [21].

In this study, we consider *regulators* as any public entities (and other entities empowered by regulators) that have a special authority to issue, monitor, and enforce regulations in the name of public interests [18,19, 22,23]. Regulations are enacted to address a specific *field of regulation* (like the concept of “field of law”)—a group of social relations that are addressed by the regulation (e.g., GDPR belongs to the personal data protection field of regulation).

2.1.2. Regulatory compliance of SIPS: Terms and concepts

Based on IEEE 1471-2000 [24], we define *software-intensive products and services (SIPS)* as any products and services in which software components contribute to the design, construction, deployment, and evolution of the system as a whole or make an essential contribution to the added value of products and services.

Nowadays, SIPS are an essential element of organizations [25] that should comply with regulations applicable to organizations operating them. Moreover, regulators increasingly enact new regulations specifically addressing SIPS. This creates a challenge of *regulatory compliance of SIPS*. We define regulatory compliance of SIPS as the state of verifiable conformance of functional and non-functional properties of SIPS to criteria laid out in regulations about (1) SIPS as a system, solution, or any other type of a tangible or intangible good, (2) SIPS development process, (3) SIPS stakeholders (end-users, operators, etc.), (4) SIPS operational environment [14,15]. Regulatory compliance of SIPS should be considered throughout the SIPS life cycle. We identify the following *process areas (PAs)* in the SIPS life cycle based on SWEBOK [26] and ISO/IEC 12207 and deduce their potential contribution to regulatory compliance of SIPS:

- SIPS Requirements Engineering (RE)—systematic handling of requirements to SIPS that derive from regulations. This main process area includes the following processes: requirements elicitation, requirements analysis and modeling (REA/M), requirements specification (RES), requirements verification and validation (REVV), and requirements management (REM). Regulatory RE is an area of requirements engineering practice and research that contributes to the compliance of SIPS by processing requirements derived from regulations for SE purposes.
- SIPS design (SD) - the process of defining the internal structure (e.g., architecture, components, interfaces) of SIPS in a way that will enable their regulatory compliance (e.g., assure verifiability, address future evolution of regulations).
- SIPS development (SDev) refers to the detailed creation of working SIPS through coding, verification, unit testing, integration testing, and debugging. SIPS development process area is related to implementing requirements derived from regulations.
- SIPS quality assurance (SQA) consists of the dynamic verification that SIPS provide expected behaviors on a set of test cases addressing the regulators' perspective on compliance by verifying the implementation of all requirements originating from regulations (e.g., [27]) and also by using tools and methods applied by regulators for compliance verification.
- In our study, we define SIPS deployment (SDep) as a set of activities directed towards generating executable and testable SIPS components, combining related components with a single

² <https://regulatory-re.com/sms>

Table 1

Overview of the most recent related secondary studies showing research areas (e.g., regulatory RE principles and practice) and topics (goal and non-goal-modeling principles and practices) covered by each secondary study.

Study scope	[29]	[30]	[8]	[3]	[31]	[7]	[10]	[32]	Our study
Year	2024	2023	2022	2021	2020	2020	2019	2018	2024
<i>Aspect of compliance</i>									
• Challenges	–	X	X	X	–	–	X	X	X
• Principles & Practices	X	X	X	–	X	X	X	X	X
— Goal/nongoal modeling	–	–	–	–	–	–	X	–	–
— Automated	–	–	X	–	–	–	–	–	–
• Stakeholders involvement	–	X	–	–	–	–	X	–	X
• Different PAs Considered	–	–	–	X	–	X	–	–	X
• Domains of application	–	X	X	–	X	X	X	–	X
• Fields of regulation	–	X	X	–	–	X	X	–	X
— Security	–	–	–	–	–	X	–	–	–
<i>Type of compliance</i>									
• Regulatory	X	X	X	X	X	X	X	X	X
• Non-obligatory	–	X	–	–	–	–	–	X	–
<i>Compliance scope</i>									
• Business process	–	–	–	–	X	–	X	X	–
• Engineering process	–	X	X	–	X	–	–	X	–
• SIPS	X	X	–	X	–	–	X	–	X

deployable artefact and putting SIPS into operation [28]. With the advancement of DevOps and automation practices, it becomes essential to assure regulatory compliance of the SIPS deployment process and regulatory compliance of the deployed SIPS.

- SIPS maintenance (SM) is the totality of activities required to provide cost-effective support to SIPS in operation to ensure that SIPS remains compliant throughout the software and regulatory evolution.

Challenges to the regulatory compliance of SIPS are general types of SE issues that emerge in achieving the regulatory compliance of SIPS.

Principles and practices for regulatory compliance of SIPS (PPs) are any means employed to implement regulatory compliance of SIPS and to tackle the related challenges. These include but are not limited to SE methods, tools, frameworks, solutions, and models. For this research, we consider that the life cycle of PPs comprises three core stages: (1) development, (2) application, and (3) validation. In each of these stages, specific types of stakeholders can be involved. For example, legal experts can be involved in developing PPs but not in their application and validation. PPs can be applied in a particular *domain of application* - operational domain in which SIPS are engineered, and PPs for the regulatory compliance of SIPS are applied (see Table 1).

2.2. Related work

Although no systematic mapping study exists on RE for regulatory compliance of SIPS, multiple secondary studies can be found in *three* different research tracks related to this topic.

2.2.1. SIPS users compliance

Compliance of SIPS users is mainly concerned with questions related to compliance to norms imposed on (1) SIPS users directly, (2) business processes of SIPS users (as one of the essential elements of the SIPS operational environment), or (3) the operational environment of SIPS. Secondary studies in this category provide insights into methods for processing regulation but do not make an explicit connection between such methods and SE. Some studies in this category (e.g., Ghanavati et al. [9]) consider methods and tools for business process compliance as applicable for RE; still, they do not discuss an explicit connection between business process compliance and implementation of compliance of SIPS.

Mustapha et al. [31] reported on several research directions towards some of the challenges faced in managing compliance of business processes. The systematic review identified BPCM (Business Process Compliance Requirements Management) approaches, the most addressed

constraint types, environments where business processes have been more implemented, and a comparative analysis of several works that have been carried out in this field of research. Mustapha et al. [31] considered two classes of the application domain: traditional and cloud environments. Still, such categorization does not allow a sufficiently granular analysis of differences between implementing compliance in different domains.

Another relevant study was conducted by Hashmi et al. [32]. Their survey aims to understand the current state of affairs in the compliance of business processes, summarize the weaknesses of existing techniques for business process compliance, and identify areas for further work.

Fellmann et al. [33] provided an overview of the focus and distribution of current compliance approaches for business processes by conducting a literature review.

Becker et al. [34] conducted a literature review to analyze existing business process compliance and to check approaches according to (1) their applicability to arbitrary modeling techniques and (2) their ability to address a preferably wide range of possible compliance rules.

Shamsaei et al. [35] suggest goal-oriented compliance management using Key Performance Indicators (KPIs) to measure the compliance level of organizations as an area that can be further developed. They undertook a systematic literature review to investigate their hypothesis, querying four major search engines and performing manual searches in related workshops and citations.

Ghanavati et al. [9] reported on a systematic literature review focusing on goal-oriented legal compliance of business processes. Eighty-eight studies were selected out of nearly 800 unique studies extracted from five search engines, with manual additions from the Requirements Engineering Journal and four relevant conferences.

2.2.2. SIPS developers compliance

Secondary studies in this category mainly focus on implementing regulatory compliance in SIPS development. These studies are usually related to regulations specifically imposing regulatory demands on the SIPS development process (e.g., safety and security standards); they cover only a part of our approach to compliance of SIPS.

Ardila et al. [8] conducted a systematic literature review on compliance checking of SE processes published in 2022. They identified 41 studies and characterized the methods for automatic compliance-checking of software processes, including used techniques, potential impacts, and challenges. The authors considered challenges to compliance of SIPS development processes but identified only five categories of abstract challenges (“the use of software process modeling languages”, “language suitability for addressing normative requirements”, “towards a generic and domain-agnostic method”, “increase the level

of automation and tool support”, “application in practice”) that were not directly mapped to the information extracted from publications.

Moyon et al. [7] report on a systematic mapping study where they addressed security compliance in agile software development. They described the maturity of the field and domains where security-compliant agile SE was investigated. The authors considered PPs for regulatory compliance related to agile software development.

Naira et al. [36] developed a taxonomy that classifies the information and artifacts considered as evidence for safety. They reviewed 218 studies and the existing safety evidence structuring and assessment techniques and further studied the relevant challenges that have been the target of investigation in the academic literature.

2.2.3. SIPS compliance

Few previous secondary studies have tried to address SIPS compliance with a broader research perspective that would cover both the compliance perspective of SIPS developers, SIPS users, and SIPS as a system. This way, studies having such scope could potentially cover not only compliance in SIPS development processes but also compliance of SIPS as a standalone product or service and SIPS in use by a particular type of organization. Such works were characterized by the efforts to consider all the tasks throughout the legal or regulatory compliance process [10], focusing on SIPS compliance and users of software [37].

Studies in this research track usually have a specific scope, such as applying a particular type of modeling PPs (e.g., goal-oriented methods [10]).

Further, some studies applying a broader approach often lack a clear scope of SIPS compliance and cover business processes or other “types” of compliance along with SIPS compliance. As a result, only a few works provide data sufficient to analyze the implications of regulatory compliance on SE.

The secondary study with the scope closest to ours is Mubarkoot et al. [30]. In this study, the authors have conducted a systematic literature review to investigate software compliance requirements, factors, policies, and the challenges they address. The study considered human- and technology-related challenges to compliance but did not provide their clear and granular categorization. The study primarily focused on policies as a means of addressing challenges. Also, the study suggested classifying policies based on the type of compliance challenges they address. This classification includes two large classes, which are as follows: technological challenges (software certification, regulation-oriented architecture, model-driven development, applying most restrictive laws, outsourcing, runtime security auditing) and human challenges (SETA, promote organizational and social bounds, incorporate appropriate responses, reward and punishment, investigate workarounds, internal control, and auditing, establish codes of ethics). Still, the granularity of classification suggested in the publication does not allow further analysis useful for implementing regulatory compliance in SE. This study identified the following types of users considered in publications: architects, auditors, developers, domain experts, end users, Information System professionals, legal experts, managers, requirements engineers, safety engineers, and service providers. Still, reported data does not allow the identification of concrete trends regarding stakeholders’ involvement.

Mubarkoot & Altmann [37] investigated frameworks used for managing the compliance of software and software services and their applications across different industries in their systematic literature review published in 2021. The study was developed based on industry classification of the frameworks’ specific needs, business requirements, and the context of compliance in 63 identified studies.

Kempe et al. [3] published a systematic literature review in 2021 and analyzed 20 studies to research regulatory and security standard requirements addressed throughout the SDLC.

Negri-Ribalta et al. [29] conducted a systematic mapping study to discover the trends of PPs proposed in requirement engineering to achieve GDPR compliance. The paper also identified the different

stages of RE the primary studies focused on, the concrete GDPR norms studies covered, and if the authors of the primary studies belonged to different disciplines. The study found that most studies approached GDPR compliance as a whole without focusing on specific “elements to achieve compliance”. Also, this study claims that interdisciplinary research in this area is essential as legal knowledge is required and that GDPR requirements affect a range of engineering disciplines, not only requirements engineering.

Abdullah et al. [38] undertook a review of the current research on compliance management topics in the Information Systems research, with the ultimate goal of carrying out a gap analysis between research-based solutions and the current needs of compliance management professionals.

Cleven et al. [39] examined the state-of-the-art compliance research in Information Systems using a comprehensive literature analysis.

Finally, Otto et al. [40] surveyed research efforts over the past 50 years in modeling and using legal texts for system development. They identified the strengths and weaknesses of each approach and proposed a broad set of requirements for tool support that would aid requirements engineers and compliance auditors.

Akhigbe et al. [10] explored how goal-oriented and non-goal-oriented modeling methods have been used for legal and regulatory compliance and identified their main claimed benefits and drawbacks based on the kind of compliance tasks they perform. Using a systematic literature mapping approach, they evaluated 103 studies. Akhigbe et al. [10] considered compliance challenges but only in the context of the application of goal modeling (e.g., the challenge of applicability of goal models for only comparing models generated from legal texts and not the legal texts themselves). Also, the authors considered the target audience for applying goal-oriented and non-goal-oriented modeling methods for legal or regulatory compliance. However, only three categories of the target audience were identified, such as regulated parties (considered in 82% of studies), regulators (considered in 12% of studies), and both regulated parties and regulators (in 6% of studies).

Considering previous related work Table 1, our research aims to complement the existing state of research in several ways. In particular, in this study, we approach compliance of SIPS:

- independently of a particular regulation or field of regulation (e.g., GDPR);
- holistically by considering the contributions of RE to all the main process areas (PAs) of the SIPS life cycle;
- as involving both SIPS users’ and SIPS developers’ compliance perspectives;
- independently of a type of software system or SIPS (e.g., safety-critical systems);
- focusing specifically on regulatory compliance, and excluding other types of compliance (e.g., compliance with contracts, internal policies);
- with a broader approach to compliance that does not only consider the compliance of requirements but rather the compliance of the software systems in general

3. Study design

In this section, we describe the goal of this study and its research questions. Then, we describe the methodology we applied.

3.1. Research goal and research questions

This secondary review aims to comprehensively assess the current evidence regarding RE for regulatory compliance of SIPS. It focuses on identifying the challenges in this domain and explores how established PPs address those challenges. Our primary objective is to provide a detailed overview of the existing research landscape while offering valuable insights for future investigations, benefiting researchers and practitioners. To achieve these aims, we propose the following research questions (RQ):

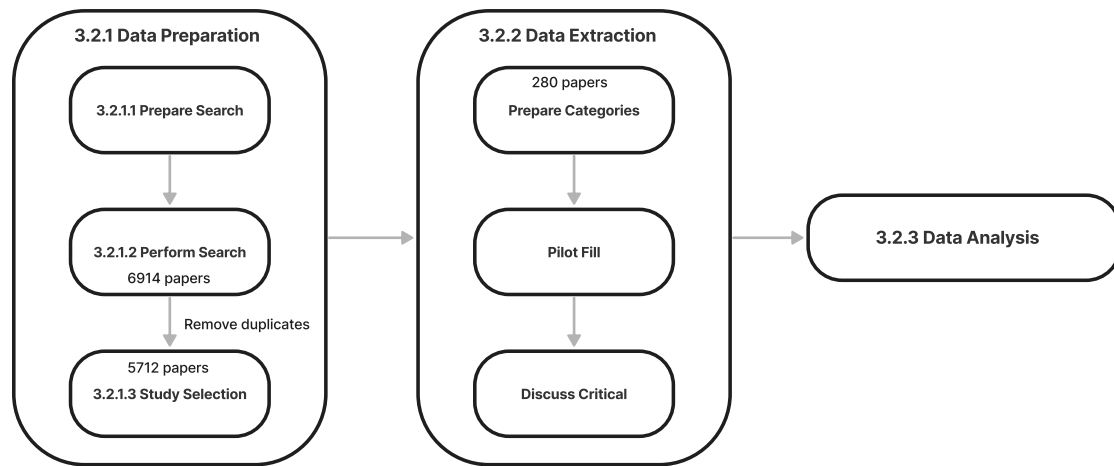


Fig. 1. Study setup.

- RQ1 What are the reported challenges in regulatory compliance of SIPS?
- RQ2 What is needed to address the challenges to the regulatory compliance of SIPS, and what principles and practices (PPs) are used/suggested?
- RQ3 Which stakeholders are involved in developing, applying and/or validating principles and practices for regulatory compliance of SIPS?
- RQ4 What are the main software process areas (PAs) involved in enabling the regulatory compliance of SIPS?
- RQ5 Which regulations and domains of application are the most prevalent in regulatory compliance of SIPS?

These research questions have been conceptualized to address various critical aspects of regulatory RE in ensuring compliance with SIPS. The challenges associated with regulatory compliance in SIPS largely stem from the inherent complexity of regulations as a source of requirements. Furthermore, the development of effective PPs, alongside the active involvement of stakeholders, is closely tied to the RE process. Additionally, variations in applicable regulations and differences across application domains are particularly significant in shaping the RE process.

3.2. Research methodology

For this study, we followed the systematic mapping study (SMS) procedure according to Kitchenham et al. [41]. We extracted and analyzed multiple interrelated categories of data (something similar to a systematic literature review (SLR) approach). Nevertheless, several factors characterize our study as an extensive SMS. The primary goal of our study was to embrace different RE-related aspects of SIPS regulatory compliance and their potential interrelationships. To this end, we collected and analyzed data on a high level of granularity. For example, we did not distinguish in detail how particular challenges were reported in primary studies, but we calculated the occurrence of mentions of challenges. Similarly, we did not conduct a detailed analysis of the involvement of different stakeholders.

The level of analysis we selected is sufficient to identify general trends and make high-level conclusions about the relationships between the categories of extracted data. Subsequently, we encourage other researchers to undertake detailed literature reviews to further analyze and validate the trends identified in this mapping study. Fig. 1 summarizes the study setup, which is split into three major phases—data preparation, extraction, and analysis.

3.2.1. Data preparation

During the data preparation phase, the first two authors were responsible for collecting the primary studies for data extraction. Initially, we developed a search string guided by the aforementioned research questions. This involved a careful process beginning with the creation of a comprehensive set of keywords, which were thoroughly discussed and refined in collaboration with all co-authors. Following this, we conducted a pilot search to test and optimize the query. We then applied the finalized search string across a predefined set of databases, systematically screening the identified studies based on their titles and abstracts (see Fig. 1).

Based on the RQs, we also prepared a dataset containing a list of known studies relevant to our review. We searched the most important SE databases to ensure we did not miss any relevant studies concerning the regulatory compliance of SIPS. We selected these sources employing the recommendations of Dyba et al. [42], using ACM Digital Library³, IEEE Xplore⁴, and an indexing system (Scopus⁵). We extended their proposal to include Elsevier (Science Direct⁶) as well⁷.

3.2.1.1. Preparation of the search string. As an initial step, we developed the search string following the guidelines provided by Brereton et al. [44]. To ensure the search results remained relevant to our study's scope, we began by incorporating the term “software” followed by “requirement”. Next, we selected additional keywords related to regulatory compliance. After updating the search string, we conducted a pilot search to test its effectiveness. For example, one of the tried search queries was (“Requirement* engineering” OR “Software engineering” OR “Software system”) AND (“Regulatory compliance” OR “Legal compliance” OR “Regulation”)—returned twice as many search results from a single database during preliminary investigations.

While conducting trial searches, we observed studies focusing on regulatory RE and compliance of systems other than SIPS (e.g., hardware, embedded systems) and compliance with regulations focused on hardware. We argue that regulatory RE and compliance of SIPS are different from non-SIPS systems. For example, it is well-known that SIPS development teams actively apply agile methods, while other engineering teams (e.g., mechanical engineering teams) only rarely apply agile methodologies [45]. In addition and, according to some of the studies in the domain of medical devices, regulations on medical

³ <https://dl.acm.org/search/advanced>

⁴ <https://ieeexplore.ieee.org/search/advanced/command>

⁵ <https://www.scopus.com/search>

⁶ <https://www.sciencedirect.com/search>

⁷ It is among the databases like ACM and IEEE that host the major journals and conference proceedings related to SE [43]

Table 2

Search strings for each data source and number of results.

Database	Entries	Results
Scopus	TITLE-ABS-KEY (software AND requirement AND (regulation OR regulatory OR compliance OR law OR legal OR certification)) AND PUBYEAR > 2016 AND PUBYEAR < 2024	4295
IEEE Xplore	("Abstract":software AND requirement AND (regulation OR regulatory OR compliance OR law OR legal OR certification)) OR ("Author Keywords": software AND requirement AND (regulation OR regulatory OR compliance OR law OR legal OR certification)) OR ("Publication Title": software AND requirement AND (regulation OR regulatory OR compliance OR law OR legal OR certification)). Filters Applied: 2017–2023	1246
ACM Digital Library	Title:(software AND requirement AND (regulation OR regulatory OR compliance OR law OR legal OR certification)) OR Abstract:(software AND requirement AND (regulation OR regulatory OR compliance OR law OR legal OR certification)) OR Keyword:(software AND requirement AND (regulation OR regulatory OR compliance OR law OR legal OR certification)) AND [E-Publication Date: (01/01/2017 TO 12/31/2023)]	987
Science Direct	Title, abstract, keywords: software AND requirement AND (regulation OR regulatory OR compliance OR law OR legal OR certification). Filters Applied: 2017–2023	386
Total:		6914
Without duplicates:		5712
After first assessment:		341
Primary studies selected:		280

devices created without specifically considering software as a medical device are considered to be problematic and hardly applicable to “software as a medical device” and software-intensive medical devices (e.g., [46]). To exclude the studies that were not focused on SIPS from the search results set, we added the keyword “software” with a boolean operator “AND”. We tested this search string and found out that it allows us to reduce the number of primary studies focused on non-SIPS requirements and compliance significantly while not losing studies we deemed relevant. This change of the search string also allowed the removal of a massive number of studies not focused on RE and compliance of any systems, but rather requirements applicable only to organizations, business processes, etc.

In the process of experimenting with various search strategies, we have also tried variations of the same words (e.g., “regulation”, “regulatory”) and the application of wildcards (e.g., “regulat*”). The results of such variations turned out to yield inconsistent results sets across the databases. For example, we observed that the number of results in Scopus and IEEE increased by about 200 hits each while the number of results in ACM decreased by about 200 hits. Furthermore, the search in title, abstract, and keywords with the application of wildcards was not possible for ScienceDirect. To address this issue, we have reviewed the first 100–200 search results with and without wildcards for Scopus and IEEE. Our review showed that the number of hits mainly increased due to the increase of the number of hits in other disciplines not related to SIPS engineering (e.g., regulated medicines consumption) and we were not able to identify any primary studies relevant to our research among the reviewed search results. Taking this into account, we therefore decided to apply the search string without wildcards across all the databases.

The final search query is:

software AND requirement AND (regulation OR regulatory OR compliance OR law OR legal OR certification)

Performing search. We adapted the search string to each database (depending on the allowed syntax) and performed the search for authors’ keywords, titles, and abstracts. Table 2 shows the search query and the number of results for each database. After removing the duplicates, we collected 5712 studies, which we divided for screening among the first two authors by reading the title and abstract (see Fig. 1).

After searching, we have also tried to apply the snowballing procedure as per the guidelines by Wohlin [47] for further identification of primary studies. Applying the snowballing procedure for our study turned out to be challenging. Firstly, the main scope of our study was primary studies considering the contribution of RE to SIPS regulatory compliance. Many primary studies focus on other process areas such as software design or quality assurance, but still include aspects of RE to support these process areas. However, identifying such studies via snowballing without applying keyword search is impossible. For

example, [48] is one of the primary studies we have identified while executing our search query and is relevant to our study. One of the studies referring to it is [49]. This study is relevant from the perspective of the regulatory compliance of SIPS as its main goal is to ensure regulatory compliance of log data processing with regulations such as GDPR. However, this study fully omits aspects related to RE required to achieve their goal. Therefore, the only option we deemed to be systematic and effective in identifying the relevance of such studies is to search for the keyword “requirement”. Next, our systematic mapping is limited to the most recent publications which limits the effectiveness of snowballing. Finally, we intentionally searched for publications belonging to different communities and disciplines to include different perspectives making it particularly challenging to account for all the communities in a starter set. While RE is the main research community of interest for our study, it is known that existing RE studies do not provide an overview of how regulatory requirements are approached throughout the SDLC [4].

Study selection. The first two authors screened the studies based on their titles and the abstract, then scanned the entire text only when necessary to reach a judgment. In this phase of the study selection process, we used an initial set of inclusion and exclusion criteria to identify the relevant studies. Specifically, we used the following inclusion criteria:

- The study must be in English.
- The study published in the period between January 1st, 2017 and December 31st, 2023.
- The context of the study is only SE—defined as “a systematic approach to the analysis, design, assessment, implementation, test, maintenance and re-engineering of software, that is, the application of engineering to software” (Laplanche [50]) or software systems. This also includes SE in the context of other types of systems and products (e.g., automotive, mechatronics).
- The study is focused or relevant to regulatory compliance.
- The study must be published in a peer-reviewed scientific journal, conference, symposium, or workshop.

We also decided to select studies published in a particular period. Regulation of software-intensive technologies evolved worldwide in the recent decade. And regulators have been proactively trying to respond to technological developments [51]. As a result, new regulations are enacted, and new regulatory approaches and frameworks are being tried out. GDPR marked the introduction of such a new framework aimed at responding to the most recent advancements in ICTs [52,53]. In recent years, regulators have drafted or enacted multiple new regulations (e.g., the Cyber Resilience Act, AI Act proposed in 2021). As these new regulations incorporate the most recent regulatory ideas, we have decided to focus on regulatory RE and compliance of SIPS with such new regulations. Therefore, our study focuses on the most

recent primary studies, starting from 2017—the year after the General Data Protection Regulation (GDPR) was enacted in April 2016 and one year before GDPR became enforceable in May 2018. We considered the following exclusion criteria during our study:

- The study is not peer-reviewed.
- The study is a secondary study.
- The study is a doctoral thesis, master's thesis, or opinion report, or a book chapter.
- The study's reference to regulatory compliance is tangential to the overall purpose or contributions.
- The study is extended in another study (e.g., a journal extension of a conference paper).
- The study is already mentioned in another database (duplicated Studies).
- The study cannot be accessed.

At the end of the first phase of the selection process, we conducted an additional synchronization involving the first two authors and the fifth author. The first two authors identified 183 “borderline studies” selection of which using the defined selection criteria was challenging. It was decided to analyze these studies. Both researchers checked the studies together until they reached an agreement. After this assessment round, the number of studies was reduced from 5712 to 341. To improve the selection process and as the result of synchronization between the researchers, the initial list of exclusion criteria was refined with additional exclusion subcriteria that are as follows:

- studies considering the regulatory compliance of other types of systems or systems containing software without specifically addressing software component compliance (e.g., radio equipment [54]);
- studies considering business process compliance without explicitly considering business process modeling as an RE method or other application for SIPS engineering (e.g., [55]);
- studies considering the regulatory compliance of IT infrastructure of organizations, without focusing specifically on the implementation of regulatory compliance at the level of a software system (e.g., development of communication protocols);
- studies considering compliance other than to general obligatory regulations or standards (e.g., contracts [56]);
- regulatory compliance of software system or PPs applicable for regulatory compliance is not a primary focus of the study (e.g., [57] reported GDPR compliance as one of the challenges that small and medium enterprises encounter, but did not focus on GDPR compliance);
- studies related to the application of software as a tool for compliance rather than an object of compliance (e.g., studies on RegTech solutions not intended for SIPS [58]);
- studies on the regulatory compliance of software development organizations without an explicit connection to regulatory compliance of SE processes or SIPS (e.g., [57] presented a set of concerns underlying the design of a business continuity plan for companies that have certified invoicing software);
- studies considering regulations related to software systems, without specific focus on the implementation of compliance of SIPS (e.g., Cybersecurity Maturity Assessment Framework in compliance with NIS Directive [59]).

In the next phase of the selection process, each researcher applied additional (refined) exclusion criteria to studies included after the first phase (341 studies). Like the previous phase, the two primary authors scanned the abstract, and in unclear cases, the full text was examined. After this final assessment round, 280 final primary studies were identified. For having a mutual agreement between two researchers while doing the first round of assessment and study selection based on the title and abstract, Cohen's kappa [60] was calculated. Many studies

(5712) were divided between the first two researchers, and ensuring that both had the same understanding of the analysis was important. Fifty studies were randomly selected from the databases and analyzed by the researchers separately for the inclusion or exclusion of the study. The Cohen's Kappa was 0.9404, which means 95.8 percent agreement or almost perfect agreement. Both raters agreed that the process and understanding were aligned enough to proceed with an entire run.

3.2.2. Data extraction

First, a set of categories was prepared for the data extraction phase based on the research questions at hand. Then, two researchers filled the categories by reviewing each study. We tried to answer the RQs with the extracted data, and after two rounds of pilot extractions, we refined the categories. There was a discussion between the authors to reach an agreement on unclear assignments. The extraction categories, the representative RQ, and the coding styles are listed in Table 3. The “open” coding style was used for 10 out of 17 questions, while the “labeled” coding style was employed for the remaining seven questions. In the case of the “labeled” coding style, a predetermined set of possible labels was established before the data extraction phase. However, this list of labels was subject to evolution as new information was uncovered during the extraction process. Any alterations made to the labels necessitated the re-labeling of all previously coded studies. Moreover, to address some general findings regarding the research area, we extracted meta-data categories like “author(s)”, “affiliation(s)”, “venue” and “publication year”. All the information referred to is available either in the primary study or on the publisher's website.

To address RQ1, we extracted the reported challenges concerning the SIPS. The coding style for this category is open, and in the data analysis, we categorized those challenges.

To address RQ2, we extracted the “principles and practices” to better understand the implemented PP process. Moreover, we extracted the “principles and practices type”, the type of PP implemented to address the mentioned challenges. Six categories were predefined for PP types (Table 4). Inspired by the work of Offermann et al. [61], we developed our categorization of ‘Principles and Practices (PP) Types’ tailored to the context of our study. Although we drew inspiration from Offermann's artifact types, we decided to refine and adapt these categories to better align with our research's specific focus and scope. We used the term ‘methodology’ instead of ‘method’ to encapsulate a broader range of practices, including guidelines, e-learning programs, methods and techniques, processes, and general approaches. We believe ‘methodology’ is a more comprehensive term covering various workflows and overarching frameworks rather than just individual methods. We followed several steps: initially, we extracted the categories and statements of the authors from the primary studies, focusing on the proposed designs. The first two authors independently formulated their categories and interpretations based on the gathered information. The final step involved consolidating these categories into a unified taxonomy, which was then discussed and validated with a broader group of authors. Each sub-type within our categories was carefully considered to reflect specific aspects of the PPs. For example, ‘guidelines’ refer to sets of recommendations or instructions; ‘methods and techniques’ are the definition of activities on how to create or interact with a system; ‘processes’ and ‘general approaches’ denote systematic series of actions or overall strategies; ‘architecture’ within ‘pattern’ refers to the design and structure of systems; and ‘lexicon’ or ‘taxonomy’ within ‘model’ indicates a structured vocabulary or classification system.

Lastly, in the case of any automation, we extracted the “Automation” and “Automation Level”. For this purpose, we considered the definition and automation types described in Parasuraman et al. [63]. They have suggested four levels of automation in their research:

1. information acquisition: Automation in acquiring information applies to sensing and recording input data.

Table 3
Extraction categories.

RQ	Extraction category	Coding style
G	Author(s)	O
	Affiliation(s)	O
	Venue	O
	Publication Year	O
RQ1	Challenges to compliance	O
RQ2	Principles and Practices	O
	Process	
	Principles and Practices Type	L
	Automation Process	O
RQ3	Automation Level	L
	Involved Stakeholders	O
	Phase of Involvement	O
RQ4	PA	L
RQ5	Regulations Considered	O
	Field of Regulation	L
	Domain of Application	L
Q	Rigor	L
	Relevance	L

General Questions (G), Open (O), Labeled (L), Quality of Study (Q).

Table 4
PPs Types (inspired by Offermann et al. [61]).

PP type	Sub-types	Structure
Methodology	Guidelines, E-learning programs, Methods and Techniques, Processes and General Approaches	A systematic framework that defines and organizes a collection of methods and principles to guide the process of creating or interacting with a system
Metrics and Measurements	–	A mathematical model that supports measuring aspects of systems or methods
Model	Lexicon, Taxonomy	A structure, or behavior-related description of a system, commonly employing some formalism (e.g. UML) and possibly text, is a generally formalized system used to formulate statements representing parts of reality
Pattern	Architecture	Definition of reusable elements of design with its benefits and application context
Requirements	–	Description, Statement about System (A system or service of type X should have some property Y [because of Z])
Tool	–	A program or a set of programs, which is running on a computer that may be used to develop, modify, test, analyze, produce, or modify another program, its data, or its documentation [62]

- information analysis: Automation in information analysis incorporates cognitive functions, such as working memory and inferential processes.
- decision and action selection: The third stage, which involves decision and action selection, requires choosing from various alternatives. Automating this stage encompasses varying degrees of enhancing or substituting human decision-making with machine-based decision-making processes.
- action implementation: The last stage, action implementation, pertains to the actual execution of the chosen action. Automating this stage involves varying degrees of machine-based execution of the selected action, typically substituting human manual or vocal execution.

To address RQ3, we extracted “involved stakeholders” and “phase of involvement” to better understand if any experts were involved in the process of developing the PP, and if yes, at which phase.

To address RQ4, we extracted for which software development main process area (PA) the PP was developed. We used a predefined label for extraction:

- *RE (Requirements Engineering)*
 - REE (Elicitation)
 - REA/M (Analysis/Modeling)
 - RES (Specification)
 - REVV (Verification and Validation)
 - REM (Management)

- *SD (Design)*
- *SDev (Development)*
- *SQA (Quality Assurance)*
- *SDep (Deployment)*
- *SM (Maintenance)*

To address RQ5, we extracted which regulations were considered and investigated under the “regulations considered” extraction category. Additionally, “field of regulation” and “domain of application” were extracted. We applied the predefined lists of fields of regulation and domains of application formulated in the previous secondary studies [10,37]. After finishing the data extraction using these categories, we have refined and adapted the categories to the data that we have obtained. Next, we provide the final list of fields of regulation and domain of application with short explanations.

Field of Regulation: Accessibility, AI/ML (capturing any regulations applicable to AI/ML-based software systems), Business (capturing regulations applicable to both business processes and/or enterprise information systems across different industries), Privacy, Privacy&Security (identified in case same regulation considers both Privacy and Security simultaneously), Quality, Safety, Security, Traffic law, User rights (capturing regulations applicable to SIPS users only, e.g., human rights, patient rights).

Domain of Application: Automotive, Avionics, Cloud computing, E-commerce, Education, Energy (including nuclear energy, electricity distribution), Enterprise (capturing wide range industries (e.g., retail, food

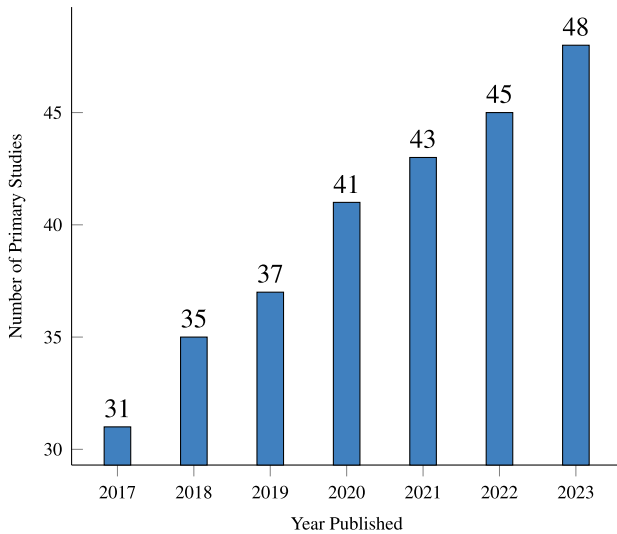


Fig. 2. Number of primary studies published per year.

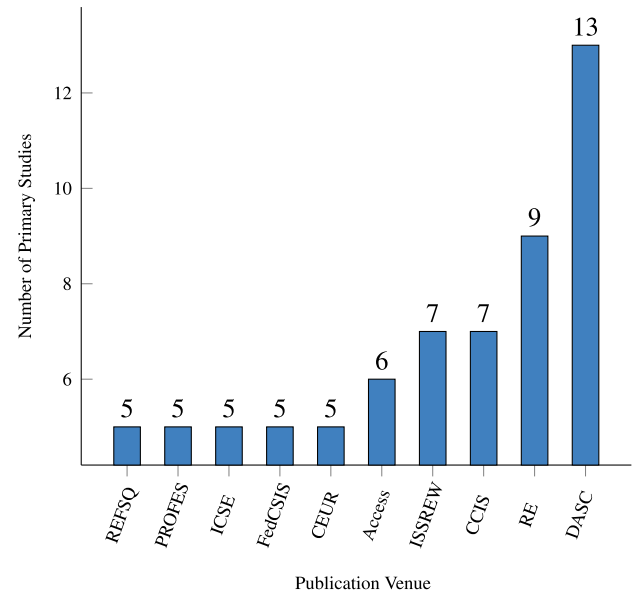


Fig. 3. Venues with the highest number of published studies.

industries) and activities characteristic or enterprises (e.g., marketing, taxation)), Finances, Government, Healthcare, IoT, Manufacturing, Media, Metrology, Military, Smart home/city, Software development (capturing primary study which focused on SIPS product and outsourcing companies, not belonging to specific industry), Telecommunications, Transport.

Finally, to evaluate the quality of the studies, we extracted “scientific rigor” and “industrial relevance”, which is a scoring system based on the work of Ivarsson and Gorschek [64]. We adopted the scoring of 0 (weak description) or 1 (medium and strong description) across the research question study design and validity for the scientific rigor. To evaluate the industrial relevance, we scored the sub-types: subject, context, scale, and research method.

3.2.3. Data analysis

We used the extracted data to address each research question during the data analysis phase. The data underwent a thorough cleaning and organizing process, and various figures and tables were generated to illustrate the findings. Descriptive statistics and frequency analysis were employed to analyze and summarize the data, leading to the presentation of various figure types, including bar charts, stacked bar charts, and maps (also known as categorical bubble plots). Additionally, the “challenges to compliance” open-coded category was examined, and its categorization was established in this phase. The first two authors carried out the data mapping task with active collaboration and consultation with the other authors.

4. Results and discussions

The following section presents the results and a discussion structured according to our research questions. We begin with an overview of general trends throughout the years, venues, and authors.

4.1. Trends throughout years, venues, and authors

The study selection process resulted in 280 relevant studies. Most selected studies were authored by researchers affiliated with academia 60.71% (170/280). A smaller part, 33 studies (11.78%), were from the authors affiliated with the industry, and 77 studies (27.5%) were conducted through collaborations between academia and industry. Fig. 2 presents the number of studies published over the years. In this research, we targeted the last seven years’ studies from 2017 (January

1) until 2023 (December 31). There has been a general increase in the number of studies over the years.

There are 181 unique venues where the primary studies were published. Fig. 3 shows the list of the top venues with the most published studies (five or more). The venues are Digital Avionics Systems Conference (DASC), Requirements Engineering Conference (RE), Communications in Computer and Information Science (CCIS), International Symposium on Software Reliability Engineering Workshops (ISSREW), IEEE Access journal (Access), CEUR Workshop Proceedings (CEUR), Federated Conference on Computer Science and Information Systems (FedCSIS), International Conference on Software Engineering (ICSE), Product Focused Software Process Improvement Conference (PROFES), and Requirements Engineering: Foundation for Software Quality Conference (REFSQ). They account for 23.92% (67/280) of all primary studies.

Finally, we also identified the top ten authors of the primary studies who are as follows Tommi Mikkonen (who is a co-author of 7 studies), Johnny Marques (6 studies), Fergal McCaffery (6 studies), Marko Esche (5 studies), Daniel Mendez (5 studies). Edna Dias Canedo (4 studies), Peng-Fei Gu (4 studies), Barbara Gallina (4 studies), John Mylopoulos (4 studies), Vlad Stirbu (4 studies). These authors authored 17.5% (49/280) of the 280 primary studies. Ivarsson and Gorschek [64] outlined a method for evaluating scientific rigor and industrial relevance using several criteria (see Table 3). Fig. 4 visualizes the rigor and relevance values extracted from the 280 primary studies. The three left bars of Fig. 4 show scores for the scientific “rigor” of the primary studies (0 or 1). Most of the studies (249) received a score of 1 for rigor-context, with only 31 primary studies receiving a score of 0. For rigor-study design, more than 55% (154/280) of the studies show an overall good quality. However, rigor-validity has almost 73.92% (207/280) 0’s, which means many studies did not report any threats to validity. The right four bars of Fig. 4 show scores for the industrial “relevance” of the primary studies (either 0 or 1). Overall, there is a low industrial involvement in the analyzed primary studies. Relevance-research methods and relevance-subject show the highest values, as represented by 42.85% (120/280) and 37.14% (104/280) studies evaluated as 1 for them. Relevance-context had 33.57% (94/280) 1’s over 0’s, and relevance-scale had the lowest overall score with 14.28% (40/280).

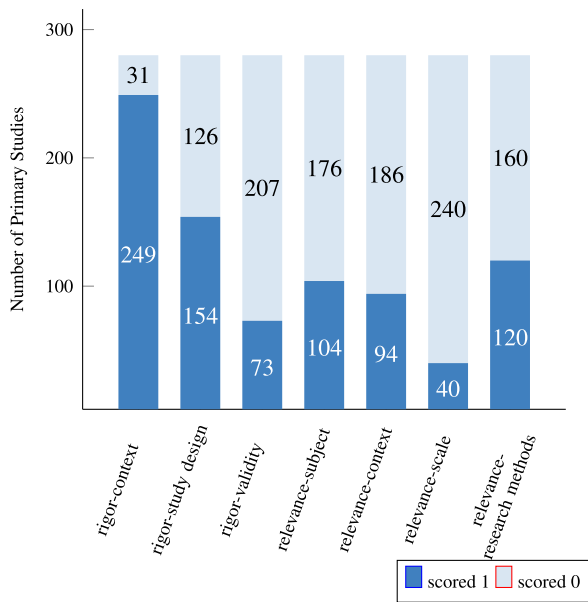


Fig. 4. Ratings of scientific rigor and industrial relevance for every study.

4.2. RQ1: What are the reported challenges in regulatory compliance of SIPS?

Highlights

- We identified 14 categories of challenges to regulatory compliance of SIPS.
- Most considered categories of challenges are abstractness, conflicts of regulatory demands with SE practices, and demand for domain knowledge.
- There is a need for studies on specific challenge categories and the relations between them.

The existing body of literature contains information about a wide range of challenges to SIPS regulatory compliance related to RE. 255 studies out of 280 (91.1%) mentioned at least one challenge to regulatory compliance. We observed that research of challenges has been increasing in recent years, however only some studies applied empirical methods to systematically research challenges or conduct in-depth research of concrete challenges (see Section 4.2.1 for details) and, as we have observed, the industrial relevance of the papers was low. Due to this, we have extracted any mention of challenges to regulatory compliance without introducing any additional qualifying criteria. Most of the analyzed primary studies mentioned challenges as motivation for their study or as a side result without elaborating on them in detail or providing a review of previous studies. Only some studies focused on challenges or explored them in detail. For example, Camilli et al. [65] described challenges in compliance assurance for collaborative AI systems, Peixoto et al. [66,67] explored how developers perceive and interpret privacy requirements, Canedo et al. [68,69] described the perceptions of ICT practitioners towards software privacy in the context of the Brazilian General Data Protection Law, Galvez & Gurses [70] have explored challenges to privacy threat modeling as required per GDPR in conditions of agile and service-oriented SE, and Li et al. [71,72] described practical challenges to GDPR compliance in the context of small companies and Andrade et al. [73] who explored how organizations integrate personal data privacy into their software development processes. The only study that approached challenges

to compliance specifically and systematically using empirical methods was Peixoto et al. [67] which mapped personal, behavioral, and external environment factors influencing the interpretation and perception of privacy. Li et al. [72] also reported multiple challenges identified in the course of their design study, but identified only three groups of challenges. Most studies contained recurring challenges such as the abstractness of regulations, compliance with multiple regulations, etc. To analyze the challenges, we have grouped related challenges into categories that we describe next. Table 5 contains the list of all the challenges, the number of primary studies that mention each category (each primary study can mention multiple challenges), examples of data about challenges extracted from studies for each category of challenges, and references to all primary studies mentioning challenges in each category.

4.2.1. Discussion RQ1: What are the reported challenges in regulatory compliance of SIPS?

To analyze the extracted data about challenges, we identified similar challenges to categorize them. Next, we calculated the number of studies mentioning a particular category of challenges (independently of the number of mentions of a particular challenge in that study). Many of the challenges were described as closely interconnected. For example, in Moyon et al. [238], one of the challenges is that “the SE field lacks methods to demonstrate compliance with security standards when applying DevOps”. In such cases, the challenge category was selected, taking into account the context of the extracted text. We identified 14 categories of challenges, which we explain next.

Abstractness of regulations (96/255 studies (37.6%)). The challenges in this category are related to preventing the immediate application of regulations as software requirements [98] and/or their translation into software requirements [84]. In particular, the primary studies described abstractness as related to (1) the language used in regulations and/or (2) the content of regulations. A broad range of terms was used to describe the language of regulations. For example, it was denoted as abstract [48,129], unclear [74,93], verbose, vague [48,137], ambiguous [48,72], abstruse [93]. There was a lack of terminological consistency in the description of these challenges. For example, primary studies could mention that regulations as a source of requirements are ambiguous and vague [48] without providing a clear distinction between the two. On the one hand, many primary studies recognized that abstractness is inherent and purposeful in covering multiple situations (e.g., [108,138]). On the other hand, many primary studies suggest that more concrete operationalizable norms are needed (e.g., [149,155]).

In terms of the content of regulations studies mention such challenges as provision of general principles only (e.g., [125,126]), absence of concrete procedures to be implemented (e.g., [76,144]), obscurity about the PPs to be applied (e.g., [122,158]), or system properties to be achieved (e.g., [114]). Another aspect of the abstractness of the content of regulations was that regulations cover different aspects and have different granularity. For example, regulations can address both high-level goals and low-level design constraints [140] and also tend to cover multiple compliance aspects in addition to technologies such as processes, people, strategy [116], industries or domains [140], governance and management [142], businesses and organization [161].

Existing studies also widely recognize that as the result of the abstractness of regulations their interpretation is required (e.g., [83]). Such interpretation poses a challenge itself because of the possibility of multiple and different interpretations [48,82]. This, increases the risk of non-compliance [72,87] and non-consistent interpretation in different cases [119,147]. It is also unclear for software engineers how to conduct such interpretation correctly [67]. Due to this, a gap between the intention of regulators and interpretation within the developing companies may emerge [136].

Table 5

References to all o the primary studies which considered categories of challenges.

Challenge category	# of studies	Example of a challenge	References to primary studies
Abstractness of regulations	96	“They find that the requirements of the standard are expressed at a high level.” [74]	[46,48,66–68,72,74–163]
Conflicts/changes to existing practices	84	“Certain DO-178C objectives make it difficult to reuse software previously developed out of DO-178C context.” [164]	[4,14,46,65,68–74,79,83,90,111,113,114,116,118,120,121,126,127,132,133,138,140,144,147,150,152,163–214]
Demand for domain knowledge	72	“SMEs can face the challenges with insufficient knowledge about regulations and standards” [74]	[4,66–70,72–74,76–78,81,83,84,86,87,89,93,96,106,110,118–121,124,125,127,129,130,133,134,139–141,143,147–149,151,156,157,161,166,193,194,197,198,206,208,215–235]
Absence of principles&practices	71	“Although previously introduced methods still lack efficient means for the representation of attacker motivation and have no prescribed way of constructing attack scenarios.” [236]	[4,48,67,70,72,73,78,79,90,96,103,112–114,117,118,121,122,127,136,139,140,148,149,151,152,155,156,158,161,175,197,199,200,203,205,207,211,222,227,228,233,234,236–263]
Complexity	69	“The resultant legal requirements models usually contain the complexities inherited from the original texts.” [169]	[46,48,68–72,74,82,84,85,96,104,109,118,121–124,127,128,139,142–145,147,148,151,152,156,161,169,175,194,196,201–203,206,212,218–221,226,227,229,253,257,259,262,264–280]
Interaction with experts	58	“Data Protection by Design is a truly interdisciplinary effort that involves many stakeholders such as legal experts, requirements engineers, software architects, developers, and system operators.” [281]	[4,67,69,70,72,73,80,86,96,109,112,120,125,127,130,131,133,136,137,139–141,143,144,147,149,151,157,158,161,162,165,175,186,193,196–198,202,224,227,229,231,235,238,251,258,259,273,274,278,279,281–286]
Resource intensity	58	“Implementing international standards and certification is expensive and time-consuming.” [74]	[4,48,71,72,74,80,86,88,93,95,96,100,101,103,104,112,114,122,126,128,137,142,147,148,151,152,164,166,202,206,212,213,216–218,225,230,231,247,259,264,266,271,272,274,280,283,286–296]
Provability	55	“The scale of the argument inevitably makes it difficult for regulators to comprehend them and to be confident that the evidence provided is of satisfactory quality.” [297]	[4,46,48,67,69,73,91,95,96,112,114,120,122,123,126,136,138,140,144,146–148,150,154–156,166,170,177,193,194,198,200,202–204,206,208,210,213,232,233,248,249,256,259,274,279,280,291,296–300]
Enforcement challenges	52	“Some respondents do not intend to use privacy practices even recognizing their importance.” [66]	[66,67,70–74,81,92,106,113,116–119,121,124,134,135,138,140,143,145,147,149,156,168,194,197,201,202,207,218,222,228,229,231,233,234,247–249,252,255,256,260,264,276,277,301–303]
Dynamics of software context	37	“Such systems often run in dynamic and uncertain environments that make it difficult providing strong assurances of compliance.” [65]	[4,65,68,69,72,80,83,84,87,91,96,106,121,123,126–128,130,140,141,145,148,150,152,161,194,212,224,229,241,254,273,277,292,304–306]
Multiplicity of regulations	35	“For some of the safety-critical domains, there is a need to implement more than one standard.” [74]	[72,74,75,77,82,83,87,111,130,140,143,146,147,149,150,152,161,168,199,204,215,216,229,254,277,278,284,288,295,302,307–311]
Dynamics of software systems	33	“This challenge is related to the continuous training of AI models in post-marketing settings.” [284]	[46,70,72,91,109,127,139,141,144,147,150,165,193–195,212,224,237,251,253,259,263,264,273,277–279,283,284,289,292,306,312]
Organizational challenges	29	“We found a lack of a privacy strategy and a lack of a privacy culture.” [67]	[4,67,69,71–73,118,120,125,127,128,131,136,138,139,141,143,151,156,196–198,200,229,231,233,259,277,313]
Regulatory gaps	26	“SOUP software requires special considerations, as the developers’ obligations related to design and implementation are not applied to it.” [274]	[4,46,116,127,131,132,135,140,144,146,149,150,154,193,196,198,199,207,248,251,252,254,274,277,306,314]

Conflicts or changes to existing SE practices caused by regulations (84/255 studies (32.9%)). We also identified a category of challenges related to the fact that regulations directly or indirectly conflict, with existing SE practices or necessitate changes to them. Some primary studies reported that regulations cause changes throughout the SDLC life cycle (e.g., [4, 206]). The most general challenges in this category are that regulations harm the SIPS development (e.g., constraints of data transfers [79], demand use of additional computational resources [176], slow down SIPS release [70], constraint the flexibility of SIPS design [70]). Another aspect is related to the fact that regulations introduce new requirements [83,169,187,192] (e.g., the demand for extended maintenance and quality assurance in operations [198]). Another challenge was related to the emergence of conflicts between regulatory requirements and other business and/or user requirements [14,138,181,199,201,205, 212], or difficulty in integrating regulatory requirements into format used for usual requirements (e.g., use stories [69]).

Primary studies also reported challenges with multiple software engineering practices which are as follows: (1) different aspects of agile development [46,70,73,74,116,118,163,165,167,170,172,175,182,

186,190,195,208,210,214], (2) DevOps, continuous delivery and maintenance [46,165,207,315], (3) regular updates [114,150], (4) software reuse [164,171,174,191,316], (5) rapid prototyping [164], (6) automation [65]. Studies often mentioned multiple aspects of such conflicts. Some of the examples of conflicts between regulatory compliance demands and agile software development are as follows: iterative and incremental development complicates risk analysis, focus on functionality neglects traceability, audits are impeded by dynamic changes of processes [167] or are absent at all in agile development [315], documentation required for compliance purposes can be missing [165], tracking of changes in requirements is challenging [170].

According to some studies, conflicts between SE practices and regulations can force companies to change their practice. For example, if it can be challenging to establish the suitability of existing SE methods (e.g., agile software development) to regulatory demands, companies may switch to more conservative development methods like Waterfall [74].

Demand for domain knowledge (72/255 studies (28.2%)). Challenges in this category were mainly related to the need for different types of

domain knowledge and expertise in regulatory RE and implementation of regulatory compliance of SIPS. We have identified five main types of domain knowledge and expertise that were mentioned in the studies which are as follows: (1) legal and/or compliance knowledge, (2) privacy knowledge, (3) security knowledge, (4) technical/software engineering knowledge, (5) application domain knowledge. Studies described a wide range of challenges related to legal and compliance knowledge. Some of these are as follows absence of awareness about regulations or regulatory norms (e.g., [66,67,96,197,225]), demand for the knowledge of “legalese jargon”(e.g., [4,87,216,221]), knowledge of the structure of legal documents (e.g., [221]), unwritten rules that might influence legal reasoning (e.g., the context of the legal scenario [48]), knowledge and experience in implementing regulations (e.g., [68,118]), systematic understanding of compliance across different development activities (e.g., [4]) or “in-depth knowledge of all legal consequences” of decisions [133]. Legal and compliance knowledge was mentioned as complementary technical/software engineering knowledge. Technical knowledge was mentioned as essential not only for technical roles to conduct their activities but also as important for legal experts (e.g., for conducting code reviews [147]), external reviewers (e.g., to verify compliance [148]), and regulatory bodies [149]. For example, [141] elaborated that regulatory demands largely depend on the characteristics of software, and its potential failures. Some examples of the technical knowledge mentioned in studies are as follows demanded for “low level knowledge about the system implementation” [70], knowledge of latest development technologies [118], technical knowledge required to feasibly react to potential changes [224].

Privacy and security knowledge were mentioned mainly in the context of compliance with privacy and security regulations. Challenges related to privacy knowledge included such challenges as insufficient knowledge of privacy [68,223], confusion between privacy and security [66,73], lack of experience [67,233]. While demand for security knowledge was mentioned in some studies [4,81,134,175,231] the challenges related to it were described on a very general level. The challenges of SIPS application domain knowledge were also considered important [119,124,125], especially in complex domains like healthcare [229] and finances [147].

According to the primary studies, demand for expertise and domain knowledge also creates challenges for developing PPs for regulatory compliance implementation [93]. A few studies mentioned that there is some form of a disconnectedness, or mismatch between the regulatory, engineering, and other perspectives involved in regulatory compliance implementation [48,76,78,84,86,130,175] with only limited understanding across the domains [80]. Many publications described it as a “semantic gap” i.e., the difference in meaning between two different representations describing the same object. This, for example, includes terms mismatch [110,218], the difference between policymakers and software engineers in understanding the concept of privacy [84], different approaches to risk assessment [86]. Last, but not least, some primary studies mentioned different challenges related to knowledge management such as structuring knowledge [194], sharing knowledge [72], and the importance of shared knowledge between software engineers and legal experts [130]. This highlights the connection of this category of challenges with the category of challenges concerned with the interaction between experts which we consider further.

Absence or insufficiency of principles and practices (PPs) (71/255 (27.8%)). A significant number of the primary studies highlighted the absence or insufficiency of PPs to conduct regulatory RE and implement SIPS compliance. Many primary studies highlighted the absence of appropriate PPs for implementation of regulatory compliance (e.g., [65, 79,102,103,317]), other studies emphasized the insufficiency and limitations of existing PPs to achieve regulatory compliance (e.g., [90, 175,237,239]) and in particular inefficiency [236], inflexibility [139], disconnectedness from the engineering practice [78], absence of the required details [70]), insufficient rigor [114].

One challenge that emerged especially in the recent studies was the absence of integrated or unified PPs (e.g., [151]), i.e. incorporating compliance throughout the development life cycle [4,112,113], embracing the different aspects of system quality [251], combining multiple PPs [253], addressing multiple regulatory demands [203,255].

Some primary studies identified the absence of internal guidelines and learning resources as a challenge [48,127,197]. Absence of the required automation or insufficient automation was also considered to be a challenge (e.g., absence of automation for handling data subject requests) [70,70,112,127,247,258,318]. Tool qualification was also mentioned in this context as, in many cases, it was unclear if a particular PP is eligible for achieving regulatory compliance [211,249].

Complexity of regulations processing and implementation (69/255 (27%)). Many studies describe different complexities emerging in the process of regulatory RE. Some of the aspects of this category of challenges are: (1) complexity of regulations, (2) complexity of software systems, and other different types of complexity-related challenges.

The complexity of regulations (e.g., [169]) arises from various challenges, such as multiple pre-conditions and exceptions [219], text length [152,220], a complex structure of regulations (incl. variety of multiple formats and notation elements that can be used in standards) [268], the complexity of regulations modeling [169] and resulting models consisting of multiple concepts and relationships [220], trade-offs and conflicts of compliance requirements [96,275,275], multiple regulatory concerns that need to be observed [72,118], management of compliance [72].

The complexity of software systems (e.g., large scale) is another aspect of complexity constraining regulatory RE and SIPS compliance. In particular, it is mentioned in the context of AI/ML systems [144, 147,201,274,279], cloud systems [253], and IoT systems [109,151]. Some studies mention that implementation of regulatory compliance is especially challenging in legacy systems [72,145,212,226,276,278] and in the context of the growth of the complexity of the software supply chain [143,147,156,259,265,280].

Error-proneness emerging due to complexity is another aspect of complexity we included in this category of challenges [48,68,72,104, 221,264,266]. Some studies mention the complexity of regulations along with resource intensity, which is often caused by such complexity. We elaborate on this challenge of resource intensity further.

We have added to this category all the challenges that mention complexity, error-proneness, or related challenges that are not connected directly to a need for legal knowledge or expertise. Challenges in this category are also relevant in the case of the availability of domain knowledge and expert human resources. Legal knowledge can help to address the complex structure of regulations, but it does not nullify the existence of regulations’ complexity as a challenge.

Interaction between experts (58/255 studies (22.8%)). We also identified a category of challenges related to interaction between the different experts involved in implementing regulatory compliance. According to the primary studies, some regulatory demands like privacy by design are interdisciplinary in their nature [281], and stakeholder interaction is required for their implementation [165,238]. This includes interdisciplinary interaction between different domains of expertise (e.g., legal experts, software engineers and system operators in [281], security and software engineering in [282]) and intradisciplinary interaction of different engineering roles (e.g., developers and verification team in [96], designers and manufacturers in [196]). Primary studies in this category mention some of the following aspects of the interaction experts usually conduct their activities in isolation [281], different perspectives (e.g., more holistic by security experts and more dispersed by software engineers [175]), differences in the terms and concepts applied [151,224], the absence of understanding of the benefits of interactions [227], conflicting suggestions and conclusions [72], cultural differences [140].

According to the primary studies, the motivation for interaction between experts includes the demand to explore different aspects of compliance holistically [193,251] (such as technical, legal, application aspects), need to handle requirements at both development team and organizational levels [69], assuring the transparency for external audits [120], addressing the complexity of business environment [139], achieving shared responsibility [120], balancing technical and legal objectives [136,140], or enabling some activities that are impossible without such an interaction (e.g., data protection impact assessment [227]). Some studies also emphasized the importance of collective shared understanding as a part of interaction [72,136,139].

It is noteworthy that interaction with domain experts or users was especially highlighted in the context of regulatory compliance of AI/ML-based systems as such an interaction plays an essential role in quality assurance ([198,229,283]).

Resource intensity of processing and implementation of regulations (58/255 studies (22.8%)). The primary studies describe the implementation of regulatory compliance as expensive [72,147,164,166,217], time-consuming [74,148,164,259,289] and laborious [93,114,216,247,264]. In a few studies, the problem of resource intensity is mentioned, especially for small and medium enterprises [74,80]. Primarily, resource intensity is related to the need to process regulations [48,216], conduct audits manually [264], extra software development efforts [164], expensiveness of access to legal knowledge and expertise, need to hire additional human resources [80], need to provide documentation to achieve compliance [103] or resources required to collect annotated data for the development of automation tools [104]. Another challenge is that these resources should be spent in a way that would maximize return on investment [217].

Provability challenges (55/255 studies (21.6%)). Challenges in this category are mainly related to the development and provision of proofs and/or documentation of compliance overall [170] or in a particular process area (e.g., DevOps [238]). This is an important aspect of SIPS compliance as without appropriate evidence regulators can assume non-compliance [4]. Among other challenges were provability challenges related to complexity and scale of compliance evidence [297] (which connects provability challenges to the aforementioned challenge of complexity), documentation for 3rd party components [46], multiplicity of sources of evidence and data collection [91,112] and trustworthiness of evidence [91]. Among the properties of the evidence that are challenging to achieve the following were discussed completeness [91,95], appropriate granularity [194], sufficiency [114], evidence maintenance [136]. Another challenge related to provability is traceability (e.g., [96,114,122,123,154,208]) as in some cases full traceability is required to demonstrate compliance [170]. One provability challenge emerging only in a couple of recent primary studies is the need to monitor and evidence continuously compliance [193,274].

Enforcement challenges (52/255 studies (20.4%)). This category of challenges includes different heterogeneous challenges related to the enforcement of regulatory compliance, i.e. making sure that regulations are implemented as expected. Even with regulations clearly specifying the required PPs and with such PPs at hand, companies and SIPS development teams can struggle to implement regulatory compliance of SIPS (e.g., because of the need to integrate and consolidate PPs [74]). First of all, such challenges mention de facto intentional non-compliance, for example, when engineers ignore or do not intend to apply compliance practices [66,222]. Another aspect of this category is the implementation of compliance only in a formal way (e.g., approaching compliance with a “tick box” approach without the consideration of SIPS compliance effectiveness [147,149]) or in a way undermining compliance usability or usefulness (e.g., by limiting other functionality in the context of execution of data subject rights [156,247]).

In some cases, enforcement challenges are related to impossibility or special challenges in implementing compliance of SIPS (e.g., because

of the impossibility of fully implementing requirements in software code [145,201]), demand to additionally rely on human subjects to enforce or verify compliance (e.g., [72,256]). Another challenge identified in the primary studies was the enforcement of regulatory compliance in systems behavior (e.g., data processing is GDPR compliant) [92,228]. In particular, enforcement mechanisms can require extensive monitoring [70], or other additional mechanisms [255], which are “new, rare, or not well understood” [138]. Moreover, such compliance enforcement can require appropriate “regulatory infrastructure” [70,149]. It is noteworthy that while the lack of enforcement is usually seen as problematic, “compliance over-engineering” [118] is also seen as a challenge to address.

Dynamics of software context and regulations (37/255 studies (14.5 %)). This category of challenges covers the challenges related to the changes in regulations and other aspects of software context. One of the most significant challenges in this category is change of regulations [80,83,126,130,152,273] or their interpretation [224]. Some changes (e.g., the concept of privacy) can be linked to the changes in social norms, cultural context, and technology rather than with explicit changes [127,148]. Li et al. [72] claim that such dynamics of regulations not only mean that SIPS engineers need to be ready to react to changes but also prepare for the upcoming regulations.

Another aspect of the dynamics of software context is the dynamic and uncertain environment of software systems. This creates challenges to completely specifying software functionality [304] and providing strong compliance assurance [65]. The challenge of the dynamic and uncertain environment is especially prominent for AI/ML-based systems. Primary studies mentioned that AI/ML-based systems often can show lower accuracy and efficiency when applied in real-world conditions [229], while it is challenging to account for software context during software testing.

Multiplicity of regulations (35/255 studies (13.7%)). The primary studies name a number of challenges emerging in connection to multiplicity of regulations that need to be processed and implemented concurrently. Multiple regulations can be applicable simultaneously due to diverse jurisdictions in which compliance is required [77,83,215], the multiplicity of sources in a particular field of law (e.g., court cases [72,87]), multiplicity of regulators in a particular field of regulations [83], or multiple levels of regulation (e.g., federal, state, and local levels in the USA [87]). Some of the challenges that emerge in connection to such multiplicity are conflicts, overlaps, and differences between regulations that need to be resolved [83,149,216,278,284,302,307], demand to possess knowledge specific to each regulation [74], preparation to the audit of compliance to multiple regulations [307], duplication of compliance processes and efforts [74,216].

Dynamics of software systems (33/255 studies (12.9%)). Another source of challenges to regulatory RE is dynamics and changes in software systems and software engineering artifacts. Primary studies recognize that overall changes in SIPS can have implications for regulatory compliance [193].

Some of the challenges in this category are related to the application of machine learning and artificial intelligence SIPS components and their evolution over time [65,150,277,279,284], changes in the code [264], or changes in the SIPS architecture [70] that can also result in a risk of non-compliance [265]. Run-time changes in software systems represent another distinct challenge that needs to be addressed [253]. Continuous changes in software systems make it difficult to track and have an up-to-date regulatory compliance status of the SIPS [72,273]. Changes can also result in the emergence of privacy threats and hence engineers need to be able to understand such new emergent privacy threats [139].

Organizational challenges (29/255 (11.4%). This category covers the challenges related to the way regulatory RE and implementation of SIPS compliance are organized. Nearly all primary studies in this category support the claim that the organizational environment affects the implementation of SIPS compliance [69,127]. Primary studies emphasize that SIPS compliance requires a number of organizational aspects which are often omitted. These are, for example, holistic organizational commitment [4], compliance planning [138], and nurturing the required strategy and culture [67,231].

The most prominent aspect in this category is related to the responsibility for SIPS compliance. This includes such challenges as engineers do not consider that they are responsible for compliance implementation [67,73,197,233], it is unclear who is responsible for regulatory compliance [120,143], there is no clear approach to sharing responsibility with other roles or partner organizations [72,141,200,229,277], there is lack of investments [127,233]. Other challenges in this category are, for example, as follows organizations or SIPS development teams do not prioritize compliance because of prioritization of functional requirements [197], compliance is considered as a necessary evil with little practical relevance [118], or as not a mandatory concern [67], or not a business concern [67]. Last but not least, a non-systematic approach to regulatory compliance is mentioned as a challenge in a few studies [67,136], including the absence and/or insufficiency of discussions of regulatory compliance within SIPS teams and/or organization [67,128].

Regulatory gaps (26/255 studies (10.2%). Some primary studies pointed to the regulatory gaps, i.e. absence of regulations applicable to SIPS. Such challenges contrast to abstractness challenges which point to the absence of concreteness of existing regulations. Some of the examples of challenges in this category are as follows absence of any regulations [254], absence of regulations for new technologies such as AI/ML-based systems [135,198,251,314], absence of regulations specifically targeting SIPS, but rather non-SIPS systems [46,193], demand for special consideration of some types of SIPS (e.g., software of unknown provenance [274]), demand for more consistent and coordinated regulation [252]. Also, one study mentioned that better involvement of regulators as stakeholders could be beneficial, but challenging [199].

Summary. As we observed from the studies, many categories of challenges are closely related and our study has pointed to at least some of such relationships (e.g., challenges in developing PPs and demand for domain knowledge are caused by the absence of knowledge and expertise in domains involved in regulatory RE, domain knowledge related to the challenge of interaction between experts, complexity challenge leading to resource intensity, complexity as creating some of the provability challenges). However, we have not found any primary studies addressing such interrelationships. This emphasizes the importance of further systematic empirical research of challenges both for research and practical purposes.

Many of our findings align with earlier studies reporting regulatory compliance challenges. Next, we highlight some of such studies. The challenge of the conflicts between regulations and existing SE practices or the introduction of additional demands on them (like—explicit and structured conformance arguments) was, for example, identified by Graydon et al. [319]. Kempe & Massey [3], in their secondary study, also identified general characteristics of regulations (e.g., ambiguity) as one of the top discussed challenges.

On the basis of the results of some of the empirical studies that we have identified, we can assume that challenges from different categories emerge simultaneously in practice. For example, Li et al. [72] mentioned challenges belonging to 12 out of 14 challenge categories we have identified, and Peixoto et al. [67] identified challenges belonging to 7 categories of challenges.

The major part of the research on challenges in the primary studies stays fragmented as studies often do not explore the essence of challenges and their interconnections. Only some studies have explored such challenges systematically but did not focus on them in detail (e.g., [70,71,104,217]). Some studies reported challenges without the application of empirical methods (e.g., [65,70,217]). Only a few studies have rigorously identified multiple challenges with the application of empirical methods (e.g., [67,72]). However, the number of studies with high rigor and relevance that tried to investigate challenges with empirical methods (e.g., [66,68]) stays relatively low. Up to date, existing studies have not resulted in a systematic overview of challenges. Further empirical evidence could be required to understand better such challenges as resource intensity and conflicts or changes caused by regulatory demands in SE practices. Kempe&Massey [3], in their secondary study, also expressed an opinion that technical implementation of regulatory compliance is related to the costs of development for the system as a whole. Nevertheless, in their systematic literature review, they did not identify any concrete quantitative assessments. We also found only scarce studies assessing the resources required to implement regulatory compliance of SIPS (e.g., [164]). Studies exploring the impact of regulations on SE practices often do not employ a systematic approach that could be applied to other regulations or types of practices.

In our opinion, the absence of systematicity in the research of challenges potentially impacts the overall state of research on the topics of regulatory compliance of SIPS and regulatory RE. For example, early studies on the topic of regulatory compliance (that are outside of the scope of this study) suggested that regulations are often developed to be abstract intentionally [2] and suggested approaches to address unintended ambiguity [320]. Our results confirm that abstractness remains a top challenge to regulatory compliance of SIPS until now.

4.2.2. Primary studies in other disciplines

Our selected primary studies also include studies belonging to the disciplines other than software engineering and computer science such as law [141,143,144,248,277], compliance and regulation [147], medicine [131,135,193,198,200,229,252,300,314,321], risk regulation and management [132,145]. In one case the authors of one of the studies had a technical background, but the study was published in the legal venue [141]. Despite belonging to other disciplines these studies covered SIPS compliance and regulatory RE challenges in a way relevant to our study. For example, consider the integration of regulatory affairs professionals in software life cycle [193], post-market surveillance of software as a medical device [314]. Challenges described in such studies fit into our existing categories of challenges. But often these challenges were described from a different perspective (e.g., legal studies considered the consequences of “hardcoding” compliance controls into SIPS and not updating them, such studies also approached regulatory compliance more “holistically” i.e. independently of particular SIPS lifecycle process areas). Medical studies emphasized a number of challenges specific to the use of AI/ML-based SIPS which is related to the SIPS maintenance process areas. Overall, challenges in the SIPS maintenance process area were under-considered in other primary studies. We consider that studies from other disciplines can contribute to regulatory RE and SIPS compliance and are important to consider. However, we suggest that a number of methodological issues should be addressed in the future to effectively review such studies and conduct interdisciplinary research on regulatory RE (e.g., studies in law have a different structure, different disciplines operate on different levels of abstraction, understanding of the expected results and contributions value vary in different disciplines, each discipline approach academic rigor differently, etc.).

4.3. RQ2: What is needed to address the challenges to the regulatory compliance of SIPS and what are the PPs used for that?

Highlights

- We have identified and categorized the principles and practices (six categories) used in the research to address different types of challenges of regulatory compliance of SIPS.
- Many of the PPs addressed multiple challenges.
- There is a lack of tool support for addressing the identified challenges.
- Automation was utilized in 26.42% of the primary studies to address challenges, with the most frequent application of automation seen in “Conflicts/changes to existing practices” and “Complexity” challenges.

The second research question aims to identify principles and practices (PPs) used to address the mentioned challenges and achieve SIPS regulatory compliance. As mentioned in Section 3.2.2, we used the categorization we have developed (see Table 4) to classify and analyze challenges. Table 6 shows the full list of six different types of PP and examples taken from the primary studies. Some studies did not develop any solution or PP but rather only identified challenges or envisioned development and/or application of PPs in the future. Since they are primarily suggestions rather than actual implemented approaches, we did not include them in the analysis for RQ2, as only implemented PPs addressing challenges were considered. For example, one study [66] investigates the personal factors affecting the developers’ understanding of privacy requirements during the vacancy period of a data protection law. Moreover, 23 studies suggested more than one type of PP. For example, one study [74] presented *requirements* and *methodology* as their solution types to address challenges. As a result, the total number of uniquely mentioned PPs in the studies is 249. The most popular type of PP was *methodology* with 69.47% (173/249). Creating *tools* with 11.24% (28/249) and developing *models* with 9.23% (23/249) were the next most popular PP types for addressing the challenges. *Patterns* 6.02% (15/249) and *requirements* 3.61% (9/249) were among the least popular PP types. One study proposed *metrics* and *measurements*. Full details are available in our published dataset.

The PP types are not mutually exclusive, and we found that 50.2% (125/249) of the primary studies address multiple challenges with their suggested PP. For example, one study [237] developed a tool for tackling the “Absence of PPs” and “Dynamics of software systems” challenges. Hence, the total number of times a PP addresses different challenges is 624.

The bubble plot in Fig. 5 shows the interplay of types of PP and the addressed challenge category. The X and Y axes have categorical values, producing a grid-like visualization. Another dimension, visualized as the size of each bubble, is the number of times when the intersection of the X and Y axes applies. For example, there are 52 times that a “methodology” was mentioned for addressing the “conflicts/changes to existing practices” challenge.

We investigated to what degree the mentioned PPs are utilizing automation to address the challenges to the regulatory compliance of SIPS. Overall, 26.42% (74/280) of the primary studies used some form of automation. With the proposed automation, several studies attempted to tackle multiple challenges. Consequently, automation was recommended to address challenges 88 times. The top two categories of challenges that were addressed by automation are “Conflicts/changes to existing practices” 18.18% (16/88) and “Complexity” 14.77% (13/88). “Resource intensity” and “Absence of PPs”, each with 13.63% (12/88) and 11.36% (10/88), and “Enforcement challenges” and “Abstractness”, with 10.22% (9/88) and 7.95% (7/88), are the next category of challenges that utilized automation.

For example, Joshi et al. [216] developed a comprehensive and semantically intricate knowledge graph encompassing a range of data compliance regulations. The knowledge graph is publicly available and can be used by enterprises to automate compliance workflows and formulate security protocols for their cloud-based operations. Zeni et al. [324] designed a semi-automated web-based system called GaiusT that automates the semantic annotation of legal documents.

Additionally, as mentioned in Section 3.2.2, we classified the level of PP automation based on the categories suggested by Parasuraman et al. [63]. We found that 44.59% (33/74) of automation is at the *information analysis* level, followed by 25.67% (19/74) PPs that have automation at both *information acquisition* and *information analysis* levels. Nine PPs include automation at *information analysis* and *decision* and *action selection* while having only *information acquisition* is 6.75% (5/74). The combination of *information acquisition*, *information analysis*, *decision* and *action selection*, and *action implementation* and only *decision* and *action selection* are each 4% (3/74). Finally, two studies utilized automation at *information acquisition*, *information analysis*, and *decision* and *action selection* level.

4.3.1. Discussion RQ2: What is needed to address the challenges to the regulatory compliance of SIPS and what are the PPs used for that?

For some challenges like “Domain knowledge and expert human resources”, there are different types of PP (e.g., models, tools, methodologies). Also, ten different tools exist to address this challenge. The problem space is not well analyzed, and the next step should involve a comparative evaluation of these PPs, examining the specific benefits and drawbacks of each approach in addressing the same challenge. This analysis would provide clearer guidance on which PP might be most effective in various contexts, aiding both researchers and practitioners in making informed decisions.

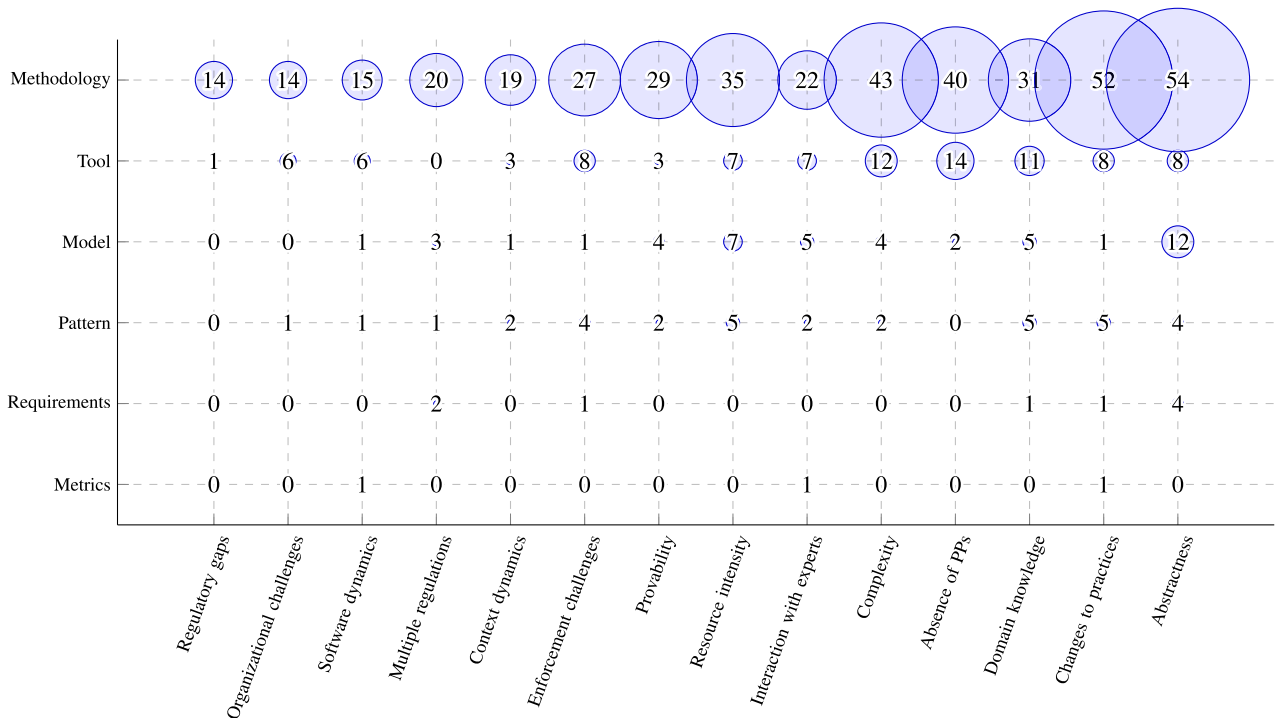
Moreover, looking at the results in Fig. 4, the number of studies in the “relevance-scale dimension” had a very low score, with 14.28% (40/280). This suggests that the mentioned PPs were evaluated predominantly using applications of unrealistic size (e.g., toy examples). This has two major implications. One, the basis for the developed/suggested PP might not be well anchored in cases in the industry, and two, and more importantly, the “solution” in the form of the PP was not tested out in a scalable and realistic manner. To bridge this gap, future research should focus on industry collaboration, where realistic examples and datasets are utilized to test the PPs. This approach would not only serve as a more rigorous test but also enhance industry confidence in adopting these PPs as viable solutions. Moreover, co-developing PPs with industry partners could lead to more practical and immediately applicable solutions. Additionally, future research could focus on developing standardized frameworks or methodologies for evaluating PPs, ensuring that they are tested under comparable conditions, especially in terms of scalability and real-world applicability.

Finally, some categories of challenges are more widely covered by PPs. Looking at Fig. 5, “Abstractness” were addressed by a PP in 13.14% (82/624) and “conflicts/changes to existing practices” in 10.89% (68/624). However, challenges like “organizational challenges” 3.36% (21/624) and “regulatory gaps” 2.4% (15/624) are underrepresented by addressing PPs. Our analysis revealed a frequent lack of a clear linkage between the challenges identified in studies and the corresponding recommended PPs (for instance, studies that proposed various challenges did not explicitly state whether their suggested PP aims to address all the mentioned challenges or not). Future research should focus on establishing these linkages more explicitly, ensuring that proposed PPs are evaluated against all relevant challenges. Lastly, as regulations evolve, so too must the PPs that support compliance. Future research could focus on developing adaptive PPs that can evolve in response to changes in regulations, ensuring continuous compliance without requiring extensive reworks. This would provide organizations with more flexible tools that can easily adapt to new regulatory requirements, reducing the cost and complexity of maintaining compliance.

Table 6

Six different types of PP with exemplary text from a primary study.

Type of PP	# of unique PPs	Exemplary Raw Text
Methodology	173	A semi-automatic methodology that assesses the security requirements of software systems concerning completeness and ambiguity, creating a bridge between the requirements documents and complying with standards. [266] A method to achieve Continuous Security Compliance by extending an agile process model to allow secure development and verifiable compliance with a standard. [167] A guideline summarized the references from the regulatory guide, codes, and standards that recommend the verification and validation methods that should be completed. [322] A 6-step systematic approach (GuideMe) that supports the elicitation of solution requirements that link GDPR data protection obligations with the privacy controls that fulfill these obligations. [48]
Metrics and Measurements	1	Two metrics are proposed that can best measure the performance of each attribute, and an assessment of either agile tools, agile methods, or DevOps is provided as being best positioned to satisfy the regulated environment attributes of communications applications. [165]
Model	23	Adopting the APDL model as a requirements model that can be expressed as a common language understood by those concerned with privacy and data protection and those responsible for developing and maintaining privacy-aware systems. [84]
Pattern	15	The definition of atomic expressions, as a prerequisite for creating the formal rules, can be considered a step towards a better interpretation of the standards requirements. [75] The pattern system guides software developers so that they can help users understand how their information system uses personal data. [323] An architectural viewpoint for describing software architectures from a legal data protection perspective whose core modeling abstractions are based on an in-depth legal analysis of the EU General Data Protection Regulation. [281]
Requirements	9	Set of generic requirement-driven elements that can be applied to similar IoT-based architectures. [77]
Tool	28	The automated system, named HPDROID, bridges the semantic gap between the general rules of GDPR and the app implementations by identifying the data practices declared in the app privacy policy and the data-relevant behaviors in the app code. [76]

**Fig. 5.** Types of challenges mapped against the type of PPs.

4.4. RQ3: Which stakeholders were involved in the development of PPs for regulatory compliance of sips?

Highlights

- Primary studies considered five stakeholders' categories: software engineers, legal experts, other experts, researchers, and other stakeholders.
- 13.6% of primary studies considered the involvement of both software engineering and legal experts.
- The number of studies considering the involvement of stakeholders in the validation of principles and practices is relatively low.
- The role of each category of stakeholders and the involvement of "other stakeholders" (e.g., suppliers, users) requires further research.

124/280 studies (44.3%) considered the need for the involvement of one or more stakeholders in the development, application, and/or validation of suggested principles or practices. We extracted data about any mention of a need to involve certain stakeholders. The way in which the involvement of stakeholders was considered varied. In some cases, stakeholders were involved along with study authors; in other cases, their involvement was mentioned without any details, or their involvement was envisioned as future work. For the purposes of answering this research question, we also counted the involvement in research activities, i.e., involvement of a role in research counts as participation in a PP development. We analyzed the data extracted from 124 primary studies mentioning the involvement of stakeholders and identified five main categories of stakeholders. As every study could consider the involvement of a few categories of stakeholders, we calculated the number of unique studies mentioning the involvement of each category of stakeholders one or more times. 90/124 (72.6%) of studies considered the involvement of some SE roles (like developers, architects, requirements analysts, and/or product owners). 55/124 (44.4%) studies considered the involvement of legal or compliance experts (compliance officers, personal data protection officers, regulators, and/or certification authorities). We also included privacy and personal data protection experts in this category as these roles are mainly related to compliance duties and mainly emerged after the enactment of GDPR. Noteworthy is that in some studies, regulators (e.g., certification authorities) were also involved in the development, application, and/or validation of PPs or corresponding research [95,297,305]. 28/124 (22.6%) studies considered the involvement of experts other than legal or compliance experts. Primarily, studies indicated the involvement of security and safety experts/engineers. In this context, it is important to mention that we assume that security and safety experts can also possess the knowledge and expertise required for compliance. Other experts involved were human factors specialists, process engineers, usability experts. 12/124 (9.7%) studies considered the involvement of researchers. These were mainly computer science or SE researchers, but also researchers in linguistics and law were involved. In 39/124 (31.5%) studies, authors considered the involvement of other stakeholders. Primarily, these were stakeholders external to the organization, such as suppliers, service providers, users, and data owners. In some cases also, internal stakeholders such as product management and sponsors were mentioned. Among the 124 studies, 68 papers (54.8%) mentioned the involvement of more than one category of stakeholders.

While extracting data from the primary studies, we have also observed that the involvement of stakeholders is usually considered for a particular phase of the PPs life cycle, such as the development, application, and validation of PP. To account for this difference, We also collected data about the involvement of stakeholders in any of

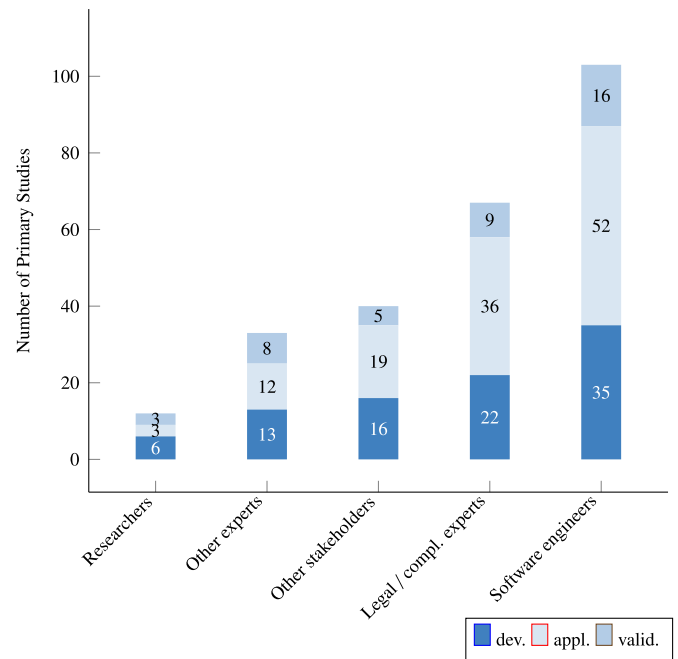


Fig. 6. Number of studies considering the involvement of stakeholders in principle or practice (1) development, (2) application, (3) validation. Note: each stakeholder can be involved in any of the three principle or practice life cycle stages simultaneously. The categories are sorted from the least mentioned on the left to the most mentioned on the right.

these phases. Based on the information about stakeholder involvement reported in the paper, we assigned one of the three categories of PPs for each stakeholder considered in the paper. Fig. 6 illustrates the involvement of a particular category of stakeholders in a particular phase of the principles or practice life cycle. Some studies suggested the need for the involvement of the same category of stakeholders in different stages of the PP life cycle. However, the number of such studies was insignificant nine primary studies out of 124 (8.1%). Three primary studies [175,213,264] suggested that involvement of stakeholders is required simultaneously to application and validation of PPs, one study [318] suggested that involvement is required to PP development and application, and four studies [151,155,223,325] suggested to involve stakeholders in development and validation of PPs. Only two studies [151,221] mentioned that the involvement of the same category of stakeholders is required for all three stages of the PP life cycle. This study also mentioned the involvement of multiple stakeholder categories: SE roles (in particular requirements analysts), legal experts (lawyers), other experts (domain experts), and researchers (researchers on linguistics).

4.4.1. Discussion RQ3: Which stakeholders were involved in the development of PPs for regulatory compliance of SIPS?

Our findings go in hand with the previous study by Mubarkoot et al. [30] that identified that among all the primary studies they identified various stakeholders including legal experts, domain experts, and some external stakeholders. Nevertheless, their results show that domain experts, legal experts, and safety engineers were the least considered stakeholders. Our findings are similar to the secondary study of Akhigbe et al. [10], who found that concerns of regulators as stakeholders are also considered in about 12% of studies. Earlier primary studies that are out of the scope of this study also pointed to the need to involve legal experts (e.g., [326]) or describe regulatory compliance implementation as an interdisciplinary activity (e.g., [327]). Still, the number of studies that pointed to the involvement of both legal experts and software engineers in the PP life cycle stays relatively

low, with 38 out of all 280 studies (13.6%). The involvement of other experts and stakeholders on par with legal experts was an important discovery. The involvement of other experts (e.g., domain, security experts) was mentioned in some of the earlier primary studies known to the authors of this study (e.g., [326]) but did not receive significant attention. The involvement of other stakeholders, such as users and suppliers, seems to be relevant, taking into account that regulations can impact their interests. Still, to the best knowledge of the authors, this aspect of the implementation of regulatory compliance of SIPS was not explored in-depth in any previous studies. Future research could better explore the roles of stakeholders involved. For example, Ayala-Rivera&Pasquale [48] envisioned the involvement of stakeholders belonging to all five groups of stakeholders that we have identified (IT professionals, data privacy experts, legal experts, governance, data processors) but did not provide any details about the role of all of the stakeholders. According to the number of primary studies that have considered the involvement of researchers, we can assume that interdisciplinary research stays relatively limited (primary studies considered the involvement of researchers belonging to disciplines other than the discipline of the primary study). The primary studies mainly indicated that stakeholders need to be involved in PP application. Less attention was paid to the involvement of stakeholders in the development of PPs. Furthermore, the involvement of all types of stakeholders in the validation of PPs was the least considered. For a deeper analysis of stakeholder involvement, we conducted a mapping between the data on stakeholder involvement and (1) RE-related challenges to compliance (described in Section 4.2), (2) PPs for regulatory compliance of SIPS (described in Section 4.3), (3) fields of regulation (described in Section 4.6).

From the mapping of categories of challenges against categories of involved stakeholders, shown in Fig. 7, we can observe the categories of challenges in which stakeholders may need to be involved. Three categories of stakeholders (software engineers, legal experts, other experts, and other stakeholders) were primarily involved in studies that mentioned the following challenges: abstractness of regulations, domain knowledge and expert human resources, absence of PPs, interaction between experts, conflicts with existing practices, and resource intensity. Legal experts only were mainly involved in studies considering the abstractness of regulations, interaction with experts, domain knowledge, and conflicts with SE practices. It is noteworthy that both SE roles and legal experts were considered for involvement almost equally in studies considering the following challenges: dynamics of software context (SE roles: 15 and legal experts: 11), regulations' multiplicity (SE roles: 9 and legal experts: 8), dynamics of SIPS systems (SE roles: 10 and legal experts 9). The involvement of other types of experts was mentioned in studies reporting domain knowledge, conflicts with software engineering PPs, interaction with experts, and provability. The involvement of other stakeholders was also noted in publications reporting the challenges of abstractness, conflicts with SE PPs, domain knowledge, and interaction with experts. Studies reported that all categories of stakeholders should be involved in connection to such challenges as abstractness, absence of PPs, changes to SE practices, interaction with experts, and complexity. It is also noteworthy that despite the challenges of regulations' multiplicity, dynamics of systems, organizational challenges, and regulatory gaps are among the least considered in the primary studies, these studies relatively often mention the involvement of SE roles, legal experts, other experts, and other stakeholders. Last but not least, the role of experts other than legal and compliance experts seems to be important in addressing domain knowledge-related challenges to compliance of SIPS. Overall, we see that all categories of stakeholders except for researchers and other experts were considered for involvement across all categories of challenges. Still, there are some differences between the involvement of stakeholders in studies mentioning different categories of challenges.

Fig. 8 maps the involvement of stakeholders concerning the fields of regulation that studies reported. SE roles, legal experts, and other stakeholders were most often mentioned in studies focusing on privacy and

quality. Other experts were most often considered in studies focusing on security and quality as fields of regulation. We also observed that SE roles, legal experts, other stakeholders and other experts were considered for involvement in seven fields of regulation (Privacy, Quality, Safety, Security, AI/ML, Privacy&Security, and Business). Researchers were most often considered for involvement in studies considering privacy.

Fig. 9 maps the involvement of stakeholders concerning the category of PPs considered in primary studies. We observed that the involvement of software engineers and legal experts is considered for almost all PPs. The involvement of other experts and other stakeholders was considered for developing methodologies, tools, models and patterns, but not requirements. The only study that considered the development of metrics and measurements did not consider the involvement of any stakeholders.

4.5. RQ4: What are the main software processes areas (PAs) involved in enabling the regulatory compliance of sips?

Highlights

- Primary studies reported RE-related challenges to regulatory compliance of SIPS throughout almost all process areas of the SDLC.
- Requirements engineering as a standalone process area was considered in 74/254 studies (29.1%). In 58/254 studies (22.8%) primary studies RE was considered in intersection with other process areas mainly SQA (19 studies) and SD (17 studies).

We identified a particular process area for 254 out of 280 studies (90.7%). We identified PAs based on the PA explicitly mentioned in the paper. In case the paper did not mention concrete PA, we followed definitions of PAs provided in Section 2.1.1 to identify the corresponding PA. Studies could mention a few PAs simultaneously. For example, the category "RE & SQA" includes studies that considered contributions to both of these PAs simultaneously. A detailed breakdown of studies according to the PAs they considered can be found in . Studies have contributed to different PAs with a major focus on RE (74/254 (29.1%)), SDLC (51/254 (20%)), SQA (20/254 (7.9%)), SD (17/254 (6.7%)), SDev (16/254 (6.3%)), and SM (2/254 (0.8%)). The whole SDLC was mainly addressed in the context of application of particular development methods (e.g., agile [164,165,189,204,328], Unified Software Development Process [121]), implementation of compliance controls throughout the SDLC (e.g., traceability [118]), systematic integration of Legal/compliance or other experts into SDLC (e.g., [193, 198]), the implementation of model-based SE or application of formal methods [267,268,317,329], or implementation of assessment methods. Also, consideration of the whole SDLC was characteristic for many research studies as they usually were not focusing on a particular SDLC process area (e.g., [127]).

We decided to additionally analyze the studies that considered RE (both as a standalone process area (74 studies) and in conjunction with other SDLC process areas (58 studies)) (see for general trends).

Four standalone RE processes most considered in the primary studies are Analysis/Modeling (33 studies), RE in general (30 studies), Elicitation (18 studies), and Validation and Verification (10 studies). Requirements Specification was considered in 6 studies and no primary study focused on Requirements Management as a standalone RE process. In the general RE category we have aggregated both primary studies that have considered all RE processes (mainly in the context of integration into software development methods (e.g., agile [125, 186,187])), considered RE on a general level, and primary studies for which it was not possible to identify concrete RE processes. In many cases it was hard to identify concrete RE process as studies

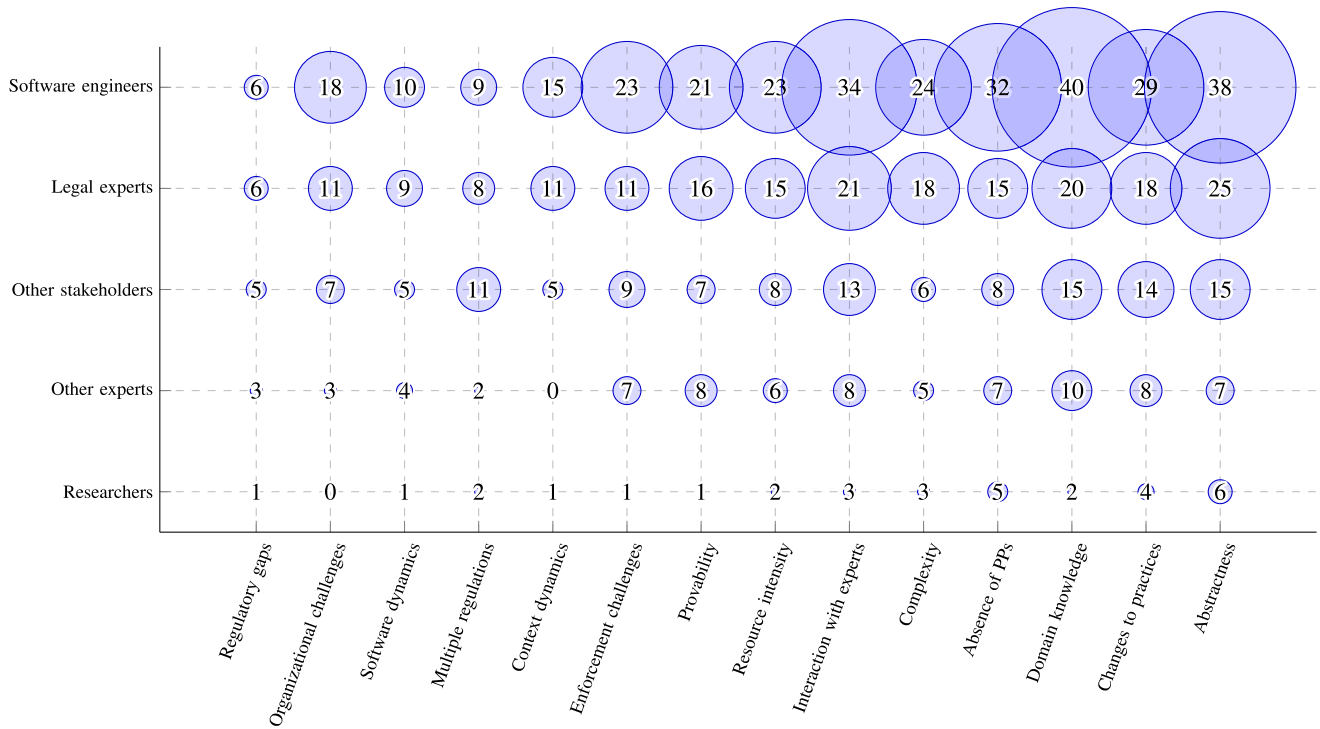


Fig. 7. Categories of challenges that were mentioned in the papers (from least mentioned on the left to the most mentioned on the right except for “No challenges”) mapped against categories of stakeholders involved (from the least mentioned on the bottom to the most mentioned on the top).



Fig. 8. Fields of regulation that were addressed in the papers mapped against categories of stakeholders involved.

simply provided a list of requirements derived in an unclear, ad hoc way and/or derived on the basis of the authors' experience [72,330–332]. For example, [330] have provided a list of requirements or “technical safeguards” which was then applied for evaluating open source applications. Herewith, the authors have not explained how they derived these requirements, nor they have suggested any other principle or practice for RE specifically. It is noteworthy that among the categories involving two or more RE processes simultaneously only the Elicitation and Analysis/Modeling category was considered in multiple studies (19 studies), while all the other categories were considered in five or fewer primary studies.

4.5.1. Discussion RQ4: What are the main software processes areas (PAs) involved in enabling the regulatory compliance of SIPS?

Our finding that RE is the main process area contributing to regulatory compliance is consistent with the findings in some of the previous studies [3]. Our results diverge from the results of Negri-Ribalta et al. [29] as in their study focusing on General Data Protection Regulation (GDPR) authors found out that the Requirements Elicitation process was addressed in 47 studies, Specification in 35 papers, and Verification in 33 studies. This difference could emerge because the authors have not defined Analysis/Modeling as a separate RE process and used only five processes in their secondary study (namely

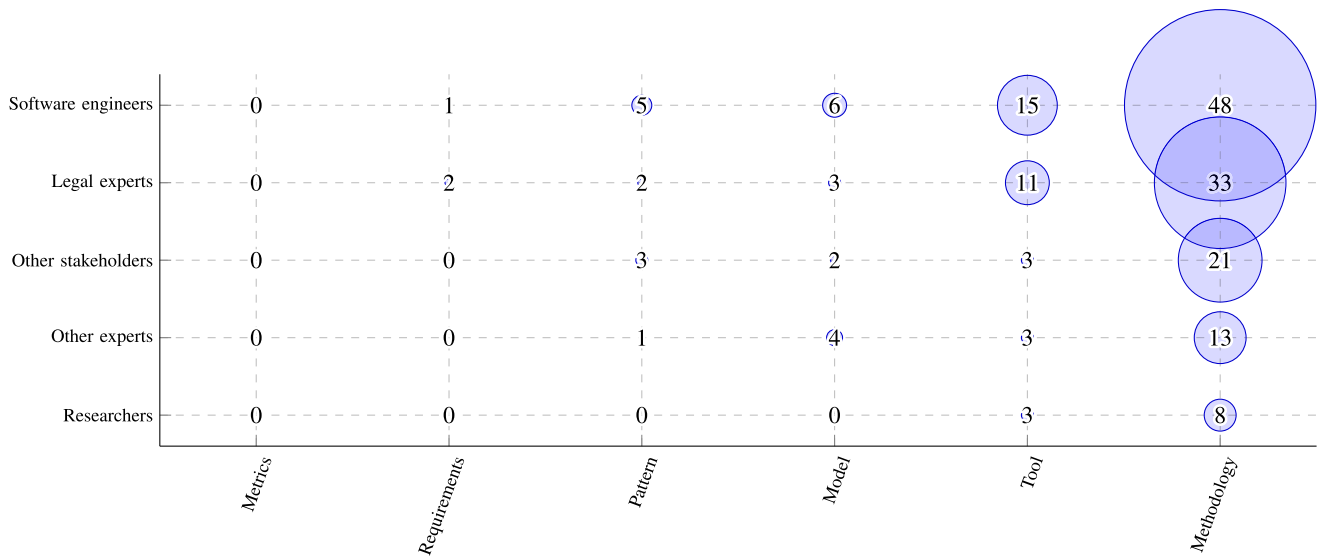


Fig. 9. Principles and practices suggested in studies mapped against categories of stakeholders involved.

Table 7

(1) Number of primary studies contributing to particular process area of software development life cycle (mutually exclusive). Process areas are as follows: RE—Requirements Engineering, SD—Design, SDev—Development, SQA—Quality Assurance, SDep—deployment, SM—Maintenance, SDLC—whole life cycle.

(2) Number of primary studies considering particular RE (including studies focusing on RE only or RE in conjunction with other process areas). RE processes are as follows: REE—Elicitation, REA/M—Analysis/Modeling, RES—Specification, REVV—Verification&Validation, REM—Management.

Process area(s)	Primary studies	Process area(s)	Primary studies
RE*	74	REA/M	33
SDLC	51	RE	30
SQA	20	REE & REA/M	19
RE* & SQA	19	REE	18
SD	17	REVV	10
RE* & SD	17	RES	6
SDev	16	REA/M & REVV	5
SQA & SM	5	REA/M & RES	3
RE* & SD & SDev	4	REA/M & RES & REVV & REM	2
RE* & SD & SQA	4	REE & RES	2
RE* & SDev	3	REE & REA/M & RES	2
RE* & SDep	3	REE & REVV	1
SD & SDev	3	REE & REA/M & RES & REVV	1
RE* & SM	2		
RE* & SD & SQA & SM	2		
SDev & SDep	2		
SM	2		
RE* & SD & SDep	1		
RE* & SDev & SDep	1		
RE* & SDev & SM	1		
RE* & SQA & SM	1		

Elicitation, Specification, Verification and Validation, Management, Documentation).

SM received insignificant attention in primary studies despite maintaining compliance due to changes in regulations is recognized to be challenging. Also, integrating software into an existing IT landscape of organizations can be another aspect requiring attention in the future. As our results show SIPS deployment (which includes DevOps) was considered in only some primary studies, but we can expect an increase of this number in the near future. Some studies considered mainly SQA or SD process in conjunction with RE activities. The number of such studies considering SQA and SD in conjunction with RE activities was almost equal to the number of primary studies considering SQA or SD without RE contribution. It is noteworthy that only a few studies considered SDev in conjunction with RE [81,238]. In the primary studies considering the RE and SD phases in conjunction, RE was used to support regulatory compliance in SD in multiple ways. For example, through the identification of architecture components [77] and design principles [333]. In the primary studies considering both RE and SQA in conjunction, RE was used to support SQA mainly by

identifying requirements that need QA (e.g., in [330]). The contribution of the RE process area to other process areas in the context of regulatory compliance was somewhat addressed in [265] on the example of contribution to SQA. This study stated that developing SQA methods starts with extracting requirements and their modeling. In [172], a tighter connection between RE and SDev was also described as essential for regulatory-compliant development. This is in line with some of the previous studies that suggested that process areas beyond RE can have specific needs that should be addressed by the RE process area [3]. For example, SQA can require guidance on the nature of the required evidence, their sufficiency, and procedures for evidence auditing [27]. Some primary studies suggested that regulatory compliance implementation should involve the interaction of different SE roles (e.g., requirements engineers, software architects, developers in [334]). Nevertheless, no details about such interaction were described. None of the studies considered the implementation of regulatory compliance throughout the SDLC in a way that would cover a contribution required in each of the process areas. We see an increasing trend towards consideration of multiple SDLC process areas in interaction. Still, the

number of such studies stays relatively low. As mentioned before, some studies provided the requirements that they used without any information about the RE methods they applied [333] and some reused requirements or RE methods from other studies [176,238]. Further research could focus on better disentangling the contribution of RE to implementing compliance in other process areas.

The number of primary studies considering two or more RE processes in conjunction stays relatively low (35 studies) and only some primary studies that considered the whole RE processes have considered RE processes in interaction. A better understanding of all the RE processes in their interconnection could be another direction for future work.

4.6. RQ5: Which regulations and domains of application are the most considered in regulatory compliance of SIPS?

Highlights

- Most primary studies focused only on a few of the most considered domains of application, fields of regulation, and regulations.
- Only some of the studies considered regulatory compliance in the context of more than one field of regulation or more than one regulation.
- Our results suggest there are differences between different fields of regulation in terms of the challenges.
- Some of the regulations (e.g., HIPAA) stay in the focus of researchers despite they were enacted or revised a relatively long time ago.
- There is a significant range of regulations (including recently enacted regulations). However, only some were considered in more than 5 studies.

4.6.1. Domain of application

As mentioned in Section 3.2.2, we have a predefined list of 20 “domain of application”. The initial list of domains of application was based on domains of application used in previous secondary studies [10,37]. However, after applying the predefined list of domains we refined it to better accommodate the results and derived the final list with 19 categories. We identified the domain of application according to the domain that was a focus of the primary study or domain for which the application of a particular principle or practice was envisioned. Here, it is important to mention that applying suggested PPs may not be limited to only the reported domain. Table 8 shows the number of primary studies considering the application domains. Of the 280 identified primary studies, 232 addressed an application domain. Healthcare domain was considered in 71 studies (30.6%), Software development in 40 studies (17.2%), Avionics in 38 studies (16.4%), Automotive domain was mentioned in 17 studies (7.3%), Cloud computing in 16 studies (6.9%), Finances in 14 studies (6%), Manufacturing domain in 12 studies (5.2%), and other application domains were mentioned in less than 10 studies (please see Table 8 for further details).

Our results suggest that overall research is skewed towards a couple of domains of application, such as healthcare, software development and avionics, as these three domains of application constitute 53.2% (149 out of 280). Noteworthy is that only 26 studies have considered the application of two or more domains of application. While some primary studies we have mapped mentioned that their results are generalizable to other domains, they have not provided further details. Only 27 primary studies have considered two or more domains of applications simultaneously. We suggest that further research on regulatory RE and SIPS compliance beyond the established domains can

be of value to the community. Also, it would be beneficial to look into the applicability/replicability of the study results and/or PPs across different domains.

4.6.2. Fields of regulation

For 268/280 (95.7%) studies, we have identified the field of regulation (Table 9). Some primary studies mentioned a particular field of regulation, but have not mentioned a concrete regulation it was addressing. The most considered regulation field was Privacy, with 101/268 (37.7%), whereas 68/268 (25.3%) studies focused on Quality. We have categorized 63/268 studies (23.4%) studies as considering software Safety. We introduced this category to capture studies concerned with the overall SIPS development processes and multiple properties of systems demanded by regulations. Many studies in this category are related to implementing medical device regulations (such as the EU Medical Device Regulation (EU MDR)) and metrological regulations (e.g., Measuring Instruments Directive). These studies are concerned with multiple aspects of software systems simultaneously (Quality, Security) and software development processes. Some other regulations addressed in the studies belonging to this category were ISO 62304 (software life cycle processes of medical devices), ISO 13485 (Medical devices quality management systems), and ISO 14971 (application of risk management for medical devices). Security was considered in 35/268 (13%) studies. In some cases, two fields of regulation were considered simultaneously. We also introduced a separate category for studies considering AI and ML systems compliance because as of now (2024) such regulations address multiple AI/ML-related concerns simultaneously. etc. We have identified 21/268 (7.8%) studies belonging to this category. Privacy&Security field of regulation was considered in 18/268 primary studies (6.7%), Business related regulations were addressed in 7/268 studies (2.6%), User rights field of regulation in 4/268 primary studies (1.5%), Accessibility in 3/268 (1.1%), and Traffic law in 2/268 primary studies (0.7%).

4.6.3. Regulations

260 out of 280 studies have mentioned at least one regulation in the context of their research. We summarize the regulations considered in the studies in Table 10 together with additional information important for the discussion. In some cases primary studies described a wide range of different regulations from the same regulator, such as US National Institute of Standards and Technology (NIST) standards (mentioned in 11 studies) and US Food and Drug Administration (FDA) regulations (mentioned in seven studies). Some of the regulations mentioned in less than five primary studies were as follows Virginia Consumer Data Protection Act (US CDPA) [138,295], Children’s Online Privacy Protection Rule (US COPPA) [140,156], EU Cybersecurity Act [255, 259], the EU In Vitro Diagnostics Regulation (EU IVDR) [200,207], US Health Information Technology for Economic and Clinical Health Act (US HITECH) [109,335] US executive order 13960 [211], US executive order 14028 [255], EU Markets in Financial Instruments Directive 2014/65/EU (EU MiFID II) [147], US Sarbanes–Oxley Act (US SOX) [216]. Some other rarely considered regulations were Chinese Cybersecurity Law [77], US Federal Risk and Authorization Management Program (FedRAMP) [264], US Federal Information Security Management Act of 2002 (US FISMA) [216]. While the majority of the studies mentioned the demand to be compliant with two or more regulations simultaneously, only some explicitly addressed this demand with corresponding PPs. For example, Joshi et al. [216] have considered multiple regulations (such as EU GDPR, US HIPAA, US FISMA, ISO 27001, ISO 27002 along with other non-regulatory types of sources of requirements like OAuth, COBIT), but only within the RE process area. Strielkina et al. [109] suggested a hierarchical cybersecurity model for healthcare IoT systems encompassing relationships between different regulations and tool support for the corresponding decision-making. Anish et al. [272] used multiple regulations to extract penalty clauses and train their ML model for automated identification and deconstruction of penalty clauses.

Table 8
Number of primary studies addressing domains of application.

Domain of application	Number of studies
Healthcare	71
Software development	40
Avionics	38
Automotive	17
Cloud computing	16
Finances	14
Manufacturing	12
IoT	9
Education	8
Enterprise	7
Metrology	7
Transport	7
Energy	6
Government	6
Media	4
E-commerce	3
Military	3
Telecommunications	3
Smart home/city	2

Table 9
Number of primary studies addressing fields of regulations.

Field of regulation	Number of studies
Privacy	101
Quality	68
Safety	63
Security	35
AI/ML	21
Privacy&Security	18
Business	7
User rights	4
Accessibility	3
Traffic law	2

4.6.4. Discussion RQ5: Which regulations and domains of application are the most considered in regulatory compliance of SIPS?

There is an evident skew towards certain domains of application, fields of regulation, and regulations. The three most considered domains of application, Healthcare (71 primary studies), and Software development (40 primary studies), and Avionics (38 studies) make up 53.2% of all (280) primary studies. Fields of regulation of Privacy (101 primary studies) and Quality (68 primary studies) cover 60.4% of all primary studies. The two most considered regulations, EU GDPR (79 primary studies) and DO-178C/330/331/332 avionics standards (34 primary studies), were considered in 40.4% primary studies.

We have mapped fields of regulations and challenges (each study can contain more than one challenge) in Fig. 10. We excluded three fields of regulation (Accessibility, User rights, and Business) from the visualization as they reported only a few challenges. Studies focusing on Accessibility mentioned the following challenges, enforcement challenges (two primary studies) and conflicts with existing principles and practices. Primary studies focusing on the User rights field of regulations mentioned the following challenges enforcement challenges (one primary study), Regulatory gaps (one primary study), Complexity-related challenges (one primary study), and absence of principles and practices (one primary study). Studies considering the business field of regulation considered the challenges of multiplicity of regulations (one primary study), resource intensity (two primary studies), absence of PPs (one primary study), and abstractness of regulations (one primary study).

Some challenges are more considered in some fields of regulation. For example, challenges of domain knowledge, abstractness, absence of PPs, and changes to software engineering practices are most prominent in the field of privacy. Simultaneously, in the field of safety,

challenges related to changes to SE practices, abstractness, provability, complexity and absence of PPs are most considered. In the field of regulation of quality the most considered challenges were changes to SE practices, abstractness, provability, and regulatory gaps. AI/ML stands out in comparison to other fields of regulation with regulatory gaps, interaction with experts, multiplicity of regulations, and enforcement as the top-mentioned challenges. This can result from differences in the maturity of research in different fields of regulation or related to basic differences between different fields of regulation. Unexpectedly, we found that the abstractness of regulations was mentioned as a challenge in such fields as safety and quality, in which regulations usually take place through technical standards. Overall, for many fields of regulation, one of the 14 categories of challenges is mentioned at least twice.

It is noteworthy that many of the regulations considered in studies have been in force for a long time. The US Health Insurance Portability and Accountability Act (US HIPAA) was enacted in 1996 and last changed in 2013. Nevertheless, it stays among the most considered regulations even now. Many of the principles of the EU GDPR were based on the European Data Protection Directive [336] enacted back in 1995. Still, GDPR, enacted based on the European Data Protection Directive, is the most considered regulation. Only some studies considered compliance to a few regulations from different fields of regulation simultaneously (for example, compliance with privacy and safety regulations). This finding is in tune with the findings of the secondary study by Ardila et al. [8], which also found that in almost all studies, regulations are addressed in isolation, reducing the possibility of generalizing the results. Further research in particular fields of regulation is especially important, considering that multiple regulations are focused on the intersection between different fields of regulation

Table 10
Number of primary studies considering regulations and additional information about each regulation.

Regulation	Field of regulation	Number of studies	Date of enactment	In force since	Date of last changes
GDPR (1) DO-178C; (2) DO-330; (3) DO-331; (4) DO-332	Privacy Safety	79/260 (30.4%) 34/260 (13%)	27/04/2016 (1, 2, 3, 4): 13/12/2011	25/05/2018 (1,2,3,4): 13/12/2011	23/05/2018 (1):05/01/2012 (2):16/02/2021 (3):16/02/2021 (4): -
HIPAA	Privacy/security	18/260 6.9%	21/08/1996	14/04/2003, 14/04/2005, 14/04/2006	26/04/2024
(1) EU MDR, (2) EU MDD	Quality	16/260 (6.1%)	(1) 05/04/2017, (2) 14/06/1993	(1) 25/05/2021(2024), (2) 01/07/1994	(1) 20/03/2023
ISO 26262	Safety	14/260 (5.4%)	11/11/2011	11/11/2011	17/12/2018
ISO 62304	Quality	14/260 (5.4%)	17/05/2006	17/05/2006	01/11/2017
ISO 13485	Quality	9/260 (3.5%)	01/03/2016	01/03/2016	01/03/2016
LGPD	Privacy	9/260 (3.5%)	18/09/2020	01/08/2021	25/10/2022
(1) AI HLEG Guidel.; (2) EU AI Act	AI/ML	8/260 (3.1%)	(1)08/04/2019; (2)21/04/2021	(1)08/04/2019; (2)01/08/2024	-
ISO 14971	Quality	7/122 (2.7%)	01/10/1998	01/10/1998	10/12/2019
IEC 62443	Security	7/260 (2.6%)	2002	-	2023
(1)ISO 27000, (2) ISO 27001; (3) ISO 27002; (4) ISO 27005	Security	4/260 (1.5%)	(2):12/10/2005; (3):15/06/2005; (4):04/06/2008	-	(2):25/10/2022; (3):12/02/2022; (4):25/10/2022
IEC 61508	Safety	6/260 (2.3%)	2000	2010	
IEC 50128	Safety	5/260 (1.9%)	11/2001	11/2001	03/2012
EU MID	Quality	5/260 (2.5%)	31/03/2004	30/10/2006	27/01/2015

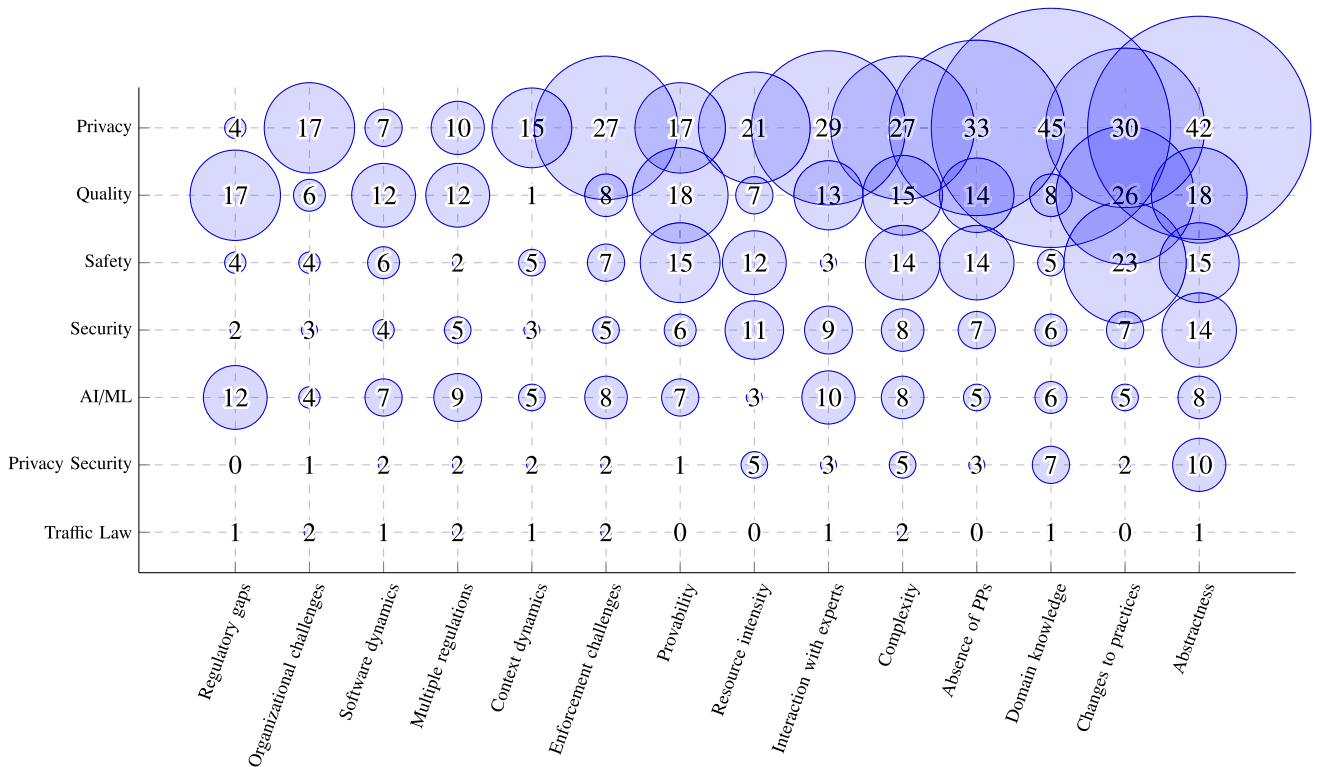


Fig. 10. Challenges to regulatory RE and compliance of SIPS and mapped against fields of regulation. Note: Fields of regulation Accessibility, User Rights, and Business have mentioned only a few challenges and thus were excluded from this mapping (See text for the details).

(e.g., privacy and security). The understanding of privacy and security from regulatory and SE perspectives can differ, which demands addressing the gap between the two perspectives. Future research could focus on in-depth research of challenges, principles, and practices in the context of different regulation fields or on the intersection between regulation fields.

5. Threats to validity

We took inspiration from Montgomery et al. [337] in structuring the threats to validity section of our SMS.

5.1. Internal validity

We placed significant emphasis on ensuring the reliability of our research outcomes. To achieve this, we closely adhered to the research plan guidelines proposed by Kitchenham et al. [41] and Petersen et al. [338]. Each step of our study was meticulously documented and followed according to the structured process outlined in Section 3.2. To enhance research reliability further, we conducted inter-rater reliability tests, including measuring Cohen's kappa, among the researchers involved in study selection, quality assessment, and data extraction. These measures aimed to maintain consistency in decision-making and reduce the potential for subjective biases. Throughout the study selection phase, the two first authors actively discussed any uncertainties regarding inclusion. In the event of disagreements, the default decision was to include the study, thus mitigating the risk of false negatives. The structure of this SMS adheres to the guidelines outlined in established literature for conducting an SMS within SE research. Our approach meticulously aligns with these recommendations.

5.2. External validity

The validity of our study may be influenced by the extent of coverage within the search results and potential biases in the selection of studies. It is plausible that certain pertinent studies may not have been included due to incomplete search strings or the omission of certain databases. To attain comprehensive evidence, our literature review search terms were deliberately broad. Our research was meticulously designed to unearth challenges related to the regulatory compliance of software systems without confining itself to specific regulations. It is plausible that our search parameters did not encompass studies narrowly focused on executing a singular regulation, omitting keywords like "law" or "regulation". Alternatively, studies might employ other terms, such as "privacy" and "personal data protection", or even reference specific regulations like GDPR or HIPAA instead of the more general keywords we employed. Researcher biases could potentially influence the assessment of studies. To counteract this possibility, a predefined set of inclusion and exclusion criteria was employed to guide the assessment process. We also incorporated studies that did not explicitly propose PP but still undertook relevant research, as these sources often contained valuable insights into prevailing challenges. As we have considered the application of different keywords and wildcards across different databases, we conducted a trial selection from a subset of the search results to evaluate the relevance of the chosen keywords for our study. Given the focus of this study — regulatory RE as a process area contributing to regulatory compliance across the SIPS life cycle — we assert that a keyword-based search offers the most systematic approach for selecting relevant studies. However, relying solely on keyword searches can introduce potential validity threats. To mitigate these risks, we reviewed the search results to identify key studies familiar to the authors, ensuring their inclusion. Additionally, we compared the outcomes of different trial searches to verify whether they encompassed these known studies and whether any new, significant primary studies emerged. The authors also discussed the breadth of coverage offered by the various trial searches. Finally, we evaluated and considered the methods and findings of related previous secondary studies.

5.3. Construct validity

The principal challenge to construct validity lies within the phase of data extraction. Before commencing the comprehensive extraction process, the authors reached an agreement, and each researcher engaged in this task performed a preliminary extraction run. This preliminary run aimed to harmonize their comprehension of the extraction inquiries. Consequently, adjustments were made to the names, explanations of extraction questions, coding methodologies, and extraction procedures to synchronize with the researchers' interpretations. Furthermore, low-confidence instances were identified and discussed between the first two authors until a consensus was reached.

6. Conclusions and further research directions

Implementation of regulatory compliance of SIPS remains an open and multifaceted goal for SE research and practice. This study contributes to disentangling regulatory compliance of SIPS by providing an overview of state of the art and identifying the most significant aspects of regulatory compliance of SIPS and regulatory RE.

Difficulties in implementing regulatory compliance of SIPS can be related to the 14 categories of challenges we have identified in the primary studies. Taking into account the number and interconnectedness of such challenges, further empirical research on particular challenges is required to create a sufficient understanding of the principles and practices that are required to address them. This is essential as studies often do not clearly connect the challenges they identified and the principles and practices they suggested and/or evaluated in relation to such challenges. A better understanding of challenges could also contribute to developing tools and automation. For now, tools as a suggested principle and practice are significantly outnumbered by methodology as the most widespread type of principles and practice. Further research on principles and practices is also essential, as our results suggest that most existing principles and practices were not validated with sufficient rigor and, in many cases, had relatively low relevance for SE practice.

The involvement of categories of stakeholders other than software engineers in the development, application, and validation of PPs is an important finding for further SE research and practice. Our findings suggest that there may be different needs in terms of the involvement of stakeholders in different fields of regulation and in addressing different categories of challenges. Herewith, interdisciplinary research can contribute to a better analysis of such different needs.

Our results also show that regulatory compliance with SIPS may require a more systematic consideration throughout the SDLC. In particular, primary studies considered not only RE but also software design, quality assurance, etc. Many studies considered RE in conjunction with other process areas (e.g., conjunction of RE and SQA) which suggests that implementation of effective relationships between requirements engineering and other process areas is essential for the achievement of SIPS regulatory compliance.

Current research focuses mainly on the 2–3 most popular domains of application (healthcare, software development, avionics), fields of regulation (privacy, quality), and regulations (GDPR, DO-178/330 standards, HIPAA). This does not allow us to better explore and account for the difference between different regulations and domains of application. Our results suggest differences in challenges to compliance with SIPS among different regulation fields. Moreover, research on implementing requirements from some regulations stays popular even after such regulations were enacted or changed.

Future research on regulatory compliance of SIPS will need to take into account many of the aspects that we have identified, which can be summarized as follows:

- the multiple categories of challenges to regulatory compliance of SIPS, which are interconnected;
- the interdependence of process areas in the implementation of compliance;

Table 11
Contributions.

	Conceptualization	Study design	Data collection	Data analysis*	Original draft*	Reviewing&Editing	Supervision
O. Kosenkov*							
P. Elahidoost*							
T. Gorschek							
J. Fischbach							
D. Mendez							
M. Unterkalmsteiner							
D. Fucci							
R. Mohanani							

	Introduction	Fundamentals	Related work	Study design	Results: General Trends	Results: RQ 1	Results: RQ 2	Results: RQ 3& RQ4	Results: RQ 5	Threats to validity	Conclusions
O. Kosenkov											
P. Elahidoost											

- role of requirements engineering in the implementation of regulatory compliance in subsequent process areas;
- the need for appropriate involvement of legal experts and, where necessary, domain experts;
- potential specificity of challenges across different fields of regulations (e.g., privacy, safety);
- the interdisciplinary nature of the topic of regulatory compliance of SIPS.

We suggest that regulatory requirements engineering practice for regulatory compliance of SIPS should better account for challenges, focus on more rigorous validation of principles and practices and involvement of the relevant groups of stakeholders of such principles and practices. Furthermore, differences in terms of SDLC process areas, regulations, and domains of application need to be considered.

Overall, requirements engineering for regulatory compliance of SIPS requires a more profound approach to more systematically ensure that there is a clear understanding of the challenges that need to be addressed and that developed principles and practices are relevant for the achievement of the final goal of ensuring regulatory compliance of software-intensive products and services.

CRediT authorship contribution statement

Oleksandr Kosenkov: Writing – original draft, Visualization, Methodology, Investigation, Data curation, Conceptualization. **Parisa Elahidoost:** Writing – original draft, Visualization, Methodology, Investigation, Data curation, Conceptualization. **Tony Gorschek:** Writing – review & editing, Supervision, Methodology. **Jannik Fischbach:** Writing – review & editing, Supervision. **Daniel Mendez:** Writing – review & editing, Supervision. **Michael Unterkalmsteiner:** Writing – review & editing, Supervision. **Davide Fucci:** Writing – review & editing, Supervision. **Rahul Mohanani:** Writing – review & editing, Methodology.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Appendix A

Tables of contributions generated with CTAB⁸ (see Table 11).

Appendix B. Supplementary data

Supplementary material related to this article can be found online at <https://doi.org/10.1016/j.infsof.2024.107622>.

Data availability

We publish our dataset of the data extracted from the 280 primary studies. We have identified for this study (available on Zenodo <https://zenodo.org/records/13999201> (DOI: 10.5281/zenodo.13999201) or on the website <https://regulatory-re.com/sms>).

References

[1] D. Hays, Shaping the future of tech industry regulation 5 steps to take now, 2019.

[2] T. Breaux, A. Antón, Analyzing regulatory rules for privacy and security requirements, *IEEE Trans. Softw. Eng.* 34 (1) (2008) 5–20.

[3] E. Kempe, A. Massey, Regulatory and security standard compliance throughout the software development lifecycle, in: *Proceedings of the 54th Hawaii International Conference on System Sciences*, 2021.

[4] E. Kempe, A. Massey, Perspectives on regulatory compliance in software engineering, in: *2021 IEEE 29th International Requirements Engineering Conference, RE, IEEE, 2021*, pp. 46–57.

[5] A. Hamou-Lhadj, Regulatory Compliance and Its Impact on Software Development, *Software Compliance Research Group, Department of Electrical and Computer Engineering*, 2015.

[6] L. Leite, D.R. dos Santos, F. Almeida, The impact of general data protection regulation on software engineering practices, *Inf. Comput. Secur.* (2021).

[7] F. Moyón, P. Almeida, D. Riofrío, D. Mendez, M. Kalinowski, Security compliance in agile software development: A systematic mapping study, in: *2020 46th Euromicro Conference on Software Engineering and Advanced Applications, SEAA, IEEE, 2020*, pp. 413–420.

[8] J.P. Castellanos Ardila, B. Gallina, F. Ul Muram, Compliance checking of software processes: A systematic literature review, *J. Softw.: Evol. Process* 34 (5) (2022) e2440.

⁸ CTAB V0.1 can be accessed at: <https://try-ctab.github.io/>

- [9] S. Ghanavati, D. Amyot, L. Peyton, A systematic review of goal-oriented requirements management frameworks for business process compliance, in: 2011 Fourth International Workshop on Requirements Engineering and Law, IEEE, 2011, pp. 25–34.
- [10] O. Akhigbe, D. Amyot, G. Richards, A systematic literature mapping of goal and non-goal modelling methods for legal and regulatory compliance, *Requir. Eng.* 24 (2019).
- [11] N. Syed Abdullah, S. Sadiq, M. Indulka, Emerging challenges in information systems research for regulatory compliance management, in: International Conference on Advanced Information Systems Engineering, Springer, 2010, pp. 251–265.
- [12] A.-J. Aberkane, G. Poels, S.V. Broucke, Exploring automated GDPR-compliance in requirements engineering: A systematic mapping study, *IEEE Access* 9 (2021) 66542–66559.
- [13] T.C.W. Lin, Compliance, technology, and modern finance symposium: The role of technology in compliance in financial services: An indispensable tool as well as a threat, *Brooklyn J. Corp. Financ. Commer. Law* 11 (1) (2016) 159–182.
- [14] P. Engiel, J.C.S.D.P. Leite, J. Mylopoulos, A tool-supported compliance process for software systems, in: 2017 11th International Conference on Research Challenges in Information Science, RCIS, IEEE, 2017, pp. 66–76.
- [15] U. Zdun, A. Bener, E.L. Olalia-Carin, Guest editors' introduction: Software engineering for compliance, *IEEE Softw.* 29 (3) (2012) 24–27.
- [16] D. Orozco, A systems theory of compliance law, *U. Pa. J. Bus. L.* 22 (2019) 244.
- [17] T.C. Lin, Compliance, Technology, and Modern Finance, *J. Corp. Fin. & Com. L.* 2016.
- [18] R. Brownsword, H. Somsen, Law, innovation and technology: before we fast forward—a forum for debate, *Law Innov. Technol.* 1 (1) (2009) 1–73.
- [19] C. Koop, M. Lodge, What is regulation? An interdisciplinary concept analysis, *Regul. Gov.* 11 (1) (2017) 95–108.
- [20] C.Y. Laporte, A. April, *Software Engineering Standards and Models*, Wiley-IEEE Press, 2018, pp. 101–166.
- [21] W. Emmerich, A. Finkelstein, C. Montanero, S. Antonelli, S. Armitage, R. Stevens, Managing standards compliance, *IEEE Trans. Softw. Eng.* 25 (6) (1999) 836–851.
- [22] D. Levi-Faur, Regulation and regulatory governance, *Handb. Politics Regul.* 1 (1) (2011) 1–25.
- [23] OECD, *The Governance of Regulators*, OECD Publishing, 2016.
- [24] R. Hilliard, IEEE recommended practice for architectural description for software-intensive systems, *IEEE Std 1471-2000* (2000) 1–30.
- [25] R. Winter, R. Fischer, Essential layers, artifacts, and dependencies of enterprise architecture, in: 2006 10th IEEE International Enterprise Distributed Object Computing Conference Workshops, EDOCW'06, IEEE, 2006, p. 30.
- [26] P. Bourque, R.E. Fairley, I.C. Society, *Guide to the Software Engineering Body of Knowledge (SWEBOK(R))*: Version 3.0, third ed., IEEE Computer Society Press, Washington, DC, USA, 2014.
- [27] J.-P. Coriveau, V. Radonjic, W. Shi, Requirements verification: Legal challenges in compliance testing, in: 2014 IEEE International Conference on Progress in Informatics and Computing, IEEE, 2014, pp. 451–454.
- [28] I.O. for Standardization, *Information Technology — DevOps — Building Reliable and Secure Systems Including Application Build, Package and Deployment*, Standard, International Organization for Standardization, Geneva, CH, 2022.
- [29] C. Negri-Ribalta, M. Lombard-Platet, C. Salinesi, Understanding the GDPR from a requirements engineering perspective—a systematic mapping study on regulatory data protection requirements, *Requir. Eng.* (2024) 1–27.
- [30] M. Mubarkoot, J. Altmann, M. Rasti-Barzoki, B. Egger, H. Lee, Software compliance requirements, factors, and policies: A systematic literature review, *Comput. Secur.* 124 (2023) 102985.
- [31] A. Mustapha, O. Arogundade, S. Misra, R. Damasevicius, R. Maskeliunas, A systematic literature review on compliance requirements management of business processes, *Int. J. Syst. Assur. Eng. Manag.* 11 (2020).
- [32] M. Hashmi, G. Governatori, B. Lam, M.T. Wynn, Are we done with business process compliance: state of the art and challenges ahead, *Knowl. Inf. Syst.* 57 (2017) 79–133.
- [33] M. Fellmann, A. Zasada, State-of-the-art of business process compliance approaches: A survey, in: ECIS 2014 Proceedings - 22nd European Conference on Information Systems, 2014, pp. 45–48.
- [34] J. Becker, P. Delfmann, M. Eggert, S. Schwittay, Generalizability and applicability of model-based business process compliance-checking approaches – A state-of-the-art analysis and research roadmap, *BuR - Bus. Res.* 5 (2012).
- [35] A. Shamsaei, D. Amyot, A. Pourshahid, A systematic review of compliance measurement based on goals and indicators, in: Advanced Information Systems Engineering Workshops: CAISE 2011 International Workshops, London, UK, June 20–24, 2011. Proceedings 23, Springer, 2011, pp. 228–237.
- [36] S. Nair, J.L. de la Vara, M. Sabetzadeh, L. Briand, An extended systematic literature review on provision of evidence for safety certification, *Inf. Softw. Technol.* 56 (2014).
- [37] M. Mubarkoot, J. Altmann, Software compliance in different industries: A systematic literature review, in: CIISR 2021, International Workshop on Current Compliance Issues in Information Systems Research, CEUR Workshop Proceedings, 2021, pp. 1–23.
- [38] N. Syed Abdullah, M. Indulka, S. Sadiq, A study of compliance management in information systems research, in: 17th European Conference on Information Systems, ECIS 2009, 2009, pp. 1711–1721.
- [39] A. Cleven, R. Winter, Regulatory compliance in information systems research literature analysis and research agenda, 29, ISBN: 978-3-642-01861-9, 2009, <http://www.alexandria.unisg.ch/Publikationen/67909>.
- [40] P.N. Otto, A.I. Anton, Addressing legal requirements in requirements engineering, in: 15th IEEE International Requirements Engineering Conference (RE 2007), 2007, pp. 5–14.
- [41] B. Kitchenham, S. Charters, Guidelines for performing systematic literature reviews in software engineering, 2007.
- [42] T. Dyba, T. Dingsoyr, G.K. Hanssen, Applying systematic reviews to diverse study types: An experience report, in: First International Symposium on Empirical Software Engineering and Measurement (ESEM 2007), 2007, pp. 225–234.
- [43] L. Zhao, W. Alhoshan, A. Ferrari, K.J. Letsholo, M.A. Ajagbe, E.-V. Chioasca, R.T. Batista-Navarro, Natural language processing for requirements engineering: A systematic mapping study, *ACM Comput. Surv.* 54 (3) (2021).
- [44] P. Brereton, B.A. Kitchenham, D. Budgen, M. Turner, M. Khalil, Lessons from applying the systematic literature review process within the software engineering domain, *J. Syst. Softw.* 80 (4) (2007) 571–583.
- [45] R. Kasauli, R. Wohlrab, et al., Charting coordination needs in large-scale agile organisations with boundary objects and methodological islands, in: Proceedings of the ICSSP, 2020.
- [46] T. Granlund, T. Mikkonen, V. Stirbu, On medical device software CE compliance and conformity assessment, in: 2020 IEEE International Conference on Software Architecture Companion (ICSA-C), IEEE, Salvador, Brazil, 2020, pp. 185–191.
- [47] C. Wohlin, Guidelines for snowballing in systematic literature studies and a replication in software engineering, in: Proceedings of the 18th International Conference on Evaluation and Assessment in Software Engineering, 2014, pp. 1–10.
- [48] V. Ayala-Rivera, L. Pasquale, The grace period has ended: An approach to operationalize GDPR requirements, in: 2018 IEEE 26th International Requirements Engineering Conference (RE), IEEE, Banff, AB, 2018, pp. 136–146.
- [49] A.O. Portillo-Dominguez, V. Ayala-Rivera, Towards an efficient log data protection in software systems through data minimization and anonymization, in: 2019 7th International Conference in Software Engineering Research and Innovation, CONISOFT, IEEE, 2019, pp. 107–115.
- [50] P. Laplante, What Every Engineer Should Know about Software Engineering, 2007, pp. 1–312.
- [51] International Telecommunication Union and the World Bank, *Digital Regulation Handbook*, International Telecommunication Union and the World Bank, 2020.
- [52] M. Rotenberg, D. Jacobs, Updating the law of information privacy: the new framework of the European Union, *Harv. J.L. & Pub. Pol'y* 36 (2013) 605.
- [53] M. Müller, M.C. Kettmann, in: H. Werthner, C. Ghezzi, J. Kramer, J. Nida-Rümelin, B. Nuseibeh, E. Prem (Eds.), *European Approaches to the Regulation of Digital Technologies*, 2024, p. 623.
- [54] M. Mueck, S. Choi, P. Bender, V. Ivanov, Y. Jin, H. Ahn, K. Kim, E. Dutkiewicz, Radio equipment directive-a novel software reconfiguration framework, in: 2017 IEEE Globecom Workshops (GC Wkshps), IEEE, 2017, pp. 1–5.
- [55] O.T. Arogundade, S. Misra, M. Odusami, E. Adelaja, O. Abayomi-Alli, An algorithm-centric approach to enhance business process compliance management, *Int. J. Eng. Res. Afr.* 50 (2020) 15–28.
- [56] G. Fantoni, E. Coli, F. Chiarello, R. Apreda, F. Dell'Orletta, G. Pratelli, Text mining tool for translating terms of contract into technical specifications: Development and application in the railway sector, *Comput. Ind.* 124 (2021) 103357.
- [57] C. Ponsard, J.-C. Deprez, Helping SMEs to better develop software: experience report and challenges ahead, in: Proceedings of the 40th International Conference on Software Engineering: Software Engineering in Practice, 2018, pp. 213–214.
- [58] P. Ryan, M. Crane, R. Brennan, GDPR compliance tools: best practice from RegTech, in: International Conference on Enterprise Information Systems, Springer, 2020, pp. 905–929.
- [59] G. Drivas, A. Chatzopoulou, L. Maglaras, C. Lambrinoudakis, A. Cook, H. Janicke, A nis directive compliant cybersecurity maturity assessment framework, in: 2020 IEEE 44th Annual Computers, Software, and Applications Conference, COMPSAC, IEEE, 2020, pp. 1641–1646.
- [60] J. Cohen, A coefficient of agreement for nominal scales, *Educ. Psychol. Meas.* 20 (1) (1960) 37–46.
- [61] P. Offermann, S. Blom, M. Schönherr, U. Bub, Artifact types in information systems design science – A literature review, in: R. Winter, J.L. Zhao, S. Aier (Eds.), *Global Perspectives on Design Science Research*, Springer Berlin Heidelberg, Berlin, Heidelberg, 2010, pp. 77–92.
- [62] L. Rierison, *Developing Safety-Critical Software: A Practical Guide for Aviation Software and DO-178C Compliance*, first ed., CRC Press, 2013.
- [63] R. Parasuraman, T. Sheridan, C. Wickens, A model for types and levels of human interaction with automation, *IEEE Trans. Syst. Man Cybern. Part A: Syst. Hum.* 30 (3) (2000) 286–297.

- [64] M. Ivarsson, T. Gorschek, A method for evaluating rigor and industrial relevance of technology evaluations, *Empir. Softw. Eng.* 16 (2011) 365–395.
- [65] M. Camilli, M. Felderer, A. Giusti, D.T. Matt, A. Perini, B. Russo, A. Susi, Risk-driven compliance assurance for collaborative AI systems: A vision paper, in: F. Dalpiaz, P. Spoletini (Eds.), *Requirements Engineering: Foundation for Software Quality*, vol. 12685, in: *Lecture Notes in Computer Science*, Springer International Publishing, Cham, 2021, pp. 123–130.
- [66] M. Peixoto, D. Ferreira, M. Cavalcanti, C. Silva, J. Vilela, J. Araújo, T. Gorschek, On Understanding How Developers Perceive and Interpret Privacy Requirements Research Preview, in: N. Madhavji, L. Pasquale, A. Ferrari, S. Gnesi (Eds.), *Requirements Engineering: Foundation for Software Quality*, in: *Lecture Notes in Computer Science*, vol. 12045, Springer International Publishing, Cham, 2020, pp. 116–123.
- [67] M. Peixoto, D. Ferreira, M. Cavalcanti, C. Silva, J. Vilela, J. Araújo, T. Gorschek, The perspective of Brazilian software developers on data privacy, *J. Syst. Softw.* 195 (2023) 111523.
- [68] E. Dias Canedo, A. Toffano Seidel Calazans, E. Toffano Seidel Masson, P.H. Teixeira Costa, F. Lima, Perceptions of ICT practitioners regarding software privacy, *Entropy* 22 (4) (2020) 429.
- [69] E.D. Canedo, A.T.S. Calazans, A.J. Cerqueira, P.H.T. Costa, E.T.S. Masson, Agile teams' perception in privacy requirements elicitation: Lgpd's compliance in Brazil, in: 2021 IEEE 29th International Requirements Engineering Conference, RE, IEEE, 2021, pp. 58–69.
- [70] R. Galvez, S. Gurses, The odyssey: Modeling privacy threats in a brave new world, in: 2018 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), IEEE, London, 2018, pp. 87–94.
- [71] Z.S. Li, C. Werner, N. Ernst, Continuous requirements: An example using GDPR, in: 2019 IEEE 27th International Requirements Engineering Conference Workshops (REW), IEEE, Jeju Island, Korea (South), 2019, pp. 144–149.
- [72] Z.S. Li, C. Werner, N. Ernst, D. Damian, Towards privacy compliance: A design science study in a small organization, *Inf. Softw. Technol.* 146 (2022) 106868.
- [73] V.C. Andrade, S. Reinehr, C.O. Freitas, A. Malucelli, Personal data privacy in software development processes: A practitioner's point of view, in: 2023 IEEE 22nd International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom), IEEE, 2023, pp. 2727–2734.
- [74] A.B. Bujok, S.T. MacMahon, P. Grant, D. Whelan, W.J. Rickard, F. McCaffery, Approach to the development of a Unified Framework for Safety Critical Software Development, *Comput. Stand. Interfaces* 54 (2017) 152–161.
- [75] J.P.C. Ardila, B. Gallina, Towards efficiently checking compliance against automotive security and safety standards, in: 2017 IEEE International Symposium on Software Reliability Engineering Workshops (ISSREW), IEEE, Toulouse, 2017, pp. 317–324.
- [76] M. Fan, L. Yu, S. Chen, H. Zhou, X. Luo, S. Li, Y. Liu, J. Liu, T. Liu, An empirical evaluation of GDPR compliance violations in android mHealth apps, in: 2020 IEEE 31st International Symposium on Software Reliability Engineering (ISSRE), IEEE, Coimbra, Portugal, 2020, pp. 253–264.
- [77] O. Tomashchuk, Y. Li, D. Van Landuyt, W. Joosen, Operationalization of privacy and security requirements for eHealth IoT applications in the context of GDPR and CSL, in: L.S. Antunes, M. Naldi, G.F. Italiano, K. Rannenberg, P. Drogkaris (Eds.), *Privacy Technologies and Policy*, in: *Lecture Notes in Computer Science*, vol. 12121, Springer International Publishing, Cham, 2020, pp. 143–160.
- [78] Y.-S. Martin, A. Kung, Methods and tools for GDPR compliance through privacy and data protection engineering, in: 2018 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), IEEE, London, United Kingdom, 2018, pp. 108–111.
- [79] D.S. Guaman, J.M. Del Alamo, J.C. Caiza, GDPR compliance assessment for cross-border personal data transfers in android apps, *IEEE Access* 9 (2021) 15961–15982.
- [80] K. Hjerpe, J. Ruohonen, V. Leppanen, The general data protection regulation: Requirements, architectures, and constraints, in: 2019 IEEE 27th International Requirements Engineering Conference (RE), IEEE, Jeju Island, Korea (South), 2019, pp. 265–275.
- [81] M. Farhadi, H. Haddad, H. Shahriar, Compliance checking of open source EHR applications for HIPAA and ONC security and privacy requirements, in: 2019 IEEE 43rd Annual Computer Software and Applications Conference, vol. 1, COMPSAC, IEEE, 2019, pp. 704–713.
- [82] M. Alsaadi, A. Lisitsa, M. Qasaimeh, Minimizing the ambiguities in medical devices regulations based on software requirement engineering techniques, in: *Proceedings of the Second International Conference on Data Science, E-Learning and Information Systems*, ACM, Dubai United Arab Emirates, 2019, pp. 1–5.
- [83] D.B. Raykar, L.T. JayPrakash, K.V. Dinesha, An iterative and incremental approach to address regulatory compliance concerns in requirements engineering, in: D. Garg, K. Wong, J. Sarangapani, S.K. Gupta (Eds.), *Advanced Computing*, in: *Communications in Computer and Information Science*, vol. 1368, Springer Singapore, Singapore, 2021, pp. 323–335.
- [84] M. Alshammari, A. Simpson, A model-based approach to support privacy compliance, *Inf. Comput. Secur.* 26 (4) (2018) 437–453.
- [85] E.S. Grant, Towards Domain-Specific Modeling Methodology for Avionic Safety-Critical Systems, 2018.
- [86] P. Dewitte, K. Wuyts, L. Sion, D. Van Landuyt, I. Emanuilov, P. Valcke, W. Joosen, A comparison of system description models for data protection by design, in: *Proceedings of the 34th ACM/SIGAPP Symposium on Applied Computing*, ACM, Limassol Cyprus, 2019, pp. 1512–1515.
- [87] P. Cook, S. Mengal, S. Parameswaran, SHAMROQ: Towards semantic models of regulations, in: *SEKE*, 2020, pp. 93–100.
- [88] O. Odarushchenko, O. Striuk, K. Leontiev, E. Odarushchenko, Software fault insertion testing for SIL certification of safety PLC-based system, in: 2020 IEEE 11th International Conference on Dependable Systems, Services and Technologies (DESSERT), IEEE, Kyiv, Ukraine, 2020, pp. 80–84.
- [89] D. Huth, F. Matthes, "Appropriate Technical and Organizational Measures": Identifying Privacy Engineering Approaches to Meet GDPR Requirements, 2019.
- [90] A. Paz, G. El Boussaidi, A requirements modelling language to facilitate avionics software verification and certification, in: 2019 IEEE/ACM 6th International Workshop on Requirements Engineering and Testing (RET), IEEE, Montreal, QC, Canada, 2019, pp. 1–8.
- [91] M. Chechik, R. Salay, T. Viger, S. Kokaly, M. Rahimi, Software assurance in an uncertain world, in: R. Hähnle, W. Van Der Aalst (Eds.), *Fundamental Approaches To Software Engineering*, in: *Lecture Notes in Computer Science*, vol. 11424, Springer International Publishing, Cham, 2019, pp. 3–21.
- [92] P.-F. Gu, Y.-N. He, J.-Z. Tang, W.-P. Ye, Discussion on traceability analysis method of safety software in nuclear power plants, in: *Nuclear Power Plants: Innovative Technologies for Instrumentation and Control Systems: The Fourth International Symposium on Software Reliability, Industrial Safety, Cyber Security and Physical Protection of Nuclear Power Plant*, ISNPP, Springer, 2020, pp. 455–462.
- [93] H. Guo, O. Kafali, A.-L. Jeukeng, L. Williams, M.P. Singh, Çorba: crowdsourcing to obtain requirements from regulations and breaches, *Empir. Softw. Eng.* 25 (1) (2020) 532–561.
- [94] A.M. Mustapha, O.T. Arogundade, A. Abayomi-Alli, O.J. Adeniran, K. Ademowo, C.Y. Alonge, A systematic method for extracting and analyzing cloud-based compliance requirements, in: 2020 International Conference in Mathematics, Computer Engineering and Computer Science (ICMCECS), IEEE, Ayobo, Ipaja, Lagos, Nigeria, 2020, pp. 1–7.
- [95] I. Biscoglio, G. Lami, G. Trentanni, Certification of cash registers software, in: *Model-Driven Engineering and Software Development: 4th International Conference, MODELSWARD 2016, Rome, Italy, February 19–21, 2016, Revised Selected Papers 4*, Springer, 2017, pp. 154–167.
- [96] M. Usman, M. Felderer, M. Unterkalmsteiner, E. Klotins, D. Méndez Fernández, E. Alégroth, Compliance Requirements in Large-Scale Software Development: An Industrial Case Study, 2020, pp. 385–401.
- [97] M. Esche, F. Salwiczek, F.G. Toro, Formalization of Software Risk Assessment Results in Legal Metrology Based on ISO/IEC 18045 Vulnerability Analysis, 2019, pp. 443–447.
- [98] C. Bartolini, S. Daoudagh, G. Lenzini, E. Marchetti, GDPR-based user stories in the access control perspective, in: *Quality of Information and Communications Technology: 12th International Conference, QUATIC 2019, Ciudad Real, Spain, September 11–13, 2019, Proceedings 12*, Springer, 2019, pp. 3–17.
- [99] D. Netto, C. Silva, J. Araújo, Identifying how the Brazilian software industry specifies legal requirements, in: *Proceedings of the XXXIII Brazilian Symposium on Software Engineering*, ACM, Salvador Brazil, 2019, pp. 181–186.
- [100] M. Patwardhan, R. Sharma, A. Sainani, oving Disambiguation of Regulations from the Cathedral to the Bazaar.
- [101] M. Jantti, Studying data privacy management in small and medium-sized IT companies, in: 2020 14th International Conference on Innovations in Information Technology (IIT), IEEE, Al Ain, United Arab Emirates, 2020, pp. 57–62.
- [102] O. Velychko, V. Gaman, T. Gordiyenko, O. Hrabovskiy, Testing of measurement instrument software with the purpose of conformity assessment, *East-Eur. J. Enterpr. Technol.* 1 (9 (97)) (2019) 19–26.
- [103] M. Jensen, S. Kapila, N. Gruschka, Towards aligning GDPR compliance with software development: A research agenda, in: *Proceedings of the 5th International Conference on Information Systems Security and Privacy, SCITEPRESS - Science and Technology Publications*, Prague, Czech Republic, 2019, pp. 389–396.
- [104] M. Patwardhan, A. Sainani, R. Sharma, S. Karande, S. Ghaisas, Towards automating disambiguation of regulations: using the wisdom of crowds, in: *Proceedings of the 33rd ACM/IEEE International Conference on Automated Software Engineering*, ACM, Montpellier France, 2018, pp. 850–855.
- [105] P. Sakul-Ung, S. Smachet, Towards privacy framework in software development projects and applications: An integrated framework, in: 2019 Research, Invention, and Innovation Congress (RI2C), IEEE, Bangkok, Thailand, 2019, pp. 1–6.
- [106] O. Kosenkov, Towards socio-technical requirements engineering for regulatory compliance, in: 2020 IEEE 28th International Requirements Engineering Conference (RE), IEEE, Zurich, Switzerland, 2020, pp. 451–456.
- [107] R. Kneuper, Translating data protection into software requirements, in: *Proceedings of the 6th International Conference on Information Systems Security and Privacy, SCITEPRESS - Science and Technology Publications*, Valletta, Malta, 2020, pp. 257–264.

- [108] A.K. Massey, E. Holtgreffe, S. Ghanavati, Modeling regulatory ambiguities for requirements analysis, in: *Conceptual Modeling: 36th International Conference, ER 2017, Valencia, Spain, November 6–9, 2017, Proceedings 36*, Springer, 2017, pp. 231–238.
- [109] A. Strielkina, O. Illiashenko, M. Zhydenko, D. Uzun, Cybersecurity of healthcare IoT-based systems: Regulation and case-oriented assessment, in: *2018 IEEE 9th International Conference on Dependable Systems, Services and Technologies, DESSERT, IEEE*, 2018, pp. 67–73.
- [110] S. Ghaisas, A. Sainani, P.R. Anish, Resolving ambiguities in regulations: towards achieving the Kohlbergian stage of principled morality, in: *Proceedings of the 40th International Conference on Software Engineering: Software Engineering in Society*, 2018, pp. 57–60.
- [111] J. Wieland, Implementation of kanban practices with a medical device software development lifecycle, in: *International Conference on Multidisciplinary Research*, vol. 2018, 2018, pp. 16–30.
- [112] N. Metayer, A. Paz, G. El Boussaidi, Modelling do-178c assurance needs: A design assurance level-sensitive dsl, in: *2019 IEEE International Symposium on Software Reliability Engineering Workshops, ISSREW, IEEE*, 2019, pp. 338–345.
- [113] V. Romero-Chacón, H. Muir-Camacho, J. Rodríguez-González, A. Gómez-Blanco, M. Chacón-Rivas, Adapting SCRUM methodology to develop accessible web sites, in: *2019 International Conference on Inclusive Technologies and Education, CONTIE, IEEE*, 2019, pp. 112–1124.
- [114] H. Bagheri, E. Kang, N. Mansoor, Synthesis of assurance cases for software certification, in: *Proceedings of the ACM/IEEE 42nd International Conference on Software Engineering: New Ideas and Emerging Results*, 2020, pp. 61–64.
- [115] T.M.R. Slavov, J.C. Marques, L.E.G. Martins, Requirements for a software audit model in safety-critical domains, in: *WER*, 2020.
- [116] A. Zaitsev, Agile methods as a risk management strategy tool—A fintech case study, 2018.
- [117] B.R. Barricelli, E. Casiraghi, A. Dattolo, A. Rizzi, 15 years of stanca act: are italian public universities websites accessible? *Univ. Access Inf. Soc.* 20 (2021) 185–200.
- [118] V. Stirbu, T. Mikkonen, Introducing traceability in github for medical software development, in: *Product-Focused Software Process Improvement: 22nd International Conference, PROFES 2021, Turin, Italy, November 26, 2021, Proceedings 22*, Springer, 2021, pp. 152–164.
- [119] B. Zieni, D. Spagnuolo, R. Heckel, Transparency by default: GDPR patterns for agile development, in: *International Conference on Electronic Government and the Information Systems Perspective*, Springer, 2021, pp. 89–102.
- [120] A. Poth, M. Kottke, K. Middelhaue, T. Mahr, A. Riel, Lean integration of IT security and data privacy governance aspects into product development in agile organizations, *JUCS: J. Univ. Comput. Sci.* 27 (8) (2021).
- [121] E. Gómez-Martínez, M. Marroyo, S.T. Acuña, Towards the integration of the GDPR in the unified software development process (s), in: *SEKE*, 2021, pp. 199–204.
- [122] F.U. Muram, M.A. Javed, S. Kanwal, Facilitating the compliance of process models with critical system engineering standards using natural language processing, in: *ENASE*, 2021, pp. 306–313.
- [123] M. Durling, H. Herencia-Zapana, B. Meng, M. Meiners, J. Hochwarth, N. Visser, R. Lee, R. Moss, V.T. Valapil, Certification considerations for adaptive stress testing of airborne software, in: *2021 IEEE/AIAA 40th Digital Avionics Systems Conference, DASC, IEEE*, 2021, pp. 1–9.
- [124] F. Sovrano, F. Vitali, M. Palmirani, Making things explainable vs explaining: Requirements and challenges under the GDPR, in: *International Workshop on AI Approaches To the Complexity of Legal Systems*, Springer, 2018, pp. 169–182.
- [125] L. Campanile, M. Iacono, M. Mastroianni, Towards privacy-aware software design in small and medium enterprises, in: *2022 IEEE Intl Conf on Dependable, Autonomic and Secure Computing, Intl Conf on Pervasive Intelligence and Computing, Intl Conf on Cloud and Big Data Computing, Intl Conf on Cyber Science and Technology Congress (DASC/PiCom/CBDCom/CyberSciTech)*, IEEE, 2022, pp. 1–8.
- [126] B. Mashaly, S. Selim, A.H. Yousef, K.M. Fouad, Privacy by design: A microservices-based software architecture approach, in: *2022 2nd International Mobile, Intelligent, and Ubiquitous Computing Conference, MIUCC, IEEE*, 2022, pp. 357–364.
- [127] E.D. Canedo, A.T.S. Calazans, I.N. Bandeira, P.H.T. Costa, E.T.S. Masson, Guidelines adopted by agile teams in privacy requirements elicitation after the Brazilian general data protection law (LGPD) implementation, *Requir. Eng.* 27 (4) (2022) 545–567.
- [128] N. Alhirabi, S. Beaumont, O. Rana, C. Perera, Privacy-patterns for IoT application developers, in: *Adjunct Proceedings of the 2022 ACM International Joint Conference on Pervasive and Ubiquitous Computing and the 2022 ACM International Symposium on Wearable Computers*, 2022, pp. 7–9.
- [129] N. Peyrone, D. Wichadakul, Formal models for consent-based privacy, *J. Log. Algebr. Methods Program.* 128 (2022) 100789.
- [130] O. Olukoya, Assessing frameworks for eliciting privacy & security requirements from laws and regulations, *Comput. Secur.* 117 (2022) 102697.
- [131] H.W. van Deutekom, S. Haitjema, Recommendations for IVDR compliant in-house software development in clinical practice: a how-to paper with three use cases, *Clin. Chem. Lab. Med. (CCLM)* 60 (7) (2022) 982–988.
- [132] K. Ludvigsen, S. Nagaraja, D. Angela, When is software a medical device? Understanding and determining the “intention” and requirements for software as a medical device in European Union Law, *Eur. J. Risk Regul.* 13 (1) (2022) 78–93.
- [133] L. Leite, D.R. dos Santos, F. Almeida, The impact of general data protection regulation on software engineering practices, *Inf. Comput. Secur.* 30 (1) (2022) 79–96.
- [134] V. Barletta, G. Desolda, D. Gigante, R. Lanzilotti, M. Saltarella, From gdpr to privacy design patterns: The materialist framework, in: *Proceedings of the 19th International Conference on Security and Cryptography-SECURITY*, 2022, pp. 642–648.
- [135] M. Kyhlstedt, The need for action by evaluators and decision makers in europe to ensure safe use of medical software, *Front. Med. Technol.* 4 (2022) 1063622.
- [136] P. Ryan, R. Brennan, Support for enhanced GDPR accountability with the common semantic model for ROPA (CSM-ROPA), *SN Comput. Sci.* 3 (3) (2022) 224.
- [137] J. Illescas, G. Buchgeher, L. Ehrlinger, D. Gabauer, J. Martinez-Gil, Representing technical standards as knowledge graph to guide the design of industrial systems, in: *International Conference on Computer Aided Systems Theory*, Springer, 2022, pp. 603–610.
- [138] E. Kempe, Documenting regulatory requirements decision-making as a compliance concern, in: *2022 IEEE 30th International Requirements Engineering Conference, RE, IEEE*, 2022, pp. 213–218.
- [139] T. Sarraja, T. Mikkonen, A. Nguyen Duc, P. Abrahamsson, Towards identification of privacy requirements with systems thinking, in: *International Symposium on Business Modeling and Software Design*, Springer, 2022, pp. 249–258.
- [140] T.D. Breaux, T. Norton, Legal accountability as software quality: A us data processing perspective, in: *2022 IEEE 30th International Requirements Engineering Conference, RE, IEEE*, 2022, pp. 101–113.
- [141] P.B. Ladkin, M. Thomas, Assigning IACS cybersecurity responsibility conformant with the UK network and information system regulation 2018, *Digit. Evidence Elec. Signature L. Rev.* 19 (2022) 87.
- [142] V. Tan, C. Cheh, B. Chen, From application security verification standard (ASVS) to regulation compliance: A case study in financial services sector, in: *2021 IEEE International Symposium on Software Reliability Engineering Workshops, ISSREW, IEEE*, 2021, pp. 69–76.
- [143] S. McLachlan, M. Neil, K. Dube, R. Bogani, N. Fenton, B. Schaffer, Smart automotive technology adherence to the law(de) constructing road rules for autonomous system development, verification and safety, *Int. J. Law Inf. Technol.* 29 (4) (2021) 255–295.
- [144] W. Price, I. Nicholson, Regulating black-box medicine, *Mich. L. Rev.* 116 (2017) 421.
- [145] M. Almada, Regulation by design and the governance of technological futures, *Eur. J. Risk Regul.* 14 (4) (2023) 697–709.
- [146] M.D. Mueck, A.E.B. On, S. Du Boispean, Upcoming European regulations on artificial intelligence and cybersecurity, *IEEE Commun. Mag.* 61 (7) (2023) 98–102.
- [147] A.C. Culley, Insights into UK investment firms’ efforts to comply with MiFID II RTS 6 that governs the conduct of algorithmic trading, *J. Financ. Regul. Compliance* 31 (5) (2023) 607–629.
- [148] F. Tang, B.M. Østfold, M. Bruntink, Helping code reviewer prioritize: Pinpointing personal data and its processing, in: *New Trends in Intelligent Software Methodologies, Tools and Techniques*, IOS Press, 2023, pp. 109–124.
- [149] L. Lucaj, P. Van Der Smagt, D. Benbouzid, Ai regulation is (not) all you need, in: *Proceedings of the 2023 ACM Conference on Fairness, Accountability, and Transparency*, 2023, pp. 1267–1279.
- [150] P. Li, R. Williams, S. Gilbert, S. Anderson, Regulating AI/ML-enabled medical devices in the UK, in: *Proceedings of the First International Symposium on Trustworthy Autonomous Systems*, 2023, pp. 1–10.
- [151] N. Alhirabi, S. Beaumont, J.T. Llanos, D. Meedeniya, O. Rana, C. Perera, PARROT: Interactive privacy-aware internet of things application design tool, in: *Proceedings of the ACM on Interactive, Mobile, Wearable and Ubiquitous Technologies*, vol. 7, ACM New York, NY, USA, 2023, pp. 1–37.
- [152] Q. Rouland, S. Gjorcheski, J. Jaskolka, Eliciting a security architecture requirements baseline from standards and regulations, in: *2023 IEEE 31st International Requirements Engineering Conference Workshops, REW, IEEE*, 2023, pp. 224–229.
- [153] G.M. Makrakis, D. Roberson, C. Kolas, WIPP: Towards IEC 62443-3-3 network compliance via software-defined networking in digital substations, in: *2023 Resilience Week, RWS, IEEE*, 2023, pp. 1–7.
- [154] J.-G. Durand, A. Dubois, R.J. Moss, Formal and practical elements for the certification of machine learning systems, in: *2023 IEEE/AIAA 42nd Digital Avionics Systems Conference, DASC, IEEE*, 2023, pp. 1–10.
- [155] D. Amalfitano, M. De Luca, A.R. Fasolino, Documenting software architecture design in compliance with the iso 26262: a practical experience in industry, in: *2023 IEEE 20th International Conference on Software Architecture Companion (ICSA-C)*, IEEE, 2023, pp. i–xi.
- [156] A. Ekambaranathan, J. Zhao, G. Chalhoub, Navigating the data avalanche: Towards supporting developers in developing privacy-friendly children’s apps, in: *Proceedings of the ACM on Interactive, Mobile, Wearable and Ubiquitous Technologies*, vol. 7, (2) ACM New York, NY, USA, 2023, pp. 1–24.

- [157] G. Desolda, A. Esposito, F. Greco, R. Lanzilotti, S. Marco, et al., MATERIALIST: A web platform for guiding privacy design pattern selection in software development, in: CEUR WORKSHOP PROCEEDINGS, vol. 3408, CEUR-WS, 2023.
- [158] D. Prokhorenkov, Toward compliance implications and security objectives: A qualitative study, in: 2023 IEEE 39th International Conference on Data Engineering Workshops, ICDEW, IEEE, 2023, pp. 138–145.
- [159] P. Sangaroonilp, H.K. Dam, M. Choetkiertikul, C. Ragkhitwetsagul, A. Ghose, A taxonomy for mining and classifying privacy requirements in issue reports, *Inf. Softw. Technol.* 157 (2023) 107162.
- [160] I. Agirre, A.J. Calderon, I. Yarza, I. Mugarza, D. Garcia, L. Borracchi, P. Uven, A. Jover, UP2DATE software updating framework compliance with safety and security regulations and standards, in: 2023 26th Euromicro Conference on Digital System Design, DSD, IEEE, 2023, pp. 399–406.
- [161] O. Kosenkov, M. Unterkalmsteiner, D. Mendez, D. Fucci, Vision for an artefact-based approach to regulatory requirements engineering, in: Proceedings of the 15th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement, ESEM, 2021, pp. 1–6.
- [162] O. Klymenko, O. Kosenkov, S. Meisenbacher, P. Elahidoost, D. Mendez, F. Matthes, Understanding the implementation of technical measures in the process of data privacy compliance: a qualitative study, in: Proceedings of the 16th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement, 2022, pp. 261–271.
- [163] A.A. Khan, M.U. Akram, A.A. Salam, W.H. Butt, An enhanced agile-v model for system engineering in complex medical device development, in: 2022 2nd International Conference on Digital Futures and Transformative Technologies (ICoDT2), IEEE, 2022, pp. 1–6.
- [164] K. Dmitriev, S.A. Zafar, K. Schmichen, Y. Lai, M. Saleab, P. Nagaranjan, D. Dollinger, M. Hochstrasser, F. Holzapfel, S. Myschik, A lean and highly-automated model-based software development process based on DO-178C/DO-331, in: 2020 AIAA/IEEE 39th Digital Avionics Systems Conference (DASC), IEEE, San Antonio, TX, USA, 2020, pp. 1–10.
- [165] T.J. Wagner, T.C. Ford, Metrics to meet security & privacy requirements with agile software development methods in a regulated environment, in: 2020 International Conference on Computing, Networking and Communications (ICNC), IEEE, Big Island, HI, USA, 2020, pp. 17–23.
- [166] M.E. Pierce, S. Marru, Integrating science gateways with secure cloud computing resources: An examination of two deployment patterns and their requirements, in: 2020 IEEE/ACM International Workshop on HPC User Support Tools (HUST) and Workshop on Programming and Performance Visualization Tools (ProTools), IEEE, GA, USA, 2020, pp. 19–26.
- [167] F. Moyon, K. Beckers, S. Klepper, P. Lachberger, B. Bruegge, Towards continuous security compliance in agile software development at scale, in: Proceedings of the 4th International Workshop on Rapid Continuous Software Engineering, ACM, Gothenburg Sweden, 2018, pp. 31–34.
- [168] G. Huang, C. Luo, K. Wu, Y. Ma, Y. Zhang, X. Liu, Software-defined infrastructure for decentralized data lifecycle governance: Principled Design and Open Challenges, in: 2019 IEEE 39th International Conference on Distributed Computing Systems (ICDCS), IEEE, Dallas, TX, USA, 2019, pp. 1674–1683.
- [169] A. Rabinia, S. Ghanavati, L. Humphreys, T. Hahmann, A methodology for implementing the formal legal-GRL framework: A research preview, in: N. Madhavji, L. Pasquale (Eds.), Requirements Engineering: Foundation for Software Quality, in: Lecture Notes in Computer Science, vol. 12045, Springer International Publishing, Cham, 2020, pp. 124–131.
- [170] O. Ø'zcan-Top, F. McCaffery, A hybrid assessment approach for medical device software development companies, *J. Softw.: Evol. Process* 30 (7) (2018) e1929.
- [171] J.F. Xu, The design assurance method of reused airborne software, *J. Phys. Conf. Ser.* 1856 (1) (2021) 012041.
- [172] T. Laukkarinen, K. Kuusinen, T. Mikkonen, Regulated software meets DevOps, *Inf. Softw. Technol.* 97 (2018) 176–178.
- [173] L. Dieudonné, A. Bayha, B. Müller, RMC factory: A new approach for avionics software reuse, 2021.
- [174] J. Liu, X. Zhang, Y. Zhao, H. Fan, Reuse strategy for the previously qualified software tool of airborne software, *J. Phys. Conf. Ser.* 1827 (1) (2021) 012111.
- [175] F. Moyón, D. Méndez, K. Beckers, S. Klepper, How to integrate security compliance requirements with agile software engineering at scale? in: Product-Focused Software Process Improvement: 21st International Conference, PROFES 2020, Turin, Italy, November 25–27, 2020, Proceedings 21, Springer, 2020, pp. 69–87.
- [176] Z. István, S. Ponnappalli, V. Chidambaram, Software-defined data protection: low overhead policy compliance at the storage layer is within reach!, *Proc. VLDB Endowment* 14 (7) (2021) 1167–1174.
- [177] S. Guarro, M.K. Yau, U. Ozguner, T. Aldemir, A. Kurt, M. Hejase, M. Knudson, Formal framework and models for validation and verification of software-intensive aerospace systems, in: AIAA Information Systems-AIAA Infotech @ Aerospace, American Institute of Aeronautics and Astronautics, Grapevine, Texas, 2017.
- [178] P.-F. Gu, Z.-M. Liu, W. Xiong, W.-H. Chen, S.-C. Wang, A study about software v&v evaluation of safety i&c system in nuclear power plant, in: Y. Xu, H. Xia, F. Gao, W. Chen, Z. Liu, P. Gu (Eds.), Nuclear Power Plants: Innovative Technologies for Instrumentation and Control Systems, in: Lecture Notes in Electrical Engineering, vol. 507, Springer Singapore, Singapore, 2019, pp. 37–47.
- [179] L. Bressan, A.L. De Oliveira, F. Campos, Y. Papadopoulos, D. Parker, An integrated approach to support the process-based certification of variant-intensive systems, in: M. Zeller, K. Höfig (Eds.), Model-Based Safety and Assessment, in: Lecture Notes in Computer Science, vol. 12297, Springer International Publishing, Cham, 2020, pp. 179–193.
- [180] F. Molina, G. Betarte, C. Luna, Design principles for constructing GDPR-compliant blockchain solutions, in: 2021 IEEE/ACM 4th International Workshop on Emerging Trends in Software Engineering for Blockchain (WETSEB), IEEE, Madrid, Spain, 2021, pp. 1–8.
- [181] P. Grace, D. Burns, G. Neumann, B. Pickering, P. Melas, M. Surridge, Identifying privacy risks in distributed data services: A model-driven approach, in: 2018 IEEE 38th International Conference on Distributed Computing Systems (ICDCS), IEEE, Vienna, 2018, pp. 1513–1518.
- [182] M. Alsaadi, A. Lisitsa, M. Khalaf, M. Qasameh, Investigating the capability of agile processes to support medical devices regulations: The case of xp, scrum, and FDD with EU MDR regulations, in: Intelligent Computing Methodologies: 15th International Conference, ICIC 2019, Nanchang, China, August 3–6, 2019, Proceedings, Part III 15, Springer, 2019, pp. 581–592.
- [183] Y. Yu, D. Barthaud, B.A. Price, A.K. Bandara, A. Zisman, B. Nuseibeh, Live-Box: A self-adaptive forensic-ready service for drones, *IEEE Access* 7 (2019) 148401–148412.
- [184] L. Keutzer, U.S. Simonsson, Medical device Apps: An introduction to regulatory affairs for developers, *JMIR mHealth uHealth* 8 (6) (2020) e17567.
- [185] J. Perez, J.L. Flores, C. Blum, J. Cerquides, A. Abuin, Optimization techniques and formal verification for the software design of boolean algebra based safety-critical systems, *IEEE Trans. Ind. Inform.* 18 (1) (2022) 620–630.
- [186] D. Huth, A. Both, J. Ahmad, G. Sauer, F. Yilmaz, F. Matthes, Process and tool support for integration of privacy aspects in agile software engineering, 2020.
- [187] P. Barbosa, J. Queiroz, D. Santos, A. Figueiredo, F. Leite, K. Galdino, RE4CH: Requirements engineering for connected Health, in: 2018 IEEE 31st International Symposium on Computer-Based Medical Systems (CBMS), IEEE, Karlstad, 2018, pp. 292–297.
- [188] L. Provenzano, K. Hänninen, Specifying software requirements for safety-critical railway systems: An experience report, in: P. Grünbacher, A. Perini (Eds.), Requirements Engineering: Foundation for Software Quality, in: Lecture Notes in Computer Science, 10153, Springer International Publishing, Cham, 2017, pp. 363–369.
- [189] O. Ø'zcan-Top, F. McCaffery, To what extent the medical device software regulations can be achieved with agile software development methods? XP—DSDM—Scrum, *J. Supercomput.* 75 (8) (2019) 5227–5260.
- [190] C. Baron, V. Louis, Towards a continuous certification of safety-critical avionics software, *Comput. Ind.* 125 (2021) 103382.
- [191] I. Reinhartz-Berger, A. Zamansky, A. Koschmider, Towards privacy-aware software reuse, in: Proceedings of the 7th International Conference on Model-Driven Engineering and Software Development, SCITEPRESS - Science and Technology Publications, Prague, Czech Republic, 2019, pp. 448–453.
- [192] R. Meis, M. Heisel, Pattern-based representation of privacy enhancing technologies as early aspects, in: Trust, Privacy and Security in Digital Business: 14th International Conference, TrustBus 2017, Lyon, France, August 30–31, 2017, Proceedings 14, Springer, 2017, pp. 49–65.
- [193] S.J. Kearney, A. Lowe, J.K. Lennerz, A. Parwani, M.M. Bui, K. Wack, G. Giannini, E. Abels, Bridging the gap: the critical role of regulatory affairs and clinical affairs in the total product life cycle of pathology imaging devices and software, *Front. Med.* 8 (2021) 765385.
- [194] R. Campbell, R. Phillips, C. Allsopp, Lessons learnt from IEC61508 software assessments, in: Conference Proceedings of ISCSS, 2018.
- [195] V. Stirbu, T. Mikkonen, Towards agile yet regulatory-compliant development of medical software, in: 2018 IEEE International Symposium on Software Reliability Engineering Workshops, ISSREW, IEEE, 2018, pp. 337–340.
- [196] U.D. Ferrell, Mindful application of standards for avionics—an intentional, systematic, and measurable transformation, in: 2018 IEEE/AIAA 37th Digital Avionics Systems Conference, DASC, IEEE, 2018, pp. 1–8.
- [197] A. Alhazmi, N.A.G. Arachchilage, I'm all ears! listening to software developers on putting gdpr principles into software development practice, *Pers. Ubiquitous Comput.* 25 (5) (2021) 879–892.
- [198] F. Zanca, C. Brusasco, F. Pesapane, Z. Kwade, R. Beckers, M. Avanzo, Regulatory aspects of the use of artificial intelligence medical software, *Semin. Radiat. Oncol.* 32 (4) (2022) 432–441.
- [199] K. Elliott, K. Coopamootoo, E. Curran, P. Ezhilchelvan, S. Finnigan, D. Horsfall, Z. Ma, M. Ng, T. Spiliotopoulos, H. Wu, et al., Know Your Customer: Balancing innovation and regulation for financial inclusion, *Data Policy* 4 (2022) e34.
- [200] H. Müller, A. Holzinger, M. Plass, L. Brcic, C. Stumptner, K. Zatloukal, Explainability and causability for artificial intelligence-supported medical image analysis in the context of the European In Vitro Diagnostic Regulation, *New Biotechnol.* 70 (2022) 67–72.

- [201] R. Conte, F. Sansone, A. Tonacci, A.P. Pala, Privacy-by-design and minimization within a small Electronic Health Record: The Health360 case study, *Appl. Sci.* 12 (17) (2022) 8441.
- [202] C.A. Ardagna, N. Bena, R.M. De Pozuelo, Bridging the gap between certification and software development, in: *Proceedings of the 17th International Conference on Availability, Reliability and Security*, 2022, pp. 1–10.
- [203] T.R. Chhetri, A. Kurteva, R.J. DeLong, R. Hilscher, K. Korte, A. Fensel, Data protection by design tool for automated GDPR compliance verification based on semantically modeled informed consent, *Sensors* 22 (7) (2022) 2763.
- [204] A. Schidek, H. Timinger, Agilization of technical development processes for medical devices, in: *2022 IEEE 28th International Conference on Engineering, Technology and Innovation (ICE/ITMC) & 31st International Association for Management of Technology (IAMOT) Joint Conference*, IEEE, 2022, pp. 1–9.
- [205] D. Alkubaisy, L. Piras, M.G. Al-Obeidallah, K. Cox, H. Mouratidis, A framework for privacy and security requirements analysis and conflict resolution for supporting GDPR compliance through privacy-by-design, in: *International Conference on Evaluation of Novel Approaches To Software Engineering*, Springer, 2021, pp. 67–87.
- [206] E.E.Y.F. Agyei, S. Pohjolainen, H. Oinas-Kukkonen, Impact of medical device regulation on developing health behavior change support systems, in: *International Conference on Persuasive Technology*, Springer, 2022, pp. 1–15.
- [207] H. Toivakka, T. Granlund, T. Poranen, Z. Zhang, Towards RegOps: A DevOps pipeline for medical device software, in: *International Conference on Product-Focused Software Process Improvement*, Springer, 2021, pp. 290–306.
- [208] J. Marques, S. Yelisetty, T. Slavov, L. Barros, Enhancing aviation software development: An experience report on conducting audits, in: *Proceedings of the XXII Brazilian Symposium on Software Quality*, 2023, pp. 198–207.
- [209] K.H. Cha, Software as a medical device (SaMD) at the FDA: Regulatory science and review, in: *2023 IEEE John Vincent Atanasoff International Symposium on Modern Computing*, JVA, IEEE, 2023, pp. 71–74.
- [210] M. Barbareschi, S. Barone, V. Casola, S. Della Torca, D. Lombardi, Automatic test generation to improve scrum for safety agile methodology, in: *Proceedings of the 18th International Conference on Availability, Reliability and Security*, 2023, pp. 1–6.
- [211] A.-R. Ottun, M. Asadi, M. Boerger, N. Tcholtchev, J. Gonçalves, D. Borovčanin, B. Siniarski, H. Flores, One to rule them all: A study on requirement management tools for the development of modern AI-based software, in: *2023 IEEE International Conference on Big Data (BigData)*, IEEE, 2023, pp. 3556–3565.
- [212] P. Sangaroonsilp, M. Choetkietikul, H.K. Dam, A. Ghose, An empirical study of automated privacy requirements classification in issue reports, *Autom. Softw. Eng.* 30 (2) (2023) 20.
- [213] C. Hubbs, J. Myren, Automating airborne software certification compliance using cert DevOps, in: *2023 IEEE/AIAA 42nd Digital Avionics Systems Conference, DASC*, IEEE, 2023, pp. 1–6.
- [214] M. Martens, A. Schidek, M. Schmidtner, H. Timinger, ADmed: An adaptive technical process for the agile development of medical devices, in: *KDIR*, 2022, pp. 177–184.
- [215] G. Valenca, R. Kneuper, M.E. Rebelo, Privacy in software ecosystems - An initial analysis of data protection roles and challenges, in: *2020 46th Euromicro Conference on Software Engineering and Advanced Applications (SEAA)*, IEEE, Portoroz, Slovenia, 2020, pp. 120–123.
- [216] K.P. Joshi, L. Elluri, A. Nagar, An integrated knowledge graph to automate cloud data compliance, *IEEE Access* 8 (2020) 148541–148555.
- [217] R. Wirtz, M. Heisel, A. Borchert, R. Meis, A. Omerovic, K. Stølen, Risk-based elicitation of security requirements according to the ISO 27005 standard, in: *Evaluation of Novel Approaches To Software Engineering: 13th International Conference, ENASE 2018, Funchal, Madeira, Portugal, March 23–24, 2018, Revised Selected Papers 8*, Springer, 2019, pp. 71–97.
- [218] J. Guo, J. Cheng, J. Cleland-Huang, Semantically enhanced software traceability using deep learning techniques, in: *2017 IEEE/ACM 39th International Conference on Software Engineering (ICSE)*, IEEE, Buenos Aires, 2017, pp. 3–14.
- [219] S. Mandal, R. Gandhi, H. Siy, Modular norm models: A lightweight approach for modeling and reasoning about legal compliance, in: *2017 IEEE 15th Intl Conf on Dependable, Autonomous and Secure Computing, 15th Intl Conf on Pervasive Intelligence and Computing, 3rd Intl Conf on Big Data Intelligence and Computing and Cyber Science and Technology Congress (DASC/PiCom/DataCom/CyberSciTech)*, IEEE, Orlando, FL, 2017, pp. 657–662.
- [220] N. Zeni, E. Seid, P. Engiel, J. Mylopoulos, Nómots: Building large models of law with a tool-supported process, *Data Knowl. Eng.* 117 (2018) 407–418.
- [221] N. Zeni, L. Mich, J. Mylopoulos, Annotating legal documents with GaiusT 2.0, *Int. J. Metadata Semant. Ontol.* 12 (1) (2017) 47.
- [222] E. Mougiakou, M. Virvou, Based on GDPR privacy in UML: Case of e-learning program, in: *2017 8th International Conference on Information, Intelligence, Systems & Applications (IISA)*, IEEE, Larnaca, 2017, pp. 1–8.
- [223] M. Gharib, P. Giorgini, J. Mylopoulos, COPri v.2 — A core ontology for privacy requirements, *Data Knowl. Eng.* 133 (2021) 101888.
- [224] N. Boltz, L. Sterz, C. Gerking, O. Raabe, A Model-Based Framework for Simplified Collaboration of Legal and Software Experts in Data Protection Assessments, *Gesellschaft für Informatik*, Bonn, 2022.
- [225] N. Kasisopha, P. Meananeatra, Applying iso/iec 29110 to iso/iec 62304 for medical device software sme, in: *Proceedings of the 2nd International Conference on Computing and Big Data*, 2019, pp. 121–125.
- [226] E. Stefanova, A. Dimov, Privacy enabled software architecture, in: *Business Modeling and Software Design: 11th International Symposium, BMSD 2021, Sofia, Bulgaria, July 5–7, 2021, Proceedings 11*, Springer, 2021, pp. 190–206.
- [227] F. Tang, B.M. Østfold, Assessing software privacy using the privacy flow-graph, in: *Proceedings of the 1st International Workshop on Mining Software Repositories Applications for Privacy and Security*, 2022, pp. 7–15.
- [228] M. Ferreira, T. Brito, J.F. Santos, N. Santos, Poster: A systems approach to GDPR compliance-by-design in web development stacks, in: *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security*, 2022, pp. 3347–3349.
- [229] K. Drabiak, Leveraging law and ethics to promote safe and reliable AI/ML in healthcare, *Front. Nucl. Med.* 2 (2022) 983340.
- [230] A. Diepenbrock, J. Fleck, S. Sachweh, An analysis of stack exchange questions: Identifying challenges in software design and development with a focus on data privacy and data protection, in: *Proceedings of the 18th International Conference on Availability, Reliability and Security*, 2023, pp. 1–7.
- [231] A.A. Ardo, J.M. Bass, T. Gaber, Implications of regulatory policy for building secure agile software in Nigeria: A grounded theory, *Electron. J. Inf. Syst. Dev. Countries* 89 (6) (2023) e12285.
- [232] C. Neitzke, J. Mendes, L. Rivero, M. Teixeira, D. Viana, Enhancing LGPD compliance: Evaluating a checklist for LGPD quality attributes within a government office, in: *Proceedings of the XXII Brazilian Symposium on Software Quality*, 2023, pp. 218–227.
- [233] L.D. Rocha, G.R.S. Silva, E. Dias Canedo, Privacy compliance in software development: A guide to implementing the LGPD principles, in: *Proceedings of the 38th ACM/SIGAPP Symposium on Applied Computing*, 2023, pp. 1352–1361.
- [234] M. Ferreira, T. Brito, J.F. Santos, N. Santos, RuleKeeper: GDPR-aware personal data compliance for web frameworks, in: *2023 IEEE Symposium on Security and Privacy*, SP, IEEE, 2023, pp. 2817–2834.
- [235] G.B. Herwanto, F.J. Ekaputra, F. Piroi, M. Sabou, Towards a knowledge graph-based exploratory search for privacy engineering, in: *VOILA@ ISWC*, 2023, pp. 49–56.
- [236] M. Esche, F.G. Toro, F. Thiel, Representation of attacker motivation in software risk assessment using attack probability trees, in: *2017 Federated Conference on Computer Science and Information Systems (FedCSIS)*, IEEE, 2017, pp. 763–771.
- [237] C. Mayr-Dorn, M. Vierhauser, F. Keplinger, S. Bichler, A. Egyed, Time-Tracer: a tool for back in time traceability replaying, in: *Proceedings of the ACM/IEEE 42nd International Conference on Software Engineering: Companion Proceedings*, ACM, Seoul South Korea, 2020, pp. 33–36.
- [238] F. Moyón, R. Soares, M. Pinto-Albuquerque, D. Mendez, K. Beckers, Integration of security standards in DevOps pipelines: An industry case study, in: M. Morisio, M. Torchiano, A. Jedlitschka (Eds.), *Product-Focused Software Process Improvement*, in: *Lecture Notes in Computer Science*, vol. 12562, Springer International Publishing, Cham, 2020, pp. 434–452.
- [239] M. Esche, F.G. Toro, Developing Defense Strategies from Attack Probability Trees in Software Risk Assessment, 2020, pp. 527–536.
- [240] A. Paz, G.E. Boussaidi, Building a software requirements specification and design for an avionics system: an experience report, in: *Proceedings of the 33rd Annual ACM Symposium on Applied Computing*, ACM, Pau France, 2018, pp. 1262–1271.
- [241] S. Sartoli, S. Ghanavati, A. Siami Namin, Compliance requirements checking in variable environments, in: *2020 IEEE 44th Annual Computers, Software, and Applications Conference (COMPSAC)*, IEEE, Madrid, Spain, 2020, pp. 1093–1094.
- [242] A. Singh, M. D'Souza, A. Ebrahim, Conformance testing of ARINC 653 compliance for a safety critical RTOS using UPPAAL model checker, in: *Proceedings of the 36th Annual ACM Symposium on Applied Computing*, ACM, Virtual Event Republic of Korea, 2021, pp. 1807–1814.
- [243] L. Sherry, J. Baldo, B. Berlin, Design of flight guidance and control systems using explainable AI, in: *2021 Integrated Communications Navigation and Surveillance Conference (ICNS)*, IEEE, Dulles, VA, USA, 2021, pp. 1–10.
- [244] M. Ahmed, M. Safar, Symbolic execution based verification of compliance with the ISO 26262 functional safety standard, in: *2019 14th International Conference on Design & Technology of Integrated Systems in Nanoscale Era (DTIS)*, IEEE, Mykonos, Greece, 2019, pp. 1–6.
- [245] M. Todde, M. Beltrame, S. Marcegaglia, C. Spagno, Methodology and workflow to perform the Data Protection Impact Assessment in healthcare information systems, *Inf. Med. Unlocked* 19 (2020) 100361.
- [246] J. Marques, A.M. da Cunha, Verification Scenarios of Onboard Databases under the RTCA DO-178C and the RTCA DO-200B, in: *2017 IEEE/AIAA 36th Digital Avionics Systems Conference, DASC*, IEEE, 2017, pp. 1–8.
- [247] P. Birnstill, E. Krempel, P.G. Wagner, J. Beyerer, Identity management and protection motivated by the general data protection regulation of the European union—A conceptual framework based on state-of-the-art software technologies, *Technologies* 6 (4) (2018) 115.
- [248] M. Mourby, K.O. Cathaoir, C.B. Collin, Transparency of machine-learning in healthcare: The GDPR & European health law, *Comput. Law Secur. Rev.* 43 (2021) 105611.

- [249] T. Saraç, Certification aspects of model based development for airborne software, in: 2019 IEEE 2nd International Conference on Information and Computer Technologies, ICICT, IEEE, 2019, pp. 285–291.
- [250] Y. Huang, J. Debnath, M. Iorga, A. Kumar, B. Xie, CSAT: a user-interactive cyber security architecture tool based on nist-compliance security controls for risk management, in: 2019 IEEE 10th Annual Ubiquitous Computing, Electronics & Mobile Communication Conference, UEMCON, IEEE, 2019, pp. 0697–0707.
- [251] H. Kuwajima, F. Ishikawa, Adapting square for quality assessment of artificial intelligence systems, in: 2019 IEEE International Symposium on Software Reliability Engineering Workshops, ISSREW, IEEE, 2019, pp. 13–18.
- [252] T. Hernandez-Boussard, M.P. Lundgren, N. Shah, Conflicting information from the food and drug administration: Missed opportunity to lead standards for safe and effective medical artificial intelligence solutions, *J. Am. Med. Inf. Assoc.* 28 (6) (2021) 1353–1355.
- [253] Z.Ä. Mann, F. Kunz, J. Laufer, J. Bellendorf, A. Metzger, K. Pohl, RADAR: Data protection in cloud-based computer systems at run time, *IEEE Access* 9 (2021) 70816–70842.
- [254] M. Yuba, K. Iwasaki, Systematic analysis of the test design and performance of AI/ML-based medical devices approved for triage/detection/diagnosis in the USA and Japan, *Sci. Rep.* 12 (1) (2022) 16874.
- [255] A. Khurshid, R. Alsaaidi, M. Aslam, S. Raza, EU cybersecurity act and IoT certification: landscape, perspective and a proposed template scheme, *IEEE Access* 10 (2022) 129932–129948.
- [256] D. Russell, A. Moitra, K. Siu, C. McMillan, Modeling a DO-178C plan and analyzing in a semantic model, in: 2022 Annual Reliability and Maintainability Symposium, RAMS, IEEE, 2022, pp. 1–8.
- [257] M.A. Javed, F.U. Muram, S. Kanwal, Ontology-based natural language processing for process compliance management, in: International Conference on Evaluation of Novel Approaches To Software Engineering, Springer, 2021, pp. 309–327.
- [258] N. Feng, L. Marsso, S.G. Yaman, B. Townsend, A. Cavalcanti, R. Calinescu, M. Chechik, Towards a formal framework for normative requirements elicitation, in: 2023 38th IEEE/ACM International Conference on Automated Software Engineering, ASE, IEEE, 2023, pp. 1776–1780.
- [259] Á. Milánkovich, K. Tuma, Delta security certification for software supply chains, *IEEE Secur. Privacy* (2023).
- [260] J. Guber, Privacy-compliant software reuse: A framework for considering privacy compliance in software reuse scenarios, *Proceedings http://ceur-ws.org ISSN 1613* (2023) 0073.
- [261] G. Schuster, Certification of software tools used in safety-critical software development, in: 2022 IEEE 5th International Conference and Workshop Óbuda on Electrical and Power Engineering (CANDO-EPE), IEEE, 2022, pp. 000211–000216.
- [262] L. Bao, C. Fuhrman, R. Landry, Certification considerations of software-defined radio using model-based development and automated testing, in: 2023 IEEE/AIAA 42nd Digital Avionics Systems Conference, DASC, IEEE, 2023, pp. 1–8.
- [263] M. Esche, L. Ho, M. Nischwitz, R. Meyer, Risk-based continuous quality control for software in legal metrology, in: 2023 18th Conference on Computer Science and Intelligence Systems (FedCSIS), IEEE, 2023, pp. 451–461.
- [264] M. Kellogg, M. Schäff, S. Tasiran, M.D. Ernst, Continuous compliance, in: 2020 35th IEEE/ACM International Conference on Automated Software Engineering, ASE, IEEE, 2020, pp. 511–523.
- [265] X. Larrucea, A. Walker, R. Colomo-Palacios, Supporting the management of reusable automotive software, *IEEE Softw.* 34 (3) (2017) 40–47.
- [266] A. Hayrapetian, R. Raj, Empirically analyzing and evaluating security features in software requirements, in: Proceedings of the 11th Innovations in Software Engineering Conference, ACM, Hyderabad India, 2018, pp. 1–11.
- [267] A.K. Jha, P. Choudhary, Adopting Model-Based Software Design and Verification for Aerospace Systems, Technical Report, SAE Technical Paper, 2017.
- [268] M. Adedjouma, A. Smaoui, Model-based computer-aided monitoring for ISO26262 compliant systems, in: 2018 IEEE International Symposium on Software Reliability Engineering Workshops (ISSREW), IEEE, Memphis, TN, 2018, pp. 349–352.
- [269] A. Tsohou, E. Magkos, H. Mouratidis, G. Chrysoloras, L. Piras, M. Pavlidis, J. Debussche, M. Rotoloni, B. Gallego-Nicasio Crespo, Privacy, security, legal and technology acceptance elicited and consolidated requirements for a GDPR compliance platform, *Inf. Comput. Secur.* 28 (4) (2020) 531–553.
- [270] J. Marques, A.M. da Cunha, Tailoring traditional software life cycles to ensure compliance of rtca do-178c and do-331 with model-driven design, in: 2018 IEEE/AIAA 37th Digital Avionics Systems Conference, DASC, IEEE, 2018, pp. 1–8.
- [271] K. Chitnis, M. Mody, P. Swami, R. Sivaraj, C. Ghone, M. Biju, B. Narayanan, Y. Dutt, A. Dubey, Enabling functional safety ASIL compliance for autonomous driving software systems, *Electron. Imaging* 29 (2017) 35–40.
- [272] P.R. Anish, P. Sonar, P. Lawhatre, S. Ghaisas, Automated identification and deconstruction of penalty clauses in regulation, in: 2021 IEEE 29th International Requirements Engineering Conference Workshops, REW, IEEE, 2021, pp. 96–105.
- [273] M. Mubarkoot, J. Altmann, Towards software compliance specification and enforcement using TOSCA, in: Economics of Grids, Clouds, Systems, and Services: 18th International Conference, GECON 2021, Virtual Event, September 21–23, 2021, Proceedings 18, Springer, 2021, pp. 168–177.
- [274] V. Stirbu, T. Granlund, J. Helén, T. Mikkonen, Extending SOUP to ML models when designing certified medical systems, in: 2021 IEEE/ACM 3rd International Workshop on Software Engineering for Healthcare, SEH, IEEE, 2021, pp. 32–35.
- [275] D. Alkubaisy, L. Piras, M.G. Al-Obeidallah, K. Cox, H. Mouratidis, Confls: a tool for privacy and security analysis and conflict resolution for supporting GDPR compliance through privacy-by-design, in: International Conference on Evaluation of Novel Approaches to Software Engineering, ENASE-Proceedings, vol. 2021, SCITEPRESS-Science and Technology Publications, 2021, pp. 80–91.
- [276] D. Klein, B. Rolle, T. Barber, M. Karl, M. Johns, General data protection runtime: Enforcing transparent GDPR compliance for existing applications, in: Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security, 2023, pp. 3343–3357.
- [277] L. Thiele-Evans, B. Pepper, J. Zelezniuk, N. Foster, T. Sourdin, Regulatory approaches to managing artificial intelligence systems in autonomous vehicles in Australia, *Int. J. Law Inf. Technol.* 29 (2) (2021) 79–100.
- [278] S. Colloud, T. Metcalfe, S. Askin, S. Belachew, J. Ammann, E. Bos, T. Kilchenmann, P. Strijbos, D. Eggenspieler, L. Servais, et al., Evolving regulatory perspectives on digital health technologies for medicinal product development, *NPJ Digit. Med.* 6 (1) (2023) 56.
- [279] K.A. Cepeda Zapata, T. Ward, R. Loughran, F. McCaffery, Challenges associated with the adoption of artificial intelligence in medical device software, in: Irish Conference on Artificial Intelligence and Cognitive Science, Springer, 2022, pp. 163–174.
- [280] C. Baron, V. Louis, Framework and tooling proposals for agile certification of safety-critical embedded software in avionic systems, *Comput. Ind.* 148 (2023) 103887.
- [281] L. Sion, P. Dewitte, D. Van Landuyt, K. Wuyts, I. Emanuilov, P. Valcke, W. Joosen, An architectural view for data protection by design, in: 2019 IEEE International Conference on Software Architecture (ICSA), IEEE, Hamburg, Germany, 2019, pp. 11–20.
- [282] N. Amara, Z. Huang, A. Ali, Modelling security requirements for software development with common criteria, in: G. Wang, J. Feng, M.Z.A. Bhuiyan, R. Lu (Eds.), Security, Privacy, and Anonymity in Computation, Communication, and Storage, in: Lecture Notes in Computer Science, vol. 11611, Springer International Publishing, Cham, 2019, pp. 78–88.
- [283] L. Feng, Research on airworthiness certification of airborne software in civil aircraft compliance verification test, in: CSAA/IET International Conference on Aircraft Utility Systems (AUS 2022), vol. 2022, IET, 2022, pp. 586–591.
- [284] K.A.C. Zapata, T. Ward, R. Loughran, F. McCaffery, A review of the artificial intelligence act proposal and the medical device regulation, in: 2023 31st Irish Conference on Artificial Intelligence and Cognitive Science, AICS, IEEE, 2023, pp. 1–6.
- [285] J. Saraiva, S. Soares, Privacy and security documents for agile software engineering: An experiment of LGPD inventory adoption, in: 2023 ACM/IEEE International Symposium on Empirical Software Engineering and Measurement, ESEM, IEEE, 2023, pp. 1–9.
- [286] C. Perera, M. Barhamgi, M. Vecchio, Envisioning tool support for designing privacy-aware internet of thing applications, *IEEE Internet of Things Mag.* 4 (1) (2021) 78–83.
- [287] C. Mills, Towards the automatic classification of traceability links, in: 2017 32nd IEEE/ACM International Conference on Automated Software Engineering (ASE), IEEE, Urbana, IL, 2017, pp. 1018–1021.
- [288] O.T. Arogundade, T.E. Abioye, A.M. Mustapha, A.M. Adeniji, A.M. Ikotun, F.O. Asahiah, Specifying and incorporating compliance requirements into software development using UML and OCL, in: Computational Science and Its Applications-ICCSA 2018: 18th International Conference, Melbourne, VIC, Australia, July 2–5, 2018, Proceedings, Part IV 18, Springer, 2018, pp. 511–526.
- [289] D. Streitferdt, A. Zimmermann, J. Schaffner, M. Kallenbach, Complete component-wise software certification for safety-critical embedded devices, in: 2018 IEEE 9th Annual Information Technology, Electronics and Mobile Communication Conference (IEMCON), IEEE, Vancouver, BC, 2018, pp. 597–602.
- [290] N.E.D. Ferreyra, P. Tessier, G. Pedroza, M. Heisel, PDP-ReqLite: A lightweight approach for the elicitation of privacy and data protection requirements, in: Data Privacy Management, Cryptocurrencies and Blockchain Technology: ESORICS 2020 International Workshops, DPM 2020 and CBT 2020, Guildford, UK, September 17–18, 2020, Revised Selected Papers 15, Springer, 2020, pp. 161–177.
- [291] J.P. Castellanos Ardila, B. Gallina, Towards increased efficiency and confidence in process compliance, in: Systems, Software and Services Process Improvement: 24th European Conference, EuroSPI 2017, Ostrava, Czech Republic, September 6–8, 2017, Proceedings 24, Springer, 2017, pp. 162–174.
- [292] D. Streitferdt, A. Zimmermann, J. Schaffner, M. Kallenbach, Component-wise software certification for safety-critical embedded devices, in: 2017 8th Annual Industrial Automation and Electromechanical Engineering Conference, IEMECON, IEEE, 2017, pp. 175–180.

- [293] A.-J. Aberkane, Automated GDPR-compliance in requirements engineering, in: 33rd International Conference on Advanced Information Systems Engineering (CAISE 2021), 2906, 2021, pp. 21–29.
- [294] V.S. Bhamidipati, S. De, A risk based approach for privacy compliant machine learning lifecycle, in: 2022 2nd International Conference on Intelligent Technologies, CONIT, IEEE, 2022, pp. 1–6.
- [295] P. Sahu, S. Roy, M. Gharote, S. Lodha, Web services relocation and reallocation for data residency compliance, in: 2023 IEEE/ACM 23rd International Symposium on Cluster, Cloud and Internet Computing Workshops (CCGridW), IEEE, 2023, pp. 125–132.
- [296] Q. Rouland, S. Gjorcheski, J. Jaskolka, A security compliance-by-design framework utilizing reusable formal models, in: 2023 IEEE 23rd International Conference on Software Quality, Reliability, and Security Companion (QRS-C), IEEE, 2023, pp. 186–195.
- [297] M.D. Harrison, P. Masci, J.C. Campos, P. Curzon, Verification of user interface software: The example of use-related safety requirements and programmable medical devices, *IEEE Trans. Hum.-Mach. Syst.* 47 (6) (2017) 834–846.
- [298] E. Vanezi, G. Kapitsaki, D. Kouzapas, A. Philippou, A formal modeling scheme for analyzing a software system design against the GDPR, in: Proceedings of the 14th International Conference on Evaluation of Novel Approaches to Software Engineering, SCITEPRESS - Science and Technology Publications, Heraklion, Crete, Greece, 2019, pp. 68–79.
- [299] A. Gannous, A. Andrews, B. Gallina, Toward a systematic and safety evidence productive verification approach for safety-critical systems, in: 2018 IEEE International Symposium on Software Reliability Engineering Workshops (ISSREW), IEEE, Memphis, TN, 2018, pp. 329–336.
- [300] E. Niemiec, Will the EU Medical Device Regulation help to improve the safety and performance of medical AI devices? *Digit. Health* 8 (2022) 20552076221089079.
- [301] A. Tsohou, E. Kosta, Enabling valid informed consent for location tracking through privacy awareness of users: A process theory, *Comput. Law Secur. Rev.* 33 (4) (2017) 434–457.
- [302] O. Pantelic, K. Jovic, S. Krstovic, Cookies implementation analysis and the impact on user privacy regarding GDPR and CCPA regulations, *Sustainability* 14 (9) (2022) 5015.
- [303] M. Werthwein, M. Brunner, B. Annghoefer, A concept enabling cybersecurity for a self-adaptive avionics platform with respect to RTCA DO-326 and RTCA DO-356, in: 2023 IEEE/AIAA 42nd Digital Avionics Systems Conference, DASC, IEEE, 2023, pp. 1–10.
- [304] M. Chechik, Uncertain requirements, assurance and machine learning, in: 2019 IEEE 27th International Requirements Engineering Conference (RE), IEEE, Jeju Island, Korea (South), 2019, pp. 2–3.
- [305] M. Anisetti, C.A. Ardagna, E. Damiani, F. Gaudenzi, A semi-automatic and trustworthy scheme for continuous cloud service certification, *IEEE Trans. Serv. Comput.* 13 (1) (2020) 30–43.
- [306] A. Henderson, S. Harbour, K. Cohen, Toward airworthiness certification for artificial intelligence (AI) in aerospace systems, in: 2022 IEEE/AIAA 41st Digital Avionics Systems Conference, DASC, IEEE, 2022, pp. 1–10.
- [307] S.S. Makkar, A.M. Abdelfatah, A.H. Yousef, Automotive standards compliance cost reduction by mutual integration between automotive SPICE and IATF 16949:2016, in: 2019 IEEE International Conference on Vehicular Electronics and Safety (ICVES), IEEE, Cairo, Egypt, 2019, pp. 1–6.
- [308] O. Ø'zcan-Top, F. McCaffery, A lightweight software process assessment approach based on MDevSPICE[®] for medical device development domain, in: J. Stolfa, S. Stolfa, R.V. O'Connor, R. Messnarz (Eds.), *Systems, Software and Services Process Improvement*, in: Communications in Computer and Information Science, vol. 748, Springer International Publishing, Cham, 2017, pp. 578–588.
- [309] D. Kim, Y.-S. Park, B. Lee, J.-W. Lee, Association-based process integration for compliance with core standards in development of medical software, in: J.J. Park, V. Loia, G. Yi, Y. Sung (Eds.), *Advances in Computer Science and Ubiquitous Computing*, in: Lecture Notes in Electrical Engineering, vol. 474, Springer Singapore, Singapore, 2018, pp. 1220–1226.
- [310] S. Sameh, S. EL-Toukhi, Application of mutually integrated international standards (A-SPICE PAM 3.1 & IATF 16949/2016), in: M. Yilmaz, J. Niemann, P. Clarke, R. Messnarz (Eds.), *Systems, Software and Services Process Improvement*, in: Communications in Computer and Information Science, vol. 1251, Springer International Publishing, Cham, 2020, pp. 673–683.
- [311] N. Li, C. Tsigkanos, Z. Jin, S. Dustdar, Z. Hu, C. Ghezzi, POET: Privacy on the edge with bidirectional data transformations, in: 2019 IEEE International Conference on Pervasive Computing and Communications (PerCom), IEEE, Kyoto, Japan, 2019, pp. 1–10.
- [312] T. Besker, A. Martini, J. Bosch, How regulations of safety-critical software affect technical debt, in: 2019 45th Euromicro Conference on Software Engineering and Advanced Applications (SEAA), IEEE, Kallithea-Chalkidiki, Greece, 2019, pp. 74–81.
- [313] A.C. Serban, E. Poll, J. Visser, A standard driven software architecture for fully autonomous vehicles, in: 2018 IEEE International Conference on Software Architecture Companion (ICSA-C), IEEE, Seattle, WA, 2018, pp. 120–127.
- [314] V. Zinchenko, K. Arzamasov, S. Chetverikov, A. Maltsev, V. Novik, E. Akhmad, D. Sharova, A. Andreychenko, A. Vladzmyrsky, S. Morozov, Methodology for conducting post-marketing surveillance of software as a medical device based on artificial intelligence technologies, 14 (5 (eng)) (2022) 15–23.
- [315] T. Laukkarinen, K. Kuusinen, T. Mikkonen, DevOps in regulated software development: Case medical devices, in: 2017 IEEE/ACM 39th International Conference on Software Engineering: New Ideas and Emerging Technologies Results Track (ICSE-NIER), IEEE, Buenos Aires, Argentina, 2017, pp. 15–18.
- [316] L. Dieudonné, A. Bayha, B. Müller, S. Götz, RMC factory: A new approach for avionics software reuse, in: Software Engineering (Satellite Events), 2021, pp. 1–21.
- [317] M. Ahmed, M. Safar, Formal verification of AUTOSAR watchdog manager module using symbolic execution, in: 2018 30th International Conference on Microelectronics (ICM), IEEE, Sousse, Tunisia, 2018, pp. 240–243.
- [318] S. Sartoli, S. Ghanavati, A.S. Namin, Towards variability-aware legal-GRL framework for modeling compliance requirements, in: 2020 IEEE 7th International Workshop on Evolving Security & Privacy Requirements Engineering, ESPRE, IEEE, 2020, pp. 7–12.
- [319] P. Graydon, I. Habli, R. Hawkins, T. Kelly, J. Knight, Arguing conformance, *IEEE Softw.* 29 (3) (2012) 50–57.
- [320] T.D. Breaux, A.I. Antón, A systematic method for acquiring regulatory requirements: A frame-based approach, in: 6th International Workshop on Requirements for High Assurance Systems, 2007, pp. 1–6.
- [321] N. Giordano, S. Rosati, G. Balestra, Medical device software: From requirements to certification, in: Telehealth Ecosystems in Practice, IOS Press, 2023, pp. 139–140.
- [322] R. Maerani, Saharudin, Sudarno, S. Santoso, Deswandri, S. Bakhri, J.-C. Jung, Developing digital instrumentation and control system for experimental power reactor by following IEEE Std 1012, *J. Phys. Conf. Ser.* 1772 (1) (2021) 012042.
- [323] M. Colesky, J.C. Caiza, A system of privacy patterns for informing users: Creating a pattern system, in: Proceedings of the 23rd European Conference on Pattern Languages of Programs, ACM, Isersee Germany, 2018, pp. 1–11.
- [324] N. Zeni, E. Seid, P. Engiel, J. Mylopoulos, NómoS: Building large models of law with a tool-supported process, *Data Knowl. Eng.* 117 (2018) 407–418.
- [325] J. Marques, A.M. Da Cunha, A set of requirements for certification of airborne military software, in: 2019 IEEE/AIAA 38th Digital Avionics Systems Conference (DASC), IEEE, San Diego, CA, USA, 2019, pp. 1–7.
- [326] A.K. Massey, P.N. Otto, L.J. Hayward, A.I. Antón, Evaluating existing security and privacy requirements for legal compliance, *Requir. Eng.* 15 (2010) 119–137.
- [327] B. Ojameruaye, R. Bahsoon, Systematic elaboration of compliance requirements using compliance debt and portfolio theory, in: Requirements Engineering: Foundation for Software Quality: 20th International Working Conference, REFSQ 2014, Essen, Germany, April 7–10, 2014. Proceedings 20, Springer, 2014, pp. 152–167.
- [328] A. Al-Momani, F. Kargl, R. Schmidt, A. Kung, C. Bosch, A privacy-aware V-model for software development, in: 2019 IEEE Security and Privacy Workshops (SPW), IEEE, San Francisco, CA, USA, 2019, pp. 100–104.
- [329] G. Bahig, A. El-Kadi, Formal verification of automotive design in compliance with ISO 26262 design verification guidelines, *IEEE Access* 5 (2017) 4505–4516.
- [330] M. Farhadi, H. Haddad, H. Shahriar, Static analysis of HIPPA security requirements in electronic health record applications, in: 2018 IEEE 42nd Annual Computer Software and Applications Conference (COMPSAC), IEEE, Tokyo, Japan, 2018, pp. 474–479.
- [331] I. Kunz, P. Stephanow, C. Banse, An edge framework for the application of privacy enhancing technologies in IoT communications, in: ICC 2020 - 2020 IEEE International Conference on Communications (ICC), IEEE, Dublin, Ireland, 2020, pp. 1–6.
- [332] P. Li, C. Xu, Y. Luo, Y. Cao, J. Mathew, Y. Ma, CareNet: Building a secure software-defined infrastructure for home-based healthcare, in: Proceedings of the ACM International Workshop on Security in Software Defined Networks & Network Function Virtualization, ACM, Scottsdale Arizona USA, 2017, pp. 69–72.
- [333] M. Sousa, D.N.G. Ferreira, C.S. Pereira, G. Bacelar, S. Frade, O. Pestana, R.C. Correia, openEHR based systems and the general data protection regulation (GDPR), in: Building Continents of Knowledge in Oceans of Data: The Future of Co-Created eHealth, 2018.
- [334] L. Sion, P. Dewitte, D. Van Landuyt, K. Wuyts, I. Emanuilov, P. Valcke, W. Joosen, An architectural view for data protection by design, in: 2019 IEEE International Conference on Software Architecture, ICSA, IEEE, 2019, pp. 11–20.
- [335] P. Li, C. Xu, H. Jin, C. Hu, Y. Luo, Y. Cao, J. Mathew, Y. Ma, ChainSDI: A software-defined infrastructure for regulation-compliant home-based healthcare services secured by blockchains, *IEEE Syst. J.* 14 (2) (2020) 2042–2053.
- [336] G. Blanco-Lainé, J.-S. Sottet, S. Dupuy-Chessa, Using an enterprise architecture model for GDPR compliance principles, in: The Practice of Enterprise Modeling: 12th IFIP Working Conference, PoEM 2019, Luxembourg, Luxembourg, November 27–29, 2019, Proceedings 12, Springer, 2019, pp. 199–214.

- [337] L. Montgomery, D. Fucci, A. Bouraffa, L. Scholz, W. Maalej, Empirical research on requirements quality: A systematic mapping study, *Requir. Eng.* 27 (2) (2022) 183–209.
- [338] K. Petersen, S. Vakkalanka, L. Kuzniarz, Guidelines for conducting systematic mapping studies in software engineering: An update, *Inf. Softw. Technol.* 64 (2015) 1–18.